Hitchpost

System Analysis and Design

Package	HP-SAD, 21 documents, version 1.0
Status	Baselined for Phase 2
Date	2026-11-09
Owner	Sanaullah Jannisar, product and engineering lead
Built from	commit 3274d6d
Source	Markdown in docs/sad is the source of truth; this PDF is generated from it.
License	MIT

Contents

HP-SAD-00 · Document control and standards conformance
HP-SAD-01 · Vision and scope
HP-SAD-02 · Feasibility study
HP-SAD-03 · Business case
HP-SAD-04 · Stakeholders and personas
HP-SAD-05 · Requirements specification
HP-SAD-06 · Use cases
HP-SAD-07 · Process and behaviour models
HP-SAD-08 · Data design
HP-SAD-09 · Data dictionary
HP-SAD-10 · System architecture
HP-SAD-11 · Quality attributes
HP-SAD-12 · Security and privacy
HP-SAD-13 · Interface design
HP-SAD-14 · User interface design
HP-SAD-15 · Test strategy and plan
HP-SAD-16 · Project plan
HP-SAD-17 · Transition plan
HP-SAD-18 · Deployment and operations
HP-SAD-19 · Maintenance and evolution
HP-SAD-20 · Glossary

HP-SAD-00 · Document control and standards conformance

Field	Value
Document ID	HP-SAD-00
Version	1.2
Status	Baselined for Phase 2
Date	2026-11-09
Owner	Sanaullah Jannisar, product and engineering lead
Conforms to	ISO/IEC/IEEE 15289 (information items), ISO/IEC/IEEE 12207 (configuration and information management processes)

1. Purpose and scope

This is the control document for the Hitchpost system analysis and design package (HP-SAD). It says what is in the package, how to read it, which standards each part follows and how far, how the package is baselined and changed, who has reviewed it, and the normative values and phases every other document must use.

The package covers the whole life of the system: vision, feasibility, analysis, design, verification, delivery, transition, operation and maintenance. It describes what is built today (end of Phase 1 plus the audit fixes) and designs forward to production (Phase 6) and beyond.

2. How to read this package

Audience	Start with	Then	Time
Executive or investor	01 Vision and scope	02 Feasibility, 03 Business case, 16 Project plan	30 min
Product manager or analyst	01, 04 Stakeholders and personas	05 Requirements, 06 Use cases, 07 Process models, 14 UI design	2 h
Engineer	10 Architecture	13 Interfaces, 08 Data design, 09 Data dictionary, 11 Quality attributes, 12 Security	2 h
Operations and support	18 Deployment and operations	17 Transition plan, 19 Maintenance, 12 Security	1 h
Assessor or auditor	This document (sections 5, 8 and 10)	05 traceability matrix, 15 Test strategy, the Phase 1 audit	1 h

Every item carries a status: **Built** (in the code now, with a path or test cited), **Phase N** (planned for that phase) or **Later** (after v1). Nothing planned is written as if it exists. Where a value or a phase appears in more than one document, section 10 of this document is the single source and the other documents cite its ID.

3. Document register

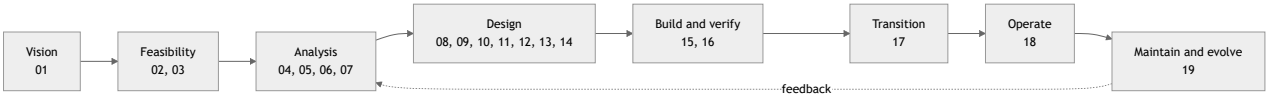
The current version of each document is in its own header table and revision history; this register lists identity and standard only, so it can't drift.

ID	Title	File	Status	Primary standard
HP-SAD-00	Document control and standards conformance	00-document-control.md	Baselined	ISO/IEC/IEEE 15289
HP-SAD-01	Vision and scope	01-vision-and-scope.md	Baselined	ISO/IEC/IEEE 29148 (BRS)
HP-SAD-02	Feasibility study	02-feasibility-study.md	Baselined	ISO/IEC/IEEE 15288 (business analysis)
HP-SAD-03	Business case	03-business-case.md	Baselined	ISO/IEC/IEEE 29148 (BRS)
HP-SAD-04	Stakeholders and personas	04-stakeholders-and-personas.md	Baselined	ISO/IEC/IEEE 29148 (StRS), 42010
HP-SAD-05	Requirements specification	05-requirements.md	Baselined	ISO/IEC/IEEE 29148 (SyRS/SRS)
HP-SAD-06	Use cases	06-use-cases.md	Baselined	ISO/IEC/IEEE 29148 (operational scenarios)
HP-SAD-07	Process and behaviour models	07-process-and-behaviour-models.md	Baselined	IEEE 1016 (interaction, state dynamics)
HP-SAD-08	Data design	08-data-design.md	Baselined	IEEE 1016 (information viewpoint)
HP-SAD-09	Data dictionary	09-data-dictionary.md	Baselined	IEEE 1016 (information viewpoint)
HP-SAD-10	System architecture	10-architecture.md	Baselined	ISO/IEC/IEEE 42010
HP-SAD-11	Quality attributes	11-quality-attributes.md	Baselined	ISO/IEC 25010, ATAM
HP-SAD-12	Security and privacy	12-security-and-privacy.md	Baselined	ISO/IEC 27001 Annex A (informative), GDPR
HP-SAD-13	Interface design	13-interfaces.md	Baselined	IEEE 1016 (interface viewpoint)
HP-SAD-14	User interface design	14-user-interface-design.md	Baselined	IEEE 1016, WCAG 2.2 AA
HP-SAD-15	Test strategy and plan	15-test-strategy.md	Baselined	ISO/IEC/IEEE 29119-3
HP-SAD-16	Project plan	16-project-plan.md	Baselined	ISO/IEC/IEEE 16326
HP-SAD-17	Transition plan	17-transition-plan.md	Baselined	ISO/IEC/IEEE 12207 (transition process)
HP-SAD-18	Deployment and operations	18-deployment-and-operations.md	Baselined	ISO/IEC/IEEE 12207 (operation process)
HP-SAD-19	Maintenance and evolution	19-maintenance-and-evolution.md	Baselined	ISO/IEC/IEEE 14764

ID	Title	File	Status	Primary standard
HP-SAD-20	Glossary	20-glossary.md	Baselined	ISO/IEC/IEEE 24765

Supporting records outside the package, not baselined but referenced: decision records, build journey, bug log, audits.

4. Lifecycle coverage



5. Standards conformance matrix

I claim alignment, not certification. Each row maps a standard's information item to where this package provides it. The rules I applied:

- **Full** only when the cited section delivers the item now and was checked in the 2026-11-09 review. The row names that section.
- **Partial** when the item exists but is incomplete, unreviewed, or planned for a later phase. The row says what is missing and when it lands.
- **N/A** with a reason.

These standards are paywalled; the mapping follows their published outlines and clause titles, not the full texts.

5.1 ISO/IEC/IEEE 29148:2018, requirements engineering

Information item	Where	Conformance
BRS: business purpose, scope, business environment	01 sections 1 to 4; 03 section 1	Full
BRS: business model, goals, stakeholders	01 goals; 03 section 2; 04 stakeholder map	Partial: the pricing hypothesis is untested (A-04 in 03)
StRS: stakeholder needs, operational concept, user characteristics	04 personas and journeys	Partial: personas are assumptions until the A-01 and A-02 discovery work (16) produces real interview data
StRS: operational scenarios	06 use cases	Full
SyRS/SRS: functional requirements, uniquely identified	05 functional requirements (FR-*)	Full
SyRS/SRS: performance, usability, security, reliability, maintainability requirements	05 non-functional requirements (NFR-*); 11 scenarios	Partial: performance targets are unmeasured until Phase 6 load tests
SyRS/SRS: interfaces (external, user, software, communications)	13 interfaces; 14 UI design	Partial: the Phase 2 protocol rules (extension header, duplicate handling, capability tokens) are checked against SDK 1.3 source but not yet proven by tests (TC-36, TC-48 to TC-50)
SyRS/SRS: design constraints, assumptions, dependencies	05 constraints; 03 assumptions	Full
Verification method per requirement	05 traceability matrix; 15 requirement coverage	Partial: Phase 2+ test cases are identified, not yet written
Requirement attributes (priority, source, status)	05 tables (phase, status, source)	Partial: priority is expressed as phase, not a separate MoSCoW field
Requirements quality review (necessary, unambiguous, verifiable)	Section 8 of this document	Partial: reviews so far were run as AI agents under my direction; no independent human review yet (planned before Phase 6)

5.2 ISO/IEC/IEEE 42010:2022, architecture description

Element	Where	Conformance
Identification and overview of the architecture description	10 opening and section 1	Full
Stakeholders and their concerns	04 stakeholder map; 10 section 1 drivers	Full
Viewpoints (named, with concerns and model kinds)	10 viewpoint catalogue	Partial: catalogue added in the 1.1 remediation; not yet reviewed against the standard's full content
Views and models	10 C4 diagrams; 07 behaviour models; 08 data model	Full
Correspondences between views	10 correspondence rules; 05 traceability matrix	Partial: rules stated; not mechanically checked
Architecture rationale and decisions	10 decisions section; ADRs 0001 to 0012 and 0018 accepted, 0013 to 0017 written as proposals	Partial: five of the seven Phase 2+ decisions are still proposals, each with a decide-by milestone
Known issues and open questions	19 tech-debt register; 10 open proposals	Full

5.3 IEEE 1016-2009, software design descriptions

Design viewpoint	Where	Conformance
Context	10 context view	Full

Design viewpoint	Where	Conformance
Composition	10 container and component views	Full
Logical	08 domain model	Full
Dependency	10 component view; package graph in `pnpm-workspace.yaml`	Full
Information	08 data design; 09 data dictionary	Full
Patterns use	10 cross-cutting concerns	Partial: patterns named, not catalogued
Interface	13 interfaces; 14 UI design	Full
Structure	10 component view	Full
Interaction	10 sequences; 06 use cases	Partial: Phase 2 sequences are checked against SDK source, not yet executed
State dynamics	07 state machines	Full
Algorithm	07 decision tables; slot finding in `packages/barber-agent/src/book.ts`	Full
Resource	18 capacity and cost notes; 11 performance scenarios	Partial: no load measurements until Phase 6

5.4 ISO/IEC/IEEE 29119-3:2021, test documentation

Document	Where	Conformance
Test policy and organisational strategy	15 the rule; ADR 0005	Full
Test plan (project level)	15 levels, entry and exit criteria, release checklist; 16 test work	Partial: risk basis and schedule for Phase 2+ testing are in 15 and 16 but not yet executed
Test design and case specifications	15 test case list (TC-*); test files under `packages/*/src/*.test.ts`	Partial: Built tests are specified in code; Phase 2+ cases are listed, not yet written
Test procedure, data and environment	15 test data and time; 18 environments	Partial: staging does not exist until Phase 6
Test completion and incident reports	Phase 1 audit; bug log	Partial: per-phase completion reports start at the Phase 2 gate

5.5 ISO/IEC 25010:2023, product quality model

Characteristic	Where	Conformance
Functional suitability	05 FR-*; 15 coverage	Full
Performance efficiency	NFR-PERF-01, NFR-PERF-02; 11 scenarios	Partial: unmeasured until Phase 6
Compatibility (interoperability)	NFR-INT-01; 13 versioning	Partial: no third-party agent tested yet
Interaction capability (usability, accessibility)	NFR-A11Y-01; 14 UI design	Partial: no usability test run yet
Reliability	NFR-REL-01, NFR-REL-02; 18 SLOs, recovery	Partial: designed, not exercised
Security	NFR-SEC-*; 12 security and privacy	Partial: agent authentication is Phase 6
Maintainability	NFR-MAINT-*; 19 maintenance	Full
Flexibility (portability, adaptability)	10 deployment view; ADR 0016 (proposed)	Partial
Safety	Not applicable: no physical harm path; harm is financial or privacy, covered under security	N/A

5.6 ISO/IEC/IEEE 12207:2017 and 15288:2023, lifecycle processes

Process	Where	Conformance
Business or mission analysis	01, 02, 03	Full
Stakeholder needs and requirements definition	04, 06	Partial: no stakeholder interviews yet
System and software requirements definition	05	Full
Architecture definition	10, 11	Full
Design definition	07, 08, 09, 13, 14	Full
Implementation	Code under `packages/`; CONTRIBUTING.md	Full for Phase 1
Verification and validation	15; Phase 1 audit	Partial: validation with real users not yet run
Transition	17	Partial: planned, not executed
Operation	18	Partial: planned, not executed
Maintenance	19	Partial: planned, not executed
Project planning, assessment and control	16	Partial: resource-loaded and re-baselined; no progress measured against it yet
Risk management	03 risks; 12 threat model	Full
Configuration management	Section 7 of this document; git; ADR 0005	Partial: branch protection not on until the repository is pushed
Information management	This document	Full
Quality assurance	15; CI gates; section 8 reviews	Partial: CI has not yet run on GitHub

Process	Where	Conformance
Disposal	19 sunset and end of life	Partial: planned

6. Baseline and change control

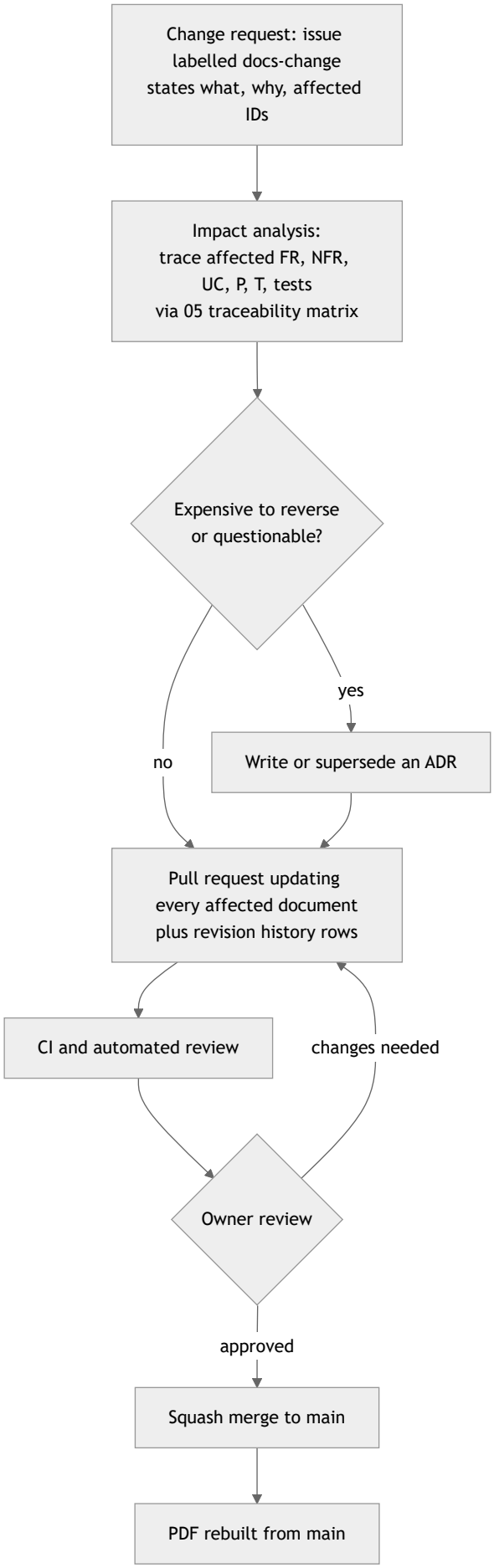
6.1 Versioning

Change	Version bump	Example
Wording, typo, link fix; no meaning changes	Patch note in revision history, version unchanged	1.0 stays 1.0
A requirement, design element, parameter or plan changes within the same phase	Minor	1.0 to 1.1
Re-baseline at a phase gate, or a change to scope or architecture	Major	1.x to 2.0

The whole package is re-baselined at each phase gate (HP-SAD-16), so every document's major version tracks the phase it was baselined for.

6.2 Change request flow (`docs-change`)

There is one change process for this package, named `docs-change` everywhere (issue label, project plan, pull request template).


Change request: issue labelled docs-change states what, why, affected IDs
Impact analysis: trace affected FR, NFR, UC, P, T, tests via 05 traceability matrix
Expensive to reverse or questionable?
yes
no
Write or supersede an ADR
Pull request updating every affected document plus revision history rows
CI and automated review
changes needed
Owner review
approved
Squash merge to main
PDF rebuilt from main

Rules:

1. A change to a requirement updates the traceability matrix in the same pull request, or it doesn't merge.
2. A change to a value or phase listed in section 10 is made in section 10 first; other documents cite the P-ID and are updated in the same pull request.
3. Decisions are never edited away. A new ADR supersedes the old one, and the old one keeps a status note.
4. Every changed document gets a revision history row naming the change and the affected IDs.

6.3 Review and approval

Until Hitchpost has more maintainers, I am the approver, and I approve my own baselines. That is a known weakness. To limit it:

- Any change touching the approval gate, security, or the message contract also gets an independent review recorded in section 8. So far those reviews have been separate Claude Code agents that I ran under my direction, each given the files and not my conclusions.
- Before Phase 6 (production), I will get at least one external human review of 05, 10, 12 and 13 and record it in section 8.

7. Configuration management of the documents

- **Source of truth:** the Markdown files in `docs/sad/` on `main`. Diagrams are Mermaid in the same files, so they version with the text.
- **Derived output:** the bound PDF is built from `main` by `pnpm docs:pdf`; it is never edited by hand. Its cover carries the package version and the git commit it was built from.
- **Identification:** each document carries its ID, version, status and date in its header table and a revision history at the end.
- **Storage and access:** public git repository; history is the audit trail. Tags mark baselines (`sad-v1.0`, then `sad-v1.1` for this remediation).
- **Consistency check, and its limits:** before a baseline I run a script that checks that every referenced item ID (FR, NFR, UC, A, R, T, D, G, BR, QAS, WP, M, DQ, E, ALT) is defined somewhere, every relative link and anchor resolves, and every document has its header and revision history. It does **not** check that a value or phase stated in one document matches another. The 2026-11-09 review found exactly that kind of contradiction (time zones placed in three different phases, different patch windows, different retention wording). Section 10 now holds those values once, and documents cite them by P-ID instead of restating them.

8. Review and sign-off record

All reviews below were run by me. The expert reviews were separate Claude Code agents I set up and directed, each with a defined role, read-only access and no sight of my own conclusions. I checked their key findings against the code or SDK myself before acting on them. No independent human has reviewed the package yet.

Date	Review	Scope	Reviewers	Outcome
2026-11-08	Phase 1 expert audit	Code, CI, docs, product	Five Claude Code agents run in parallel under my direction: QA engineering, application security, software architecture, DevOps, product and portfolio	9 pre-Phase-2 findings, all fixed test-first; docs corrected (report)
2026-11-08	Cross-document consistency check	HP-SAD first draft (12 documents)	Owner, scripted check	No undefined IDs and no broken links in that draft. The script did not check values or phases (see section 7)
2026-11-09	Baseline 1.0 sign-off	HP-SAD-00 to 20	Sanaullah Jannisar, owner (self-approval)	Baselined for Phase 2
2026-11-09	Independent standards assessment	HP-SAD-00 to 20, version 1.0	One Claude Code agent acting as a standards assessor, run under my direction	Overall grade C+: breadth strong, internal contradictions in values, phases, schedule and money, an incomplete traceability matrix, and conformance claims stronger than the evidence. 11 ranked findings
2026-11-09	Independent engineering review	Design documents against code and A2A SDK	One Claude Code agent acting as a staff engineer, run under my direction	15 findings, including two design defects confirmed in the SDK: manual approval cannot use the input-required state, and the agent card has no metadata field for the contract version
2026-11-09	Remediation and re-baseline 1.1	HP-SAD-00 to 20	Sanaullah Jannisar, owner (self-approval)	I decided every contested value and phase once (section 10), corrected the booking protocol, rebuilt the traceability matrix, re-baselined the schedule and budget, and downgraded conformance claims to Partial where the evidence is thin

9. Conventions

Convention	Rule
Document IDs	HP-SAD-NN, two digits, matching the file prefix
Item IDs	Prefix legend in 20 Glossary; IDs are never reused, retired IDs stay listed as retired
Status labels	Built (with code path or test), Phase N, Later
Phases	0 Foundation, 1 Agent line, 2 Approval gate, 3 Directory, 4 Client app, 5 Ratings, 6 Production, Later Evolution
Values	Any number or phase used in more than one document is a P-ID in section 10; documents cite the ID
Voice	First person for my decisions, plain English, no unsourced market claims (date them or mark "to verify")
Diagrams	Mermaid, inline
Personas	Dana (customer), Marcus (barber), Priya (agent developer), Sam (operator)

10. Normative parameters and phase map

This section is the single source for values and phases. Other documents cite these IDs. A change here follows rule 2 in section 6.2.

10.1 Parameter register

ID	Parameter	Value
P-01	Offer hold	10 min from `issuedAt`
P-02	Reserved hold (after `booking_request` accepted, shop on manual approval)	Until the shop decides, max 30 min (P-03)
P-03	Manual approval wait	30 min, then `booking_rejected` with reason `shop_timeout`
P-04	Personal agent booking deadline	35 min (P-03 + 5 min); polls `GetTask` every 10 s, backing off to 60 s
P-05	Availability request deadline	10 s for the whole exchange (Built)
P-06	Max search window	31 days (Built)
P-07	Open holds cap	3 per sender; sender is the client IP until agent authentication (Phase 6), then the agent identity. No per- `contextId` cap: clients choose `contextId`
P-08	Rate limit	60 requests per minute per sender; basic per-IP limit in Phase 2, per-identity in Phase 6
P-09	Clock margin	The personal agent treats an offer as expired 30 s before its local deadline: receivedAt + (expiresAt - issuedAt)
P-10	Cancellation cutoff	None by default; per shop (`cancellationCutoffMinutes`)
P-11	Retention: expired or declined offers	7 days
P-12	Retention: bookings, audit events, interaction records	2 years, then deleted (not anonymised); aggregates are kept without personal fields
P-13	Retention after account deletion	Personal data erased from live systems within 30 days; backup copies expire within P-15 (30 days), so fully gone within 60 days
P-14	Retention: resolved reports	1 year
P-15	Backups	Daily full plus continuous WAL; RPO 5 min for infrastructure loss; backups expire after 30 days; no separate cold-storage export
P-16	Security patching	Critical CVE within 48 hours; high within 7 days; others in the next release
P-17	Support response targets	SEV1 1 h, SEV2 4 business hours, SEV3 next release; community issues triaged within 5 days. Severity definitions: the single SEV table in 19. No SEV1 cover is promised while pilot listings are paused (17)
P-18	Contract version support	Each major version is supported for 6 months after its successor ships
P-19	Text field limit	1 to 200 characters, no control characters (Built)
P-20	Price cap and duration cap	0 to 10,000,000 cents; 1 to 1,440 minutes (Built)

Zero loss and RPO. No confirmed booking is ever lost: the booking write is committed synchronously before `booking_confirmed` is sent, so a crash either leaves no booking and no confirmation, or both. The 5-minute RPO in P-15 applies to everything else (offers, audit tail, directory edits) and to loss of a whole region.

10.2 Phase map

One row per capability that more than one document places in time. If a document disagrees with this table, this table wins and the document is a defect.

Capability	Phase
Typed availability request and offer over A2A; strict validation; whole-exchange deadline	1 (Built)
Offer hold and expiry, `offer_declined`, booking as an A2A Task, approval gate, cancel, reschedule	2
Manual shop approval (Task stays WORKING; client polls `GetTask`)	2
Business-side persistence: SQLite (SDK `DatabaseTaskStore` plus offers, bookings, audit tables); personal-side JSONL audit	2
Basic per-IP rate limit (P-08) and open-holds cap (P-07)	2
Correlation fields (`contextId`, `taskId`, `offerId`, `messageId`) on every audit event	2
Shop configuration (`Book`) validated at load	2

Capability	Phase
Contract version as an `AgentCapabilities.extensions` entry, declared by clients in the `A2A-Extensions` header	2
Server-minted capabilities: `offerId` authorises booking, `bookingToken` authorises cancel and reschedule; `contextId` is for correlation only	2
Directory, listing verification, search	3
Client app, built-in personal agent, calendar write	4
Barber dashboard, including manual approval queue and outcome marking (FR-RATE-04)	4
Ratings from verified interactions; customer "Did it go as booked?" prompt (FR-RATE-05); interaction records attested by matching JCS hashes on both sides	5
Time zones (IANA zone per shop, local slot grid, DST rules; ADR 0018)	6
Agent authentication, signed agent cards, signed interaction records, per-identity rate limits (ADR 0017)	6
Staging environment (WP-6.1) and staging smoke tests	6
One subdomain per hosted business agent	6
Postgres with `slot_claims` exclusion constraint; multi-instance hosting	6
Real booking system over MCP with conditional writes	6
Trace ids, SLO dashboards, alerting	6
First real booking (pilot)	6
Shop-side cancellation pushed to the customer	Later
Payments	Later (not in v1)

Revision history

Version	Date	Change	Author
1.0	2026-11-09	First baseline	S. Jannisar
1.1	2026-11-09	Remediation after independent review: added section 10 (parameter register P-01 to P-20, phase map); conformance downgraded to Partial where evidence is thin; reviews disclosed as Claude Code agents run under my direction; self-approval and planned external review stated; consistency check described with its limits; one change process name (`docs-change`); register no longer duplicates versions	S. Jannisar
1.2	2026-11-09	Second remediation after regrade: P-07 per sender only; P-13 and P-15 reconciled (30-day backups, fully erased within 60 days); phase map adds staging (Phase 6), capability tokens, the extension header, the FR-RATE-04/05 split and signed interaction records (Phase 6); interfaces, interaction and project-planning conformance set to Partial	S. Jannisar

HP-SAD-01 · Vision and scope

Field	Value
Document ID	HP-SAD-01
Version	1.1
Status	Baselined for Phase 2
Date	2026-11-09
Owner	Sanaullah Jannisar, product and engineering lead
Conforms to	ISO/IEC/IEEE 29148:2018 (business requirements: mission, goals, scope); ISO/IEC/IEEE 15288 business or mission analysis

1. Vision statement

Any person's agent can find a local business's agent, ask it a question and get a real offer back. The person then says yes or no, and the booking lands correctly on both sides with a record both can check.

For v1 that means: Dana's agent books Marcus's barbershop over an open protocol. Nothing is committed without Dana's approval, and Marcus's book never double-books.

2. Problem

1. **Agents connect to software, not to each other.** A personal agent that wants to book a haircut has to drive a booking website built for humans, or hand the job back to the person. The barber's systems already know the answer, but nothing lets one agent ask another directly.
2. **Small businesses lose bookings to friction.** A barber cutting hair can't answer the phone. Booking apps help, but each is its own silo with its own app and login.
3. **There is no trusted way to find or judge a business's agent.** Even when a business has an agent, nobody can look it up, check that it's really that business, or see how it has behaved before.

3. Goals

ID	Goal	Measured by
G-1	A person can book a real appointment through their agent with one approval	Approved bookings that were honored (north star)
G-2	A business can list its agent quickly without changing its booking tool	Time from signup to first offer sent, measured on pilot shops: median at most 30 minutes, 90th percentile at most 2 hours
G-3	Agents can only commit a person after an explicit yes	Zero bookings without a logged approval (audit check)
G-4	People can tell a real, well-behaved business agent from a fake or a bad one	Share of bookings made with verified listings; report rate
G-5	Any A2A agent can take part, not only ours	At least one third-party agent completing a booking by Phase 6

4. Non-goals

- **Inventing a protocol.** Agents talk over A2A; tools over MCP (ADR 0003).
- **Replacing booking platforms.** Hitchpost sits beside the barber's existing tool and reads and writes through it.
- **Payments and deposits in v1.** They bring card-data and consumer-protection rules. Later, if bookings work without them.
- **Autonomous booking without approval.** Not a default, ever (ADR 0007). A per-contact opt-in may come later.
- **Free-form chat between language models.** Agents exchange typed messages; a language model may turn a person's words into a request, but never decides what gets booked (ADR 0010).
- **Verticals beyond appointment booking before v1** (ADR 0008).

5. Product principles

1. **The approval gate is the trust floor, not the moat.** Other agent products also ask before acting. What I add is a gate that sits between *two parties*' agents and is logged for both sides.
2. **The moat is the directory plus reputation from verified interactions.** A listing is only worth something if people can find it and trust it, and trust is earned from bookings that really happened.
3. **Other agents are strangers.** Every inbound message is untrusted data, validated and rebuilt before use. Nothing is acted on from free text.
4. **Share the minimum.** My agent shares a free slot, not my calendar. The barber's agent shares an offer, not its book.
5. **Open by default.** MIT code, open protocol, portable listings (ADR 0004).
6. **Prove it narrow before going wide.** One vertical, one neighborhood, real bookings.

6. Success metrics

North star

Weekly human-approved bookings that were honored: bookings approved by the person that reached the outcome Completed, as marked by the shop or confirmed by the customer (FR-RATE-04). No-shows are recorded as NoShow and cancelled bookings as Cancelled; neither counts. Counting only Completed bookings stops the metric from rewarding junk bookings or no-shows.

Counter-metrics (must not get worse while the north star grows)

Metric	Why it matters	Phase
First-offer rejection rate	High means offers don't fit what people asked for	2
Median time to approve	Long means the approval step is a chore	2
Booking errors (double-booked, cancelled by shop, wrong time)	Directly breaks trust on both sides	2
Reports per 100 interactions	Abuse and fake listings	5
Repeat use per person within 60 days	One-off novelty vs a real habit	4

Baseline to measure before Phase 2 ships

Time-to-book today, by phone, website or app, measured on myself and 5 other people for a haircut in the same week. Without this baseline, "faster booking" is not a claim I can make. It's recorded as assumption A-04 in the business case.

7. Scope by phase

Phase	In scope	Out of scope	Status
0. Foundation	Repo, MIT license, CI, review bot config, decision log	Hosting	Built locally; first push pending
1. Agent line	Barber agent with Agent Card and in-memory book; my agent asks and validates offers; strict validation	Booking, approvals, real calendars	Built (`packages/`)
2. Approval gate	Stored offers with expiry, booking request bound to an offer, human yes or no, booking written, audit log on both sides, decline and ask again, cancel and reschedule	Directory, app UI, payments	Phase 2
3. Directory	Business registration, origin verification, search by name, area and service	Ratings, paid placement, signed Agent Cards (Phase 6)	Phase 3
4. Client app	WhatsApp-style app; built-in personal agent as the consumer agent at launch; contacts are agents; approve in the app	Third-party consumer agents as a requirement	Phase 4
5. Ratings	Two-sided reviews only from verified interactions; behavior signals (answered, honored, stayed in scope); reporting	Review moderation at scale	Phase 5
6. Production	Hosting, signed Agent Cards and auth between agents, per-identity rate limits, monitoring, backups, one real booking system over MCP, time zones, 5 to 10 real barbers in one neighborhood	Multiple cities, payments	Phase 6
Later	Language-model front end, more verticals, deposits, per-contact auto-approve, federation of directories		Later

8. v1 release criteria (end of Phase 6)

v1 ships only when all of these hold. The test-based evidence for each is the release exit criteria in 15 §11; criterion 2 is measured in the pilot.

1. **Correctness:** 4 consecutive weeks with zero double-bookings and zero bookings without a logged approval.
2. **Real use:** at least 5 barbers listed and verified in one neighborhood; at least 50 honored (Completed) bookings in the last 4 weeks; at least 30% of people who booked once have booked again.
3. **Security:** no open high or critical findings from a fresh audit; signed agent cards, agent-to-agent auth and per-identity rate limits on; dependency audit clean in CI.
4. **Operations:** monitoring and alerts on the booking path; a restore from backup tested; an incident runbook used at least once in a drill.
5. **Privacy:** published privacy notice; data retention enforced in code; a person can export and delete their data.
6. **Interop:** at least one agent not written by me completes a booking through the directory.

If criterion 2 can't be met after Phase 4, the business case kill criteria apply before more is built.

9. Supersedes and related

Supersedes the product sections of insights.md and the "pieces" table in concept.md. Related: 03 business case, 04 stakeholders and personas, 05 requirements.

Revision history

Version	Date	Change	Author
0.1	2026-11-08	First draft	S. Jannisar
1.0	2026-11-09	Baselined: renumbered into lifecycle order, formal document control, standards conformance	S. Jannisar
1.1	2026-11-09	Remediation after independent review: measurable G-2, north star defined as Completed bookings, signed Agent Cards moved to Phase 6, v1 criteria linked to release exit criteria in 15	S. Jannisar

HP-SAD-02 · Feasibility study

Field	Value
Document ID	HP-SAD-02
Version	1.2
Status	Baselined for Phase 2
Date	2026-11-09
Owner	Sanaullah Jannisar, product and engineering lead
Conforms to	ISO/IEC/IEEE 15288:2023, Business or mission analysis process (problem definition, solution class alternatives, selection); ISO/IEC/IEEE 29148:2018, business requirements context

1. Purpose and scope

This study asks one question before more is built: should Hitchpost go ahead past Phase 1, and in what form? It covers the system request, how booking works today, feasibility on five axes, the alternatives I considered with a weighted scoring, my recommendation, and the conditions that would reverse it.

It uses the goals (G-), assumptions (A-) and risks (R-) defined in 01 Vision and scope and 03 Business case. Every number marked **estimate** is a planning figure, not a measurement. The measurements that replace them are named next to each one.

2. System request summary

Item	Content
Sponsor and owner	Sanaullah Jannisar
Business need	Personal agents can't reach local businesses' systems directly. Small service businesses lose bookings to missed calls and app silos. Nobody can look up or judge a business's agent.
Proposed capability	Business agents reachable over A2A, a human approval gate logged on both sides, a public directory with verification, and reputation from verified interactions (01).
Expected value	Faster booking for people (A-04), fewer lost bookings for shops (A-02), a neutral directory others can build on (G-5).
Constraints	Solo lead with an AI pair; open source (MIT); no payments in v1; one vertical (barbers) and one neighbourhood until the v1 release criteria are met.
State today	Phase 1 built: two agents exchange validated, typed messages over A2A, with 22 passing tests (journey).

3. As-is analysis

3.1 How Dana books today

Dana books a haircut every 3 to 4 weeks, usually late in the cycle (04 Stakeholders and personas).

Step	Channel	Time (estimate)	Pain
Remember she needs a cut	Herself	n/a	Usually remembers when it's already overdue
Find a free slot	Shop's booking app or website	2 to 5 min	One more app and login per shop; slots shown as a grid to scan
If no online booking: call	Phone	1 to 3 min per attempt; often 2 to 3 attempts	Barber can't answer mid-cut; calls go unanswered
Confirm and add to her calendar	By hand	1 min	Easy to forget; no record both sides can check
Total time-to-book		**4 to 15 min (estimate)**	Measured as the A-04 baseline before Phase 2 merges

3.2 How Marcus takes bookings today

Step	Channel	Pain
Online bookings	His booking app	Works, but only for customers who use that app
Phone and walk-in requests	Phone, messages, counter	Missed while cutting. I estimate 3 to 6 missed calls a day for a 2-chair shop (**estimate**, replaced by the A-02 interview answers)
No-shows	None	No reliable reminder or confirmation trail outside the app
Reputation	Public review sites	Reviews say nothing about whether bookings were honored

3.3 Quantified pain (estimates, to be replaced by measurement)

Measure	Estimate	Replaced by
Dana's time-to-book	4 to 15 min	A-04 baseline, 6 people
Marcus's missed calls per day	3 to 6	A-02 interviews, 10 barbers

Measure	Estimate	Replaced by
Share of missed calls that become a lost booking	20 to 40%	A-02 interviews
Marcus's revenue lost per week at $30 per cut	3 to 6 calls × 6 days × 20 to 40% × $30 = $108 to $432	A-02 interviews

The lost-revenue range is wide on purpose. It's the reason A-02 runs before Phase 3, not after.

4. Feasibility assessment

Rating: **High** (no known blocker), **Medium** (a known risk with a mitigation), **Low** (a blocker without a mitigation yet).

4.1 Technical feasibility: High, with one Medium dependency

Question	Finding	Rating
Can two agents find each other and exchange typed messages over an open protocol?	Yes. Built in Phase 1 on the official A2A JS SDK v1.3 (spec v1.0), with end-to-end tests over JSON-RPC.	High
Is A2A mature enough to build on?	v1.0 spec, a v0.3 compatibility layer, three transports. Breaking changes are possible (R-10). Mitigation: contract tests and a supported-version window (13 Interfaces).	High
Can the approval gate be made safe against hostile agents?	Partly proven: strict validation and offer matching are built and tested. The gate itself is Phase 2 design (10 Architecture).	High
Can a business agent read and write the barber's real booking tool?	Unknown. It depends on each tool's API and terms (A-03, R-03). Fallbacks exist: calendar sync, or a Hitchpost-hosted book.	**Medium**
Can one person build and run it?	Within the scope of one neighbourhood, yes. Effort estimate of 716 hours expected, about 859 hours with reserve, discovery included (16 Project plan).	Medium

4.2 Economic feasibility: Medium

A 3-year cash view under stated assumptions. Year 1 runs November 2026 to October 2027; Year 2 November 2027 to October 2028; Year 3 November 2028 to October 2029. The v1 decision (M-08) falls in Year 2 (16 Project plan).

Assumptions (all estimates):

- **Pricing:** the single hypothesis in 03 Business case section 2: $1 per honored booking, capped at $39 per shop per month, first 3 months free for each shop.
- **Volume:** a paying shop gets 25 honored Hitchpost bookings a month in Year 2 and 35 in Year 3, so it pays $25 and then $35 a month (under the cap).
- **Shops, as a scenario, not a forecast:** the pilot neighbourhood (10 shops) goes live on 2027-10-19 and pays from February 2028. If the 12-week expansion rule in 03 section 5 passes, a second neighbourhood (15 shops) starts in June 2028 and pays from September 2028, and a third (15 shops) starts in December 2028 and pays from March 2029. 80% of shops convert to paying after the free months. That gives 96 paying shop-months in Year 2 ((10 × 9 + 15 × 2) × 80%) and 336 in Year 3 ((10 × 12 + 15 × 12 + 15 × 8) × 80%). If an expansion step fails its rule, the later rows don't happen.
- No churn modelled. No payments income. Owner time excluded (see below).

	Year 1	Year 2	Year 3
AI pair and tools	$1,200	$1,200	$2,000
Domain	$20	$20	$20
Hosting (staging and production from Phase 6, July 2027)	$240	$1,500	$4,800
Research incentives (Wizard-of-Oz, interviews)	$700	$0	$0
Legal review (privacy notice, terms)	$1,500	$0	$0
Moderation and misc.	$0	$300	$1,000
Cash cost	**$3,660**	**$3,020**	**$7,820**
Revenue	**$0**	**$2,400**	**$11,760**
Net	**−$3,660**	**−$620**	**+$3,940**
Cumulative	**−$3,660**	**−$4,280**	**−$340**

No-expansion scenario (only the pilot neighbourhood ever pays; Year 3 costs cut to the Year 2 level of $3,020 because there is nothing to scale):

	Year 1	Year 2	Year 3
Revenue	$0	$1,800 (72 shop-months × $25)	$3,360 (96 shop-months × $35)
Net	−$3,660	−$1,220	+$340
Cumulative	**−$3,660**	**−$4,880**	**−$4,540**

If Year 3 costs were not cut, the no-expansion cumulative would be about −$9,340; cutting them is part of the stop rule.

Reconciliation with the project budget. The spend to the v1 decision (November 2026 to February 2028) is Year 1 ($3,660) plus November 2027 to February 2028 from Year 2 ($400 tools, $20 domain, $240 hosting = $660): **$4,320 before contingency, $5,184 with 20% contingency**. That is the same figure as 16 Project plan section 7.2.

Net present value at a 10% discount rate, end-of-year cash flows: −$3,660 / 1.10 − $620 / 1.21 + $3,940 / 1.331 = −$3,327 − $512 + $2,960 = **NPV ≈ −$880** (**estimate**). The no-expansion scenario gives −$3,327 − $1,008 + $255 = **NPV ≈ −$4,080**. In cash terms the project comes close to breaking even over three years only if both expansion steps succeed, and loses about $4,500 if none do.

- **Run-rate break-even:** Year 3 monthly cost is about $650; at $35 per paying shop that's about **19 paying shops**.
- **My time is not in the table.** About 716 hours to v1 at an opportunity cost of $60 an hour is about $43,000 (**estimate**). It isn't recovered in 3 years at this scale; with it included the NPV is strongly negative.

Conclusion: the cash risk is small and bounded, about $5,200 before any revenue (budget with contingency). The economic case at this scale rests on what I learn, the portfolio value and the option to expand. It does not rest on near-term profit, and the NPV says so plainly. That's acceptable as long as the kill criteria in section 7 are honored.

4.3 Operational feasibility: Medium

Question	Finding	Rating
Will barbers act on bookings that arrive this way?	Unproven (A-02). Standing approval by default means Marcus doesn't have to do anything per booking (FR-GATE-05).	Medium
Will people approve offers instead of using an app or calling?	Unproven (A-01). Tested by an 8-week Wizard-of-Oz before Phase 2 build beyond protocol-safe work.	Medium
Can one person handle onboarding, support and moderation?	Yes, at 5 to 10 shops: under 15 minutes onboarding per shop, support by message during hypercare (17 Transition plan). Not beyond one neighbourhood without help (R-11).	Medium
Does it fit how shops already work?	Hitchpost sits beside the existing booking tool rather than replacing it, which is a non-goal in 01.	High

4.4 Schedule feasibility: Medium

The expected effort is 716 hours (P80 about 733, P95 about 750) from the three-point estimates, discovery work included, or about 859 hours with a 20% reserve. All of it is done by one person at 15 hours a week (**estimate** of sustainable solo capacity), so discovery and build share the same hours. On that resource-loaded plan the pilot goes live on **2027-10-19** and the v1 decision lands on **2028-02-08**, or as late as **2028-04-18** if the full reserve is used before the pilot (16 Project plan). The schedule is sensitive to two things: the booking-system connector (WP-6.5) and how fast barbers can be recruited for the pilot.

4.5 Legal and regulatory feasibility: High for v1, Medium later

This section is not legal advice. It lists what has to be checked, and when.

Area	Position for v1	Rating
Personal data (GDPR / UK GDPR / CCPA)	Minimal data: name, contact, booking times. Data minimisation (NFR-PRIV-01), retention and deletion (NFR-PRIV-02). A privacy notice is required before the pilot (12 Security and privacy).	High
Booking platform terms	Automation may be restricted (R-03). Checked in the A-03 desk audit before Phase 3 starts.	Medium
Payments and card data	Out of scope for v1, so no PCI DSS exposure (R-09).	High
Consumer protection and liability for wrong bookings	Mitigated by the approval and audit log on both sides, plus clear terms reviewed by a lawyer before the pilot (R-07).	High
Name and trademark	"Hitchpost" is a working codename (ADR 0006). A trademark search is needed before public launch.	Medium
Open-source licence	MIT, with dependency licences checked in CI from Phase 6.	High

5. Alternatives analysis

5.1 Alternatives

ID	Alternative	Summary
ALT-A	Do nothing	Stop after Phase 1. Keep the code as a reference.
ALT-B	Plugin for one booking platform	Build an A2A endpoint for one platform's shops only (for example Square Appointments, subject to its API and terms).
ALT-C	Own directory on A2A (proposed)	A neutral, cross-platform directory of business agents, with the approval gate, verification and reputation. Connectors to booking tools come in Phase 6.
ALT-D	Consumer-only assistant	A personal agent that drives businesses' existing websites and apps for the person. No business side, no directory.

5.2 Criteria and weights

Criterion	Weight	What a 5 means
Fit to goals G-1 to G-5	25	Meets all five goals
Defensibility	20	Hard to copy, with an asset that compounds (directory, reputation)
Time to first value	15	Real bookings within weeks
Cost and effort	15	Lowest build and run cost
Dependency risk	15	No single outside party can switch it off

Criterion	Weight	What a 5 means
Learning and portfolio value	10	Tests the riskiest assumptions; shows end-to-end system design

5.3 Weighted scoring (scores 1 to 5)

Criterion (weight)	ALT-A	ALT-B	ALT-C	ALT-D
Fit to goals (25)	1	3	5	2
Defensibility (20)	1	2	4	1
Time to first value (15)	1	4	2	4
Cost and effort (15)	5	4	2	3
Dependency risk (15)	5	1	3	2
Learning and portfolio (10)	1	3	5	3
Weighted score (of 5)	**2.20**	**2.80**	**3.60**	**2.35**

Score notes:

- **ALT-B** scores 1 on dependency risk because one platform's API terms decide whether it exists (R-02, R-03). It scores 3 on fit because it fails G-5 (any agent) and G-4 (neutral trust).
- **ALT-D** scores 1 on defensibility because general assistants already drive websites (R-02 and section 1 of 03). Driving human-facing websites is also brittle and may break their terms.
- **ALT-C** scores 2 on time and on cost, because it needs a directory and a business side. That's the price of the only option that meets all five goals.

5.4 Sensitivity

ALT-C leads ALT-B by 0.80. The single 10-point weight shift that hurts ALT-C most moves weight from fit to time to first value. Even then ALT-C still leads by 0.40. It would take two such shifts at once, for example fit to time and learning to cost, to bring the two level. I accept that: it only happens if I stop caring about the goals in 01.

6. Recommendation

Proceed with ALT-C, using ALT-B's integration as the Phase 6 connector for whichever booking tool the A-03 audit favors, not as the product. The work is staged so that the riskiest assumptions are tested before the money and time that depend on them are spent:

Before	Test	Assumptions
Phase 2 build beyond protocol-safe work (M-01)	8-week Wizard-of-Oz with about 15 people; time-to-book baseline	A-01, A-04
Phase 3 starts (M-02)	10 barber interviews; booking-tool API desk audit; verified competitor scan	A-02, A-03, A-07
Phase 3 starts (M-02)	Defensibility and price check, in the same interviews and scan	A-05
Phase 4 starts	Whether people care which assistant they use (from the A-01 data)	A-08

7. Conditions that would reverse this recommendation

I'd stop or change course if any of these happen. Each maps to a kill criterion in 03 Business case section 3.

Condition	Response
A-01 fails: under 60% complete one booking, under 30% complete two, or under 50% first-offer approval, over 8 weeks	Stop Phase 2 build at M-01. Keep Phase 1 and the protocol-safe work as a reference (ALT-A).
A-02 fails: fewer than 3 of 10 barbers would list for free	Pivot to another vertical where the business side is more eager, or to ALT-D for learning only.
A-03 fails: none of the top 3 tools allows writes	Keep ALT-C, with a Hitchpost-hosted book or calendar sync. Re-estimate WP-6.5.
A-05 or A-07 fails: a platform already offers cross-platform agent booking with reputation	Partner with it or contribute to it. Don't build a competing directory.
Real time per week drops below 8 hours for more than a month	Re-baseline the schedule in 16 Project plan, or cut Phase 5 to after v1.

Revision history

Version	Date	Change	Author
1.0	2026-11-09	First baseline	S. Jannisar
1.1	2026-11-09	Remediation after independent review: one pricing hypothesis ($1 per honored booking, $39 cap, 3 months free); 3-year table rebuilt with a stated shop scenario, NPV at 10% and reconciliation to the 16 budget ($4,140, $4,968 with contingency); schedule and effort from the resource-loaded plan; A-01 redesigned to 8 weeks with the new pass rule	S. Jannisar
1.2	2026-11-09	Second remediation after regrade: economics recomputed for the re-baselined plan (pilot live 2027-10-19, paying from February 2028; expansions a month later); staging hosting only from Phase 6; explicit no-expansion scenario (cumulative −$4,540, NPV ≈ −$4,080); scenario NPV ≈ −$880; budget reconciled at $4,320 ($5,184 with contingency); effort 716 h	S. Jannisar

HP-SAD-03 · Business case

Field	Value
Document ID	HP-SAD-03
Version	1.1
Status	Baselined for Phase 2
Date	2026-11-09
Owner	Sanaullah Jannisar, product and engineering lead
Conforms to	ISO/IEC/IEEE 29148:2018 (business requirements: business environment, model, risks); ISO/IEC/IEEE 15288 business or mission analysis

The case for building Hitchpost, what has to be true for it to work, and how I'll find out cheaply before building too far.

1. Market and competition

Every claim below is marked **to verify (2026-11-08)** until I've checked it against a primary source and added a link. I won't cite any of them outside this repo until they're verified.

Protocols (the layer I build on, not compete with)

Player	What it does	Relevance	Check
A2A (Agent2Agent), Linux Foundation project, JS SDK v1.3 implementing spec v1.0	Agent-to-agent messaging; Agent Cards at a well-known URL; card signatures in the spec	My wire protocol. SDK version confirmed in this repo's lockfile.	Partly verified (SDK); governance to verify
MCP (Model Context Protocol)	Agent-to-tool connections	How agents will reach booking systems (Phase 6)	To verify (2026-11-08)

Registries and directories (closest to my directory)

Player	What it is	Gap I see	Check
Official MCP Registry	Registry of MCP servers (tools), aimed at developers	Lists tools, not businesses; no reputation	To verify (2026-11-08)
AGNTCY Agent Directory	Open agent directory effort	Developer infrastructure, not a consumer phone book for local businesses	To verify (2026-11-08)
MIT NANDA index	Research index of agents	Research, not consumer-facing	To verify (2026-11-08)
Vendor agent marketplaces (e.g. Google Cloud agent marketplace, Salesforce AgentExchange)	Enterprise agent catalogs	Enterprise buyers, not local services	To verify (2026-11-08)

Agent commerce and approval

Player	What it is	Overlap	Check
AP2 (Agent Payments Protocol), "mandates"	Proof that a user authorized an agent purchase	Overlaps my approval gate for payments	To verify (2026-11-08)
ACP (Agentic Commerce Protocol, OpenAI and Stripe)	Checkout initiated by agents	Overlaps if I add payments	To verify (2026-11-08)
Consumer agents (ChatGPT agent, Gemini)	Book and buy on the user's behalf, with confirmation	Already ask before acting, so the gate alone is not unique	To verify (2026-11-08)

Booking platforms (the real competition for barbers)

Player	Position	Threat	Check
Booksy, Square Appointments, Fresha, Vagaro, Squire, Acuity	Own the barber's calendar, consumer app and reviews	Could ship an A2A endpoint themselves, inside their own silo	To verify (2026-11-08)
Google (Reserve with Google, "Ask for me", Duplex)	Books local businesses from Search and Maps; can call businesses	Distribution I can't match	To verify (2026-11-08)

What's left open

Nobody I've found so far offers all three of these for small local businesses: a neutral, cross-platform directory of business agents; reputation built from verified agent interactions; and an approval record both sides can check. That's my position, and it stays a hypothesis until the scan is verified (A-07).

2. Business model

Options

Option	Who pays	For what	Pros	Cons
A. Business subscription	Barber	Verified listing, agent hosting, booking sync	Predictable; matches how barbers already pay booking tools	Hard sell before there's demand
B. Per-booking fee	Barber	Each honored booking	Pays only for results; easy first yes	Revenue tied to slow early volume
C. Consumer subscription	Person	Personal agent and app	Clear value if the app is great	Consumer subscriptions are hard; competes with general assistants
D. Open core plus hosted service	Businesses and developers	Hosted directory, verification, SLA	Fits MIT and open protocol	Needs scale to matter

My choice for v1: B, a per-booking fee with a monthly cap, so a shop pays only for results and never more than a small, predictable amount. A (subscription) is not offered in v1; I revisit it only if the cap is hit by most paying shops. D is the long-term shape. C is off the table for v1, because the built-in personal agent is how I solve cold start, not a product to charge for.

Price hypothesis (to test, not to announce)

One hypothesis, used everywhere in this package, including the revenue model in 02 Feasibility study:

- **$1 per honored booking**, where honored means the booking reached Completed (the customer showed up).
- **Capped at $39 per shop per month.**
- **First 3 months free** for every shop, including the pilot shops.
- **Anchor:** barbers already pay booking platforms roughly $30 to $100+ per month (to verify, 2026-11-08). At 25 to 35 honored bookings a month a shop pays $25 to $35, below that anchor, because Hitchpost adds to their stack rather than replacing it.
- **Tested in** the A-02 interviews (would you pay this?) and A-05 (does any barber accept any price?).

Cost drivers

Driver	Phase	Notes
Hosting (directory, hosted business agents, database)	6	Small at one neighborhood; scales with listings and messages
Verification (phone or SMS checks, domain checks)	3	Per-listing cost
Language-model calls	Later	Only on the person's side, to turn words into a request; never per agent-to-agent message
Booking platform API access	6	Unknown; some platforms may charge or restrict (A-03)
Moderation time	5	Mine at first; the biggest hidden cost if abuse grows

3. Assumptions and how I'll test them

Each assumption gets the cheapest test that could prove it wrong, and a kill or pivot criterion decided **before** the test runs.

ID	Assumption	Cheapest test	Kill or pivot if	Before
A-01	People will book through an agent and approve offers, instead of tapping a booking app or calling	Wizard-of-Oz for **8 weeks** over WhatsApp with about 15 people: I act as their agent and as the barber's. Eight weeks covers at least two booking cycles for someone who books every 3 to 4 weeks (04)	Fewer than 60% complete one booking through the agent, fewer than 30% complete two, or first-offer approval under 50%	M-01, before Phase 2 build beyond protocol-safe work
A-02	Barbers will list their shop and act on bookings that arrive this way	Interview 10 local barbers: tool, pains, would they list, would they pay	Fewer than 3 of 10 would list for free	Phase 3 starts
A-03	Barbers' booking tools allow programmatic reads and writes	Desk audit of public APIs and terms for the tools barbers named in A-02	None of the top 3 tools allows writes. Pivot: Hitchpost hosts the calendar, or use calendar sync	Phase 3 starts
A-04	Agent booking is faster for the person than today	Time-to-book baseline on me plus 5 people, then the same with the Wizard-of-Oz flow	Not at least 50% faster end to end	M-01
A-05	A neutral directory is defensible and someone will pay for it	Verified competitor scan, plus the price question (section 2) in the A-02 interviews	A booking platform already offers cross-platform agent booking, or no barber accepts any price	M-02, before Phase 3 starts
A-06	People trust reviews from verified interactions more than ordinary reviews	5 short interviews showing two listing mockups	No preference	Phase 5 starts
A-07	Nobody offers directory, verified reputation and a two-sided approval record for local businesses	Verify every row in section 1 with primary sources and dates	A live product covers all three	Phase 3 starts
A-08	The built-in personal agent is enough on the consumer side at launch, without third-party assistants	Measure in the A-01 test whether people care which assistant they use	Most people refuse a new app	Phase 4 starts

The three riskiest are **A-01**, **A-02 with A-03**, and **A-05**: the audit's three. None of them needs code to test.

4. Risks

Likelihood and impact on a 1 to 3 scale. Owner is me unless noted.

ID	Risk	L	I	Mitigation
R-01	People don't adopt agent booking (A-01 fails)	2	3	8-week test before Phase 2 build beyond protocol-safe work (M-01); kill criteria above
R-02	Booking platforms ship their own agent endpoints and keep it inside their silo	3	3	Be neutral and cross-platform; portable listings; partner rather than fight
R-03	Booking tools block API access or forbid automation in their terms	2	3	A-03 desk audit; fallback to calendar sync or a Hitchpost-hosted calendar
R-04	Prompt injection or hostile agents trick an agent into acting	2	3	Typed messages, strict validation, approval gate, no actions from free text (12 security)
R-05	Fake or impersonated business agents	2	3	Verified listings, signed Agent Cards, reporting (UC-09)
R-06	Spam and hold exhaustion: agents messaging at machine speed or locking chairs with offers they never take	3	2	Open-holds cap (P-07) and per-IP rate limit (P-08) from Phase 2; per-identity limits and sender reputation from Phase 6
R-07	Liability for wrong bookings	2	2	Approval and audit log on both sides; clear terms
R-08	Privacy breach of calendar or contact data	1	3	Share minimum; retention limits; export and delete
R-09	Regulation once deposits or payments appear (card data, consumer protection)	2	2	No payments in v1; use a payment provider and AP2 or ACP later
R-10	A2A changes in breaking ways	2	2	Track the spec; SDK compatibility layer; contract tests
R-11	Solo maintainer bandwidth (moderation, support, ops)	3	2	One neighborhood; automate checks; recruit contributors through open source
R-12	Cold start: empty directory and no consumer agents speaking A2A	3	3	Built-in personal agent (A-08), seeded neighborhood, nearly free listing

5. Go-to-market: one neighborhood

1. **Pick one area** with at least 15 barbershops within walking distance, where I can visit in person.
2. **Recruit from the A-02 interviews.** I offer free listing and setup for the first 10 shops, done by me in under 15 minutes per shop.
3. **Seed demand** with the A-01 participants, then their friends. Target 50 people who've booked at least once.
4. **Show it working in the shop:** a QR code at the counter saying "Book next time by message", which opens the client app.
5. **Measure weekly:** north star, counter-metrics, listing time, reports.
6. **Decide at 12 weeks:** expand to the next neighborhood, change the vertical, or stop. The criteria are the kill rules in section 3 and the v1 release criteria in 01. Each further neighbourhood gets the same 12-week rule; the shop counts in 02 section 4.2 assume two such expansions and drop out if a step fails.

Supersedes and related

Supersedes sections 1, 3, 4, 6 and 9 of insights.md. Related: 01 vision and scope, 04 stakeholders and personas, Phase 1 audit.

Revision history

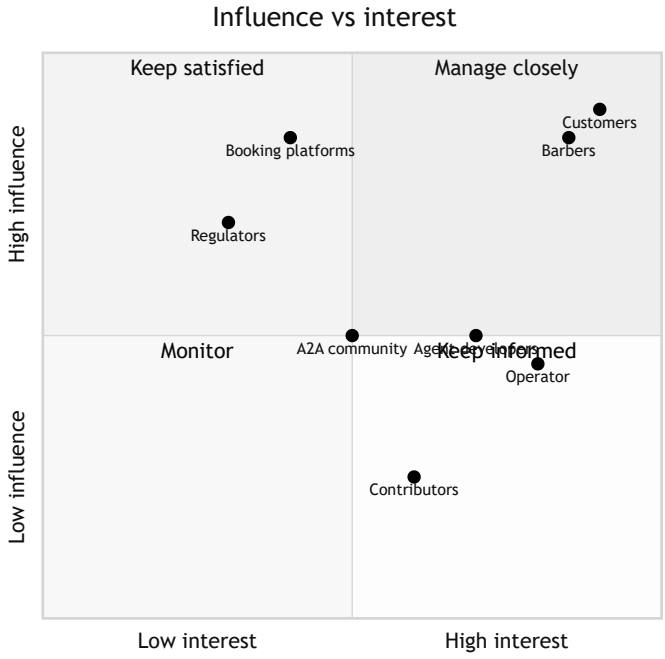
Version	Date	Change	Author
0.1	2026-11-08	First draft	S. Jannisar
1.0	2026-11-09	Baselined: renumbered into lifecycle order, formal document control, standards conformance	S. Jannisar
1.1	2026-11-09	Remediation after independent review: one pricing hypothesis ($1 per honored booking, $39 cap, 3 months free), model B chosen for v1; A-01 redesigned to 8 weeks with a one-booking and two-booking pass rule; A-05 moved to M-02; R-06 covers hold exhaustion with P-07 and P-08; expansion rule tied to the 02 scenario	S. Jannisar

HP-SAD-04 · Stakeholders and personas

Field	Value
Document ID	HP-SAD-04
Version	1.1
Status	Baselined for Phase 2
Date	2026-11-09
Owner	Sanaullah Jannisar, product and engineering lead
Conforms to	ISO/IEC/IEEE 29148:2018 (stakeholder requirements: stakeholders, user profiles, operational concept); ISO/IEC/IEEE 42010 stakeholders and concerns

1. Stakeholder map

Stakeholder	Interest	Influence	How I engage
Customers (Dana)	Book fast, no surprises, privacy	High: adoption decides everything	8-week Wizard-of-Oz test (A-01), app feedback, ratings
Barbers and shop owners (Marcus)	More bookings, fewer missed calls, no double-booking, low effort	High: supply side	Interviews (A-02), in-person setup, weekly check-ins
Agent developers (Priya)	Get their agent listed, trusted and used	Medium: interop and growth	Open docs, open source, Agent Card spec, contract tests
Directory operator and moderator (Sam)	Keep listings real and abuse low	Medium	Admin tools (Phase 6), runbooks
Booking platforms (Booksy, Square, Fresha and others)	Keep customers in their ecosystem; API terms	High: they control calendar access	Read API terms (A-03), approach as partners, never scrape
A2A and MCP communities	Protocol adoption and correct use	Medium: protocol direction	Follow the spec, report issues, contribute fixes
Regulators (privacy, consumer protection)	Lawful data handling; fair practices	High if payments come	Privacy by design, no payments in v1, legal review before Phase 6
Contributors	Interesting, well-run open-source project	Low to medium	CONTRIBUTING, good first issues, fast reviews
Hiring managers and peers	Evidence of how I lead a build	Low on product, high for me	Journey, ADRs, audits, honest bug log



2. Responsibilities (RACI-lite)

R = does the work, A = owns the decision, C = consulted, I = informed. "Me" is the maintainer, who is also Sam until there's a separate operator.

Activity	Me	Barbers	Customers	Contributors	Platforms
Product direction and scope	A, R	C	C	I	I
Architecture and ADRs	A, R			C	

Activity	Me	Barbers	Customers	Contributors	Platforms
Code changes and review	A			R	
Listing and verification	A, R	R (provide details)			C (API)
Approving bookings		A for the shop's time (Phase 2 decision)	A for their own time		
Moderation and reports	A, R	C	R (report)		
Security response	A, R	I	I	C	I
Releases and operations	A, R	I	I	C	

One open decision for Phase 2: does Marcus approve each booking, or do opening hours count as his standing approval? My working answer is standing approval by default, with a per-shop switch for manual approval. It gets confirmed in the A-02 interviews.

3. Personas

Dana, customer

- **Context:** 34, works hybrid, books a haircut every 3 to 4 weeks, usually remembers late. Has an assistant app on her phone. Because she books only every 3 to 4 weeks, the A-01 test in 03 runs 8 weeks: long enough to see two of her bookings.
- **Goals:** get a slot that fits after work without calling; know it's really booked.
- **Pains:** phone calls during work hours; every shop uses a different app; booking forms on a phone; finding out the slot was gone.
- **What she needs from Hitchpost:** one message, one clear offer, one tap to approve, confirmation she can trust.
- **What would make her leave:** a wrong booking, or approvals that feel like more work than calling.

Marcus, barber and shop owner

- **Context:** 41, owns a 2-chair shop, cuts all day, uses a booking app his customers mostly ignore. Phone rings while he's cutting.
- **Goals:** a full book, fewer no-shows, no double-bookings, no extra admin.
- **Pains:** missed calls equal missed bookings; booking-app fees; customers who don't show.
- **What he needs:** listing in minutes, bookings landing in the tool he already uses, nothing to watch during the day.
- **What would make him leave:** one double-booking, or having to manage yet another inbox.

Priya, agent developer

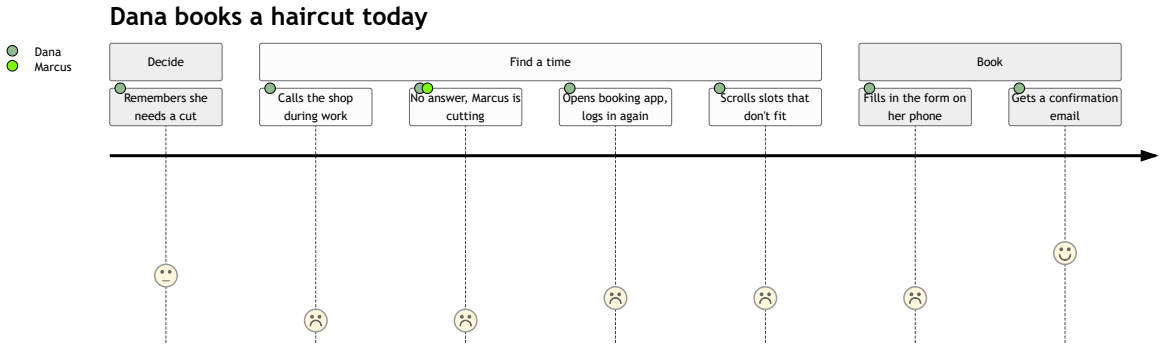
- **Context:** 29, builds agents for small businesses as a freelancer. Knows A2A.
- **Goals:** list her clients' agents, have them found and trusted, prove they behave.
- **Pains:** no directory where local-business agents get discovered; no way to show her agent is reliable.
- **What she needs:** a clear message contract, a test harness, a simple registration and verification flow, and visible reputation.

Sam, operator and moderator

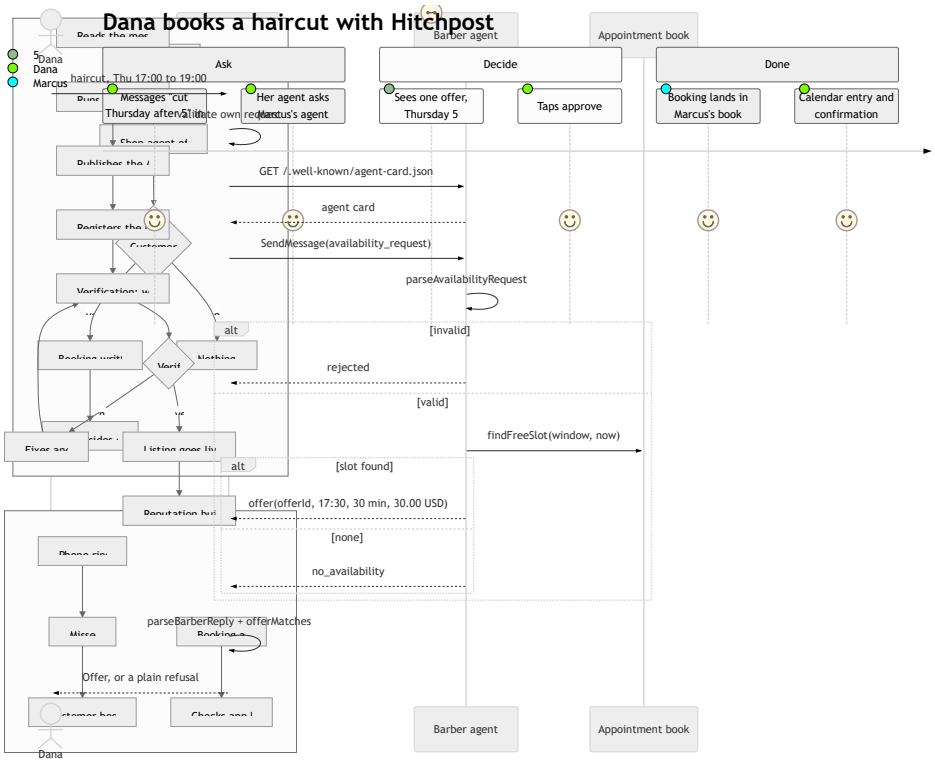
- **Context:** the maintainer at launch; later a part-time role.
- **Goals:** real listings only, fast response to reports, quiet on-call.
- **Pains:** fake listings, spam agents, unclear evidence when handling disputes.
- **What Sam needs:** an admin view of listings and reports, audit logs from both sides of a dispute, rate-limit and block controls.

4. Journeys

Dana: today



Dana: with Hitchpost (Phase 4)



Marcus: today vs with Hitchpost

Priya: onboarding a client's agent (Phase 3)

5. Supersedes and related

Supersedes "Who it is for" in concept.md. Related: 01 vision and scope, 03 business case, 06 use cases.

Revision history

Version	Date	Change	Author
0.1	2026-11-08	First draft	S. Jannisar
1.0	2026-11-09	Baselined: renumbered into lifecycle order, formal document control, standards conformance	S. Jannisar
1.1	2026-11-09	Remediation after independent review: A-01 test length (8 weeks) tied to Dana's booking frequency; Priya's verification step matches FR-DIR-01	S. Jannisar

HP-SAD-05 · Requirements specification

Field	Value
Document ID	HP-SAD-05
Version	1.2
Status	Baselined for Phase 2
Date	2026-11-09
Owner	Sanaullah Jannisar, product and engineering lead
Conforms to	ISO/IEC/IEEE 29148:2018 (system and software requirements specification); ISO/IEC 25010 quality characteristics

What Hitchpost must do and how well, from what exists today (Phase 1 plus the audit fixes) through production. Each requirement has an ID, a phase, a status and a source, and traces to a use case, a design section, a verification method and a test case.

1. Purpose and scope

In scope: agent-to-agent appointment booking for one vertical (barbers, ADR 0008): asking for availability, a human approval gate, booking and changing bookings, a public directory of business agents, a client app with agents as contacts, and ratings from verified interactions.

Out of scope until Later: payments and deposits, verticals other than appointment booking, a natural-language front end, federation between directories, and shop-side cancellation of a confirmed booking over the protocol (in v1 the shop contacts the customer out of band). See 01. Vision and scope.

Values. Numeric values (holds, timeouts, limits, retention) are not restated here as free numbers. Each is a normative parameter `P-nn` defined once in the parameter register of 00 Document control. Where a value appears in this document it is followed by its P-ID, and the register wins if they ever differ.

2. Definitions

Term	Meaning
Agent	Software that acts for one party (a person or a business) and speaks A2A.
Agent card	The A2A document at `/.well-known/agent-card.json` that says who an agent is and how to reach it.
Offer	A barber agent's proposal of one slot: service, start, duration, price, currency, `offerId`, `issuedAt`, `expiresAt`.
Hold	The slot an unexpired offer keeps out of other offers (P-01).
Reserved	The state of an offer once a `booking_request` for it has been accepted while the shop decides (P-02).
Approval	A person's explicit yes to one specific offer.
Commitment	Any action that spends a person's money, books their time or shares their personal data.
Verified interaction	An interaction with a logged offer and a matching logged decision on both sides, ending in a booking that reached Completed or NoShow.
Honored booking	A booking that reached Completed. The north star counts these.
Inbound data	Anything received from another agent. Always untrusted.
Verification method	**T** test, **A** analysis, **I** inspection, **D** demonstration (ISO/IEC/IEEE 29148 §6.5).

3. Constraints and assumptions

Constraints

- Agent-to-agent messaging uses A2A v1.0 through the official SDK (ADR 0003).
- TypeScript on Node 24, one monorepo (ADR 0002).
- Messages between agents are typed data parts, not free text (ADR 0010).
- MIT licensed, built in the open (ADR 0004).
- No payments or deposits in v1 (R-09 in 03).
- Times on the wire are UTC. Before Phase 6 the book is UTC only and every booking is a demonstration; no real customer booking happens before Phase 6, when per-business IANA time zones arrive (FR-BOOK-05, ADR 0018).
- The contract version is declared once, as an `AgentCapabilities.extensions` entry on the agent card (uri `https://hitchpost.dev/ext/contract/v1`, `required: true`), and messages list that uri in their `extensions`. The A2A `AgentCard` has no metadata field to carry it (13).
- The A2A SDK stops draining a task's events at `INPUT_REQUIRED` (`@a2a-js/sdk` 1.3 `server/index.js`), and A2A defines that state as "the caller must reply". It is therefore never used to wait for a shop owner (FR-GATE-05).

Assumptions: the business assumptions this specification rests on are tracked with their tests in 03. Business case. If one fails, the requirements that depend on it are revisited, not built anyway.

Assumption	Requirements that depend on it
A-01 people will approve agent offers	FR-GATE-01 to FR-GATE-05, FR-BOOK-01 to FR-BOOK-11
A-02, A-03 barbers list; their tools allow reads and writes	FR-DIR-01, FR-BOOK-06

Assumption	Requirements that depend on it
A-04 agent booking is faster	NFR-PERF-01, the whole Phase 2 flow
A-06 verified reviews are trusted more	FR-RATE-01 to FR-RATE-05, FR-DIR-05
A-08 the built-in personal agent is enough at launch	FR-APP-03

4. Functional requirements

Status is **Built** (with where it lives and the test case that proves it), **Phase N** or **Later**. Sources: **NB** = notebook sketch, **ADR** = decision record, **Audit** = Phase 1 audit, **Review** = the two independent reviews of this package on 2026-11-09 (run as separate Claude Code agents under my direction).

4.1 Agent messaging (MSG)

ID	Requirement	Phase	Status	Source
FR-MSG-01	A business agent must publish an A2A agent card describing its name, interface URL and skills.	1	**Built.** `barberCard` in `packages/barber-agent/src/server.ts`; exercised through card discovery by TC-17 to TC-22.	NB, ADR 0003
FR-MSG-02	A business agent must answer an `availability_request` with exactly one of `offer`, `no_availability` or `rejected`.	1	**Built.** `BarberExecutor.reply` in `packages/barber-agent/src/executor.ts`. TC-17, TC-18, TC-20.	NB
FR-MSG-03	Every agent must validate inbound agent data against a strict schema and rebuild it from known fields, dropping unknown fields.	1	**Built.** `parseAvailabilityRequest`, `parseBarberReply` in `packages/core/src/booking.ts`. TC-12 to TC-15.	ADR 0007, Audit
FR-MSG-04	A requesting agent must reject an offer that does not match its request (same service, start inside the requested window).	1	**Built.** `offerMatches` in `packages/core/src/booking.ts`, used by `askForSlot` in `packages/my-agent/src/ask.ts`. TC-16, TC-21.	Audit
FR-MSG-05	A requesting agent must bound the whole availability exchange (card discovery and message) by one deadline (P-05) and refuse redirects.	1	**Built.** `askForSlot` deadline and `redirect: "error"`. TC-22.	Audit
FR-MSG-06	Times must be strict ISO 8601 with an explicit zone, rejected if the day, hour, minute or offset doesn't exist, and stored as canonical UTC.	1	**Built.** `toInstant` in `packages/core/src/booking.ts`. TC-11, TC-13.	Audit, Review
FR-MSG-07	An availability window must be positive and at most P-06 long.	1	**Built.** `MAX_WINDOW_DAYS` in `packages/core/src/booking.ts`. TC-13.	Audit
FR-MSG-08	A requesting agent must not send a request it cannot validate itself.	1	**Built.** `askForSlot` validates before sending. TC-19.	Audit
FR-MSG-09	Every agent card must declare the Hitchpost contract as an `AgentCapabilities.extensions` entry (uri `https://hitchpost.dev/ext/contract/v1`, `required: true`); a client must declare that uri in the `A2A-Extensions` request header (the SDK checks required extensions against the header, not the message body) and should also list it in the message `extensions`; an agent must answer an unknown `kind` with `rejected`. Only major versions exist; additive changes keep the version.	2	Phase 2	13, Review
FR-MSG-10	Questions (availability) must use A2A Messages; commitments (book, cancel, reschedule) must use A2A Tasks so each has a durable id.	2	Phase 2. Availability already uses a Message reply (`executor.ts`).	13
FR-MSG-11	From Phase 2, both agents must record `contextId`, `taskId`, `offerId` and `messageId` on every audit event, so one booking can be followed across both logs.	2	Phase 2	Review
FR-MSG-12	A `booking_request`, `offer_declined`, `cancel_request` or `reschedule_request` is authorised by a server-minted capability, never by `contextId`: `offerId` (random UUID) authorises booking and declining that offer, and the `bookingToken` (128-bit random, returned in `booking_confirmed`) authorises cancelling and rescheduling that booking. A request without the matching capability is rejected. `contextId` is kept for correlation only, because the client chooses it. Capabilities are logged hashed, and never shown in a user interface or put in a URL.	2	Phase 2	Review

4.2 Booking lifecycle (BOOK)

ID	Requirement	Phase	Status	Source
FR-BOOK-01	A barber agent must store every offer it issues (`offerId`, `contextId`, service, start, price, `issuedAt`, `expiresAt`) and hold its slot until the offer expires (P-01), is declined, or is reserved by a `booking_request`. A reserved offer keeps its slot until the shop decides or P-03 passes (P-02). The business clock is authoritative for expiry.	2	Phase 2	Audit, Review

ID	Requirement	Phase	Status	Source
FR-BOOK-02	A barber agent must answer a `booking_request` carrying an `offerId` with a Task that ends `booking_confirmed` or `booking_rejected` with reason `expired`, `unknown_offer`, `slot_taken`, `shop_declined`, `shop_timeout` or `other`. The decision re-checks, in the same transaction that writes the booking, that the offer exists, is unexpired or reserved, belongs to the same `contextId`, and that the slot is still free.	2	Phase 2	Audit, Review
FR-BOOK-03	A customer must be able to cancel a booking (`cancel_request` → `cancelled`) and reschedule it (`reschedule_request` → a new `offer`, then the normal approve and book flow) through their agent, and the barber's book must update.	2	Phase 2	NB
FR-BOOK-04	Slot finding must never offer a slot that overlaps an existing booking, falls outside opening hours or starts in the past.	1	**Built.** `findFreeSlot` in `packages/barber-agent/src/book.ts`. TC-01 to TC-09.	Audit
FR-BOOK-05	Each business must have an IANA time zone. Opening hours are minutes of the local day; the slot grid starts from the local opening time; a local time skipped by a daylight-saving change produces no slot, and a repeated local time is offered once (first occurrence). Times on the wire stay UTC.	6	Phase 6 (UTC only today, ADR 0011; ADR 0018)	Audit, Review
FR-BOOK-06	A barber agent must read and write the shop's real booking system through MCP instead of the in-memory book, and the write must be conditional or atomic on that system; a booking system that can't do that is not supported.	6	Phase 6	ADR 0003, ADR 0011, Review
FR-BOOK-07	A retried `booking_request` must never create a second booking. A client that has the `taskId` retries with `GetTask`. A client that lost the response resends without a `taskId`; the business looks up `offerId` to `taskId`, and the new Task completes at once with the same `booking_confirmed` payload plus `duplicateOf` naming the original Task. The same rule applies to `cancel_request` through `bookingId`.	2	Phase 2	Review
FR-BOOK-08	An `offer_declined` message for a held offer must release its hold at once.	2	Phase 2	Review
FR-BOOK-09	A barber agent must refuse to create a new hold when the sender already has P-07 open holds. Until agent authentication, the sender is the client IP. There is no per-`contextId` cap, because clients choose `contextId`.	2	Phase 2	Review
FR-BOOK-10	A refused cancellation must end the cancel Task REJECTED with a `cancel_rejected` data part and reason `cutoff`, `unknown_booking` or `other`. The cutoff is a per-shop setting with no default (P-10).	2	Phase 2	Review
FR-BOOK-11	A `reschedule_request` is a question answered as a Message: an `offer` carrying `replacesBookingId`, `no_availability`, or `rejected` with reason `cutoff`. Booking that offer is an atomic swap: the old booking is cancelled only in the transaction that confirms the new one, and the cutoff (P-10) is checked again there (`booking_rejected` reason `cutoff`). If the new booking fails, the old one stands.	2	Phase 2	Review
FR-BOOK-12	A barber agent must validate the shop's own book configuration when it loads it (opening hours, service names unique, currency code, every booked range parseable and inside a valid day) and refuse to start on an invalid one.	2	Phase 2. Gap today: an unparseable booked `start` silently stops blocking its slot (tech debt D-15 in 19).	Review

4.3 Approval gate (GATE)

ID	Requirement	Phase	Status	Source
FR-GATE-01	No agent may make a commitment for a person without that person's explicit approval.	2	Phase 2. Today agents only offer; nothing can be booked.	NB, ADR 0007
FR-GATE-02	An approval must be bound to exactly one offer (`offerId`) and must lapse with that offer. The personal agent treats an offer as expired P-09 before its local deadline. An approval for one offer can never book another.	2	Phase 2	ADR 0007, Audit, Review
FR-GATE-03	Both sides must keep an append-only audit log of offers, decisions (with timestamp), booking requests and results. Each event carries a SHA-256 hash of the JCS (RFC 8785) canonical form of its data part.	2	Phase 2	ADR 0007, Review
FR-GATE-04	The only code path that sends a `booking_request` must take an `Approval`, a type only the gate can create; the type system must make it impossible to book without one.	2	Phase 2	Audit (architecture review)
FR-GATE-05	On the business side, opening hours count as standing approval by default. A per-shop switch lets the owner approve each booking manually. While the owner decides, the booking Task stays WORKING with a status message, never INPUT_REQUIRED; the personal agent sends the `booking_request` with `returnImmediately: true` and polls `GetTask` until its booking deadline (P-04). With no answer after P-03 the Task ends `booking_rejected` with reason `shop_timeout`.	2	Phase 2	Audit (open question in ADR 0007), Review

4.4 Directory (DIR)

ID	Requirement	Phase	Status	Source
FR-DIR-01	A business must be able to register its agent (`POST /v1/listings`), and the listing is published only after it proves control of the agent's origin (well-known token or DNS TXT record).	3	Phase 3	NB, insights

ID	Requirement	Phase	Status	Source
FR-DIR-02	People and agents must be able to search the directory by business name, service and area (`GET /v1/listings`, 13).	3	Phase 3	NB
FR-DIR-03	A listing must point to the business's agent card, and the card's interface URL must have the same origin as the listing. Mismatches are refused. Hosted business agents get one subdomain each so their origins differ.	3	Phase 3 (subdomains per hosted tenant from Phase 6)	Audit (security review), Review
FR-DIR-04	A business must be able to update or remove its own listing, and no other.	3	Phase 3	
FR-DIR-05	Each listing must show its verification status and rating summary.	5	Phase 5	NB

4.5 Client app (APP)

ID	Requirement	Phase	Status	Source
FR-APP-01	A person's contacts in the app must be agents (business agents from the directory, or any A2A agent by URL).	4	Phase 4	NB
FR-APP-02	The approval screen must show only validated offer data, rendered as plain text, and must state that nothing is booked until the person approves.	4	Phase 4. The CLI already prints only validated fields (`packages/my-agent/src/main.ts`).	Audit
FR-APP-03	The app must include a built-in personal agent; it is the consumer agent at launch, so a person can use Hitchpost without bringing their own (A-08).	4	Phase 4	Audit (product review)
FR-APP-04	A person must see their upcoming bookings and be able to reschedule or cancel them.	4	Phase 4	
FR-APP-05	A person must be able to block or remove an agent contact.	4	Phase 4	
FR-APP-06	After a `booking_confirmed` that matches the approved offer field for field, the personal agent must write the booking to the person's calendar; a confirmation that doesn't match is not written and is flagged to the person.	4	Phase 4	Review

4.6 Ratings and outcomes (RATE)

ID	Requirement	Phase	Status	Source
FR-RATE-01	Only verified interactions may be rated; each interaction may be rated once per side. In Phase 5 an interaction is verified when both sides' audit events carry matching JCS SHA-256 hashes of the offer and the decision; cryptographic signatures on interaction records come with agent authentication in Phase 6 (ADR 0017).	5	Phase 5	NB, insights
FR-RATE-02	The system must compute structured agent-behaviour metrics from audit logs: response time, offer honoured, stayed within its card's skills, approval rate.	5	Phase 5	NB
FR-RATE-03	A person may add a short human review to a verified interaction; it is shown separately from the behaviour metrics.	5	Phase 5	NB
FR-RATE-04	The shop must be able to mark every booking whose time has passed as Completed or NoShow on its dashboard. The north star counts Completed bookings only.	4	Phase 4	Review
FR-RATE-05	The customer must be asked "Did it go as booked?" after a booking's time has passed; the answer is recorded on the interaction record, and a disagreement with the shop's mark is flagged rather than silently overriding it.	5	Phase 5	Review

4.7 Operator and moderation (ADMIN)

ID	Requirement	Phase	Status	Source
FR-ADMIN-01	Anyone must be able to report an agent; an operator must be able to suspend or remove a listing, and the business must be notified with the reason.	5 (report), 6 (takedown)	Phase 5 / 6	insights
FR-ADMIN-02	An operator must be able to see an audit trail of moderation actions.	6	Phase 6	

5. User stories for the next phases

Phase 2

FR-GATE-01, FR-GATE-02. As Dana, I want to approve one specific offer, so that my agent can never book something I didn't see.

- **Given** my agent received a valid offer for a haircut on Thursday at 17:30 for 30.00 USD, **when** I approve it, **then** my agent sends a `booking_request` for that `offerId` only, and the approval is recorded in my audit log.

- **Given** I approved offer A, **when** any code tries to book offer B with that approval, **then** it is refused and nothing is sent.
- **Given** the offer is within P-09 of its deadline or past it, **when** I approve it, **then** my agent tells me it expired and asks the barber agent for a fresh offer.

FR-BOOK-01, FR-BOOK-02, FR-BOOK-07. As Marcus, I want offers to hold the slot briefly and bookings to be decided once, so that two customers are never given the same chair.

- **Given** the barber agent offered 17:30 to Dana, **when** another agent asks for the same window before the offer expires, **then** 17:30 is not offered.
- **Given** a `booking_request` with an unknown or expired `offerId`, **when** it arrives, **then** the barber agent answers `booking_rejected` (`unknown_offer` or `expired`) and its book is unchanged.
- **Given** two `booking_request`s for the same slot arrive together, **when** both are processed, **then** exactly one is confirmed.
- **Given** Dana's agent retries the same `booking_request`, **when** it arrives, **then** it gets the same Task back, not a second booking.

FR-GATE-05. As Marcus, I want to approve bookings myself on busy days, so that I stay in control of my chair.

- **Given** my shop is set to manual approval, **when** Dana's agent sends a `booking_request`, **then** the offer becomes Reserved, the Task stays WORKING with "waiting for the shop", and Dana's agent polls for the result.
- **Given** I don't answer within P-03, **when** the time passes, **then** the Task ends `booking_rejected` with `shop_timeout` and the slot is free again.

FR-BOOK-08, FR-BOOK-09. As Marcus, I don't want strangers to lock up my chairs with offers they never take.

- **Given** Dana declines an offer, **when** her agent sends `offer_declined`, **then** the slot is offered again at once.
- **Given** one sender already has P-07 open holds, **when** it asks again, **then** it gets `rejected` and no new hold.

FR-GATE-03, FR-MSG-11. As Dana or Marcus, I want a record of what my agent proposed and what was decided, so that I can check what happened if something goes wrong.

- **Given** a completed booking, **when** I read my audit log, **then** it shows the offer, my decision with a timestamp, the booking request and the result, in order, each with the shared `contextId`, `taskId`, `offerId` and `messageId`, with no entries changed or removed.

FR-BOOK-03, FR-BOOK-10, FR-BOOK-11. As Dana, I want to cancel or move my booking through my agent, so that I don't have to call the shop.

- **Given** a confirmed booking, **when** I cancel it, **then** the barber's book frees the slot, both audit logs record the cancellation, and the slot can be offered again.
- **Given** the shop has a cutoff and I'm inside it, **when** I cancel, **then** the Task ends REJECTED with `cancel_rejected` reason `cutoff` and my booking stands.
- **Given** I reschedule and the new slot is taken before I approve, **when** the booking fails, **then** my original booking is unchanged.
- **Given** the shop has a cutoff and I'm inside it, **when** I ask to reschedule, **then** I get `rejected` with reason `cutoff` and my booking stands.
- **Given** my agent lost the response to a `booking_request`, **when** it resends without a `taskId`, **then** it gets the same `booking_confirmed` with `duplicateOf` and the book still holds one booking.

Phase 3

FR-DIR-01. As Marcus, I want to list my shop's agent, so that customers' agents can find me.

- **Given** I submit my agent card URL and place the verification token on that origin (or its DNS), **when** verification runs, **then** the listing goes live marked as verified.
- **Given** I can't prove control, **when** I submit, **then** the listing is not published.

FR-DIR-02. As Dana, I want to find a barber near me who does fades, so that my agent can ask them for a slot.

- **Given** listings exist, **when** I search for "fade" near my area, **then** I get matching verified listings with their agent card links, nearest first.

FR-DIR-03. As Dana, I want my agent to talk only to the business I picked, so that a listing can't redirect me somewhere else.

- **Given** a listing at `https://shop.example`, **when** its card's interface URL points at another origin, **then** my agent refuses to send it anything and the directory flags the listing.

6. Non-functional requirements

ID	Requirement	Target	Phase	Status
NFR-SEC-01	Inbound agent data is untrusted and strictly validated before any use.	100% of inbound message kinds have a parser and rejection tests; text fields obey P-19.	1	**Built** for the four current kinds (`packages/core/src/booking.ts`); each Phase 2 kind adds its parser and tests.
NFR-SEC-02	Agents authenticate each other with signed agent cards: JWS over the JCS-canonical card, keys published as JWKS at a URL registered in the directory listing, immediate revocation on suspected compromise.	Unsigned or unverifiable agents can't book.	6	Phase 6
NFR-SEC-03	Rate limits per sender on every agent and directory endpoint.	P-08; over-limit gets HTTP 429.	2, 6	Phase 2 per client IP; Phase 6 per verified agent identity.
NFR-SEC-04	No stack traces, file paths or server banners in responses.	Zero in a probe of error paths (oversized body, malformed JSON, unknown route).	1	**Built.** Error handler and `x-powered-by` off in `packages/barber-agent/src/server.ts`. Verified today by demonstration (audit probe, re-run 2026-11-09); automated as TC-30 in Phase 2.

ID	Requirement	Target	Phase	Status
NFR-SEC-05	Text shown to a person contains no control characters.	All displayed fields pass `SAFE_TEXT` (P-19).	1	**Built.** `SAFE_TEXT` in `packages/core/src/booking.ts`. TC-13, TC-15.
NFR-PRIV-01	Data minimisation: an agent shares a slot, never a calendar.	No message kind carries calendar contents or contact details beyond what the booking needs.	1	**Built** for current messages; inspected for each new message kind.
NFR-PRIV-02	Personal data has a documented retention period and can be exported and deleted on request.	Retention P-11 to P-14; erasure within P-13, backups expire per P-15.	6	Phase 6
NFR-PERF-01	Offer round trip (request to validated offer).	p95 under 2 s on the hosted service.	6	Locally the end-to-end test runs in about 150 ms; not yet measured hosted.
NFR-PERF-02	One request can only cause bounded work.	Slot search covers at most P-06 (1,488 slots).	1	**Built** (`MAX_WINDOW_DAYS`). TC-13.
NFR-REL-01	Directory availability.	99.5% monthly.	6	Phase 6
NFR-REL-02	No lost or duplicated bookings.	Zero double bookings in concurrency tests; a booking is committed before `booking_confirmed` is sent; offers, bookings and audit logs survive a restart.	2	Phase 2: business side on SQLite through the SDK's `DatabaseTaskStore` plus offer, booking and audit tables; personal side on a JSONL audit file. Phase 6: Postgres `slot_claims` with a range exclusion constraint.
NFR-OBS-01	Logs that follow one booking end to end.	Every booking traceable across both agents by its correlation ids (FR-MSG-11) from Phase 2; by one trace id across all services from Phase 6.	2, 6	Phase 2 (correlation ids), Phase 6 (trace ids)
NFR-A11Y-01	Client app accessibility.	WCAG 2.2 AA, checked by automated audit and a manual screen-reader pass.	4	Phase 4
NFR-INT-01	A2A compliance.	Works with the official A2A SDK v1.x on both sides; card at the standard path; a third-party agent completes a booking (G-5).	1, 6	**Built** for our two agents (`@a2a-js/sdk` 1.3, A2A v1.0); third-party interop Phase 6 (TC-64 on staging, WP-6.12).
NFR-MAINT-01	CI gates on every change.	Lint, type check and tests required to merge to `main`.	0	Workflow written (`.github/workflows/ci.yml`); enforced once the repository is pushed and branch protection is on (ADR 0005).
NFR-MAINT-02	Every new behaviour ships with a test.	New logic without a test is not merged.	0	Policy in CONTRIBUTING.md.

7. Traceability matrix

Every FR and NFR appears exactly once. Design references use the renumbered package: 07 Process and behaviour models, 08 Data design, 09 Data dictionary, 10 Architecture, 11 Quality attributes, 12 Security and privacy, 13 Interfaces, 14 User interface design, 18 Deployment and operations. Verification methods are defined in section 2; test cases `TC-nn` are catalogued in 15 Test strategy.

Requirement	Use case	Design	Method	Test cases
FR-MSG-01	UC-01	13 agent card; 10 barber agent	T	TC-17 to TC-22
FR-MSG-02	UC-01	13 message contract	T	TC-17, TC-18, TC-20
FR-MSG-03	UC-01	13 message contract; 09 field limits; 12 trust boundaries	T	TC-12 to TC-15, TC-49
FR-MSG-04	UC-01	07 offer rules; 10 personal agent	T	TC-16, TC-21
FR-MSG-05	UC-01	12 client hardening	T	TC-22
FR-MSG-06	UC-01	09 instant format; 13 message contract	T	TC-11, TC-13
FR-MSG-07	UC-01	09 field limits	T	TC-13
FR-MSG-08	UC-01	10 personal agent	T	TC-19
FR-MSG-09	UC-02	13 versioning and compatibility	T	TC-31, TC-51
FR-MSG-10	UC-02, UC-04	13 A2A usage; 10 booking sequence	T	TC-32
FR-MSG-11	UC-02, UC-03, UC-04	08 audit event; 18 observability	T	TC-44
FR-MSG-12	UC-02, UC-03, UC-04	12 agent-to-agent threats; 13 message contract	T	TC-48
FR-BOOK-01	UC-02	07 offer state machine; 08 offer store	T	TC-33
FR-BOOK-02	UC-02	07 booking decision table; 10 booking sequence	T	TC-34, TC-35
FR-BOOK-03	UC-04	07 booking state machine; 13 message contract	T	TC-39
FR-BOOK-04	UC-01	07 slot availability rules; 08 appointment book	T	TC-01 to TC-09
FR-BOOK-05	UC-01, UC-02	10 time zones (ADR 0018)	T	TC-98

Requirement	Use case	Design	Method	Test cases
FR-BOOK-06	UC-02	10 booking system connector; 17 connection options	T, D	TC-99
FR-BOOK-07	UC-02	07 booking decision table; 13 A2A usage	T	TC-36
FR-BOOK-08	UC-03	07 offer state machine; 13 message contract	T	TC-37
FR-BOOK-09	UC-01, UC-02	07 offer rules; 12 abuse controls	T	TC-38
FR-BOOK-10	UC-04	07 cancellation rules; 13 message contract	T	TC-39
FR-BOOK-11	UC-04	07 booking state machine; 13 message contract	T	TC-40, TC-52
FR-BOOK-12	UC-01	08 appointment book; 09 book configuration	T	TC-45
FR-GATE-01	UC-02	10 approval gate component	T	TC-42
FR-GATE-02	UC-02, UC-03	10 approval gate component; 07 approval rules	T	TC-43
FR-GATE-03	UC-02, UC-03, UC-04	08 audit log	T	TC-44
FR-GATE-04	UC-02	10 approval gate component	T, I	TC-42 (type-level fixture)
FR-GATE-05	UC-02	07 approve-and-book activity; 10 booking sequence; 14 barber dashboard	T	TC-41
FR-DIR-01	UC-05	10 directory service; 08 listing	T	TC-60
FR-DIR-02	UC-06	13 directory API	T	TC-61
FR-DIR-03	UC-06, UC-07	12 directory trust; 10 tenancy	T	TC-62
FR-DIR-04	UC-05	13 directory API	T	TC-63
FR-DIR-05	UC-06	14 listing detail	T	TC-84
FR-APP-01	UC-07	10 client app; 14 chat list	T	TC-70
FR-APP-02	UC-02	14 approval sheet	T, I	TC-71
FR-APP-03	UC-07	10 client app	T	TC-72
FR-APP-04	UC-04	14 bookings list	T	TC-73
FR-APP-05	UC-07	14 chat list	T	TC-74
FR-APP-06	UC-02	10 personal agent; 08 booking	T	TC-75
FR-RATE-01	UC-08	08 ratings; 07 rating eligibility table	T	TC-80, TC-87
FR-RATE-02	UC-08	10 rating service	T	TC-81
FR-RATE-03	UC-08	14 listing detail	T	TC-82
FR-RATE-04	UC-08	07 booking state machine; 14 barber dashboard	T	TC-83
FR-RATE-05	UC-08	07 booking state machine; 14 customer outcome prompt	T	TC-86
FR-ADMIN-01	UC-09, UC-10	10 operator tools; 07 report state machine	T	TC-85, TC-90
FR-ADMIN-02	UC-10	10 operator tools	T	TC-91
NFR-SEC-01	UC-01	12 trust boundaries	T	TC-13, TC-15, TC-20, TC-50
NFR-SEC-02	UC-02, UC-06	12 identity and authentication; 10 signing	T	TC-92
NFR-SEC-03	UC-01, UC-02	12 abuse controls	T	TC-47 (per IP), TC-93 (per identity)
NFR-SEC-04	UC-01	12 server hardening	D now; T from Phase 2	Audit probe; TC-30
NFR-SEC-05	UC-01	12 trust boundaries	T	TC-13, TC-15
NFR-PRIV-01	UC-01, UC-02	12 privacy; 09 privacy classes	I	Inspection of each message kind in 13 against 09 privacy classes, per release; TC-12, TC-14 for unknown-field dropping
NFR-PRIV-02	All	12 retention; 08 retention	T, D	TC-97
NFR-PERF-01	UC-01	11 performance scenarios; 18 SLOs	T	TC-94
NFR-PERF-02	UC-01	11 performance scenarios	T	TC-13
NFR-REL-01	UC-06	18 SLOs	A, D	TC-95 (monthly availability report from monitoring)
NFR-REL-02	UC-02, UC-04	08 persistence; 10 booking sequence	T	TC-35, TC-46
NFR-OBS-01	UC-02	18 observability	T	TC-44 (Phase 2), TC-96 (Phase 6)
NFR-A11Y-01	UC-02, UC-07	14 accessibility	T, D	TC-76, TC-77
NFR-INT-01	UC-01, UC-06	13 A2A usage	T, D	TC-17, TC-64
NFR-MAINT-01	All	18 CI/CD	I, D	Inspection of the branch ruleset and a CI run on the first pull request
NFR-MAINT-02	All	18 CI/CD	I	Pull request review checklist

Revision history

Version	Date	Change	Author
0.1	2026-11-08	First draft	S. Jannisar
1.0	2026-11-09	Baselined: renumbered into lifecycle order, formal document control, standards conformance	S. Jannisar
1.1	2026-11-09	Remediation after independent review: P-ID values; booking protocol fixes (Reserved hold, WORKING not INPUT_REQUIRED, idempotency, hold caps, decline, cancel rejection, atomic reschedule, contextId binding); new FR-MSG-11, FR-MSG-12, FR-BOOK-07 to FR-BOOK-12, FR-APP-06, FR-RATE-04; one verified-interaction definition; corrected phases; traceability rebuilt with verification methods and test case IDs	S. Jannisar
1.2	2026-11-09	Second remediation after regrade: FR-MSG-09 extension declared in the A2A-Extensions header; FR-MSG-12 authority moved from contextId to server-minted capabilities (offerId, bookingToken); FR-BOOK-07 duplicate handling matched to SDK 1.3; FR-BOOK-09 cap per sender only; FR-BOOK-11 reschedule as a Message with cutoff at the question and the swap; FR-RATE-04 split into shop marking (Phase 4) and FR-RATE-05 customer prompt (Phase 5); third-party interop moved to Phase 6; traceability updated (TC-51, TC-52, TC-86)	S. Jannisar

HP-SAD-06 · Use cases

Field	Value
Document ID	HP-SAD-06
Version	1.2
Status	Baselined for Phase 2
Date	2026-11-09
Owner	Sanaullah Jannisar, product and engineering lead
Conforms to	ISO/IEC/IEEE 29148:2018 (operational scenarios); UML 2.5 use case and sequence notation

Step-by-step flows for use cases UC-01 to UC-10. UC-01 describes the system as built; the rest describe the design for their phase. Requirement IDs refer to 05. Requirements. The booking protocol behind UC-02 to UC-04 is ADR 0012; business rules (BR-) and states are in 07; timing values are the normative parameters P-01 to P-20 in 00.

Actors: **Dana** (customer), **Dana's agent**, **Marcus** (barber), **Marcus's agent** (barber agent), **Priya** (agent developer), **Sam** (operator), **Directory**.

UC-01. Ask a business agent for availability

Phase 1, Built. Code: `askForSlot` in `packages/my-agent/src/ask.ts`, `BarberExecutor` in `packages/barber-agent/src/executor.ts`.

- **Actors:** Dana, Dana's agent, Marcus's agent.
- **Preconditions:** Dana's agent knows the barber agent's URL. The barber agent is running with an appointment book.
- **Trigger:** Dana asks for a service in a time window (today through the CLI: service, earliest, latest).
- **Postconditions:** Dana sees a validated offer, "no slots" or a rejection. Nothing is booked.
- **Related:** FR-MSG-01 to FR-MSG-08, FR-BOOK-04, NFR-SEC-01, NFR-SEC-05.

Main flow

1. Dana's agent validates its own request (service, strict ISO times, window up to 31 days).
2. It fetches the barber agent's card from `/.well-known/agent-card.json` (no redirects, one deadline for the whole exchange).
3. It sends the `availability_request` as an A2A data part over JSON-RPC.
4. The barber agent validates and rebuilds the request.
5. It finds the first free slot in the window that fits opening hours, overlaps no booking and is not in the past.
6. It replies with an `offer` message.
7. Dana's agent validates the reply and checks the offer matches the request (same service, start inside the window).
8. Dana sees the offer and the note that nothing is booked until she approves.

Alternate and exception flows

- **1a.** Dana's request is invalid: her agent refuses to send it and says the service or dates aren't valid.
- **2a.** The card can't be fetched, redirects, or the agent doesn't answer before the deadline (10 s): Dana sees "Couldn't get an answer from that agent."
- **4a.** The request is invalid or not a data part (for example free text): the barber agent replies `rejected`.
- **5a.** No slot fits: the barber agent replies `no_availability`.
- **7a.** The reply is malformed, contains control characters, or the offer doesn't match the request: Dana's agent refuses it with a plain message of its own. Remote text is never shown.
- **7b.** The barber agent answers with a Task instead of a Message: Dana's agent reports the task state.

UC-02. Approve an offer and book it

Phase 2.

- **Actors:** Dana, Dana's agent, Marcus's agent.
- **Preconditions:** UC-01 produced a validated, matching offer with `issuedAt` and `expiresAt`. The barber agent stored it as Held and blocks the slot until it expires (offer hold, P-01).
- **Trigger:** Dana approves the offer.

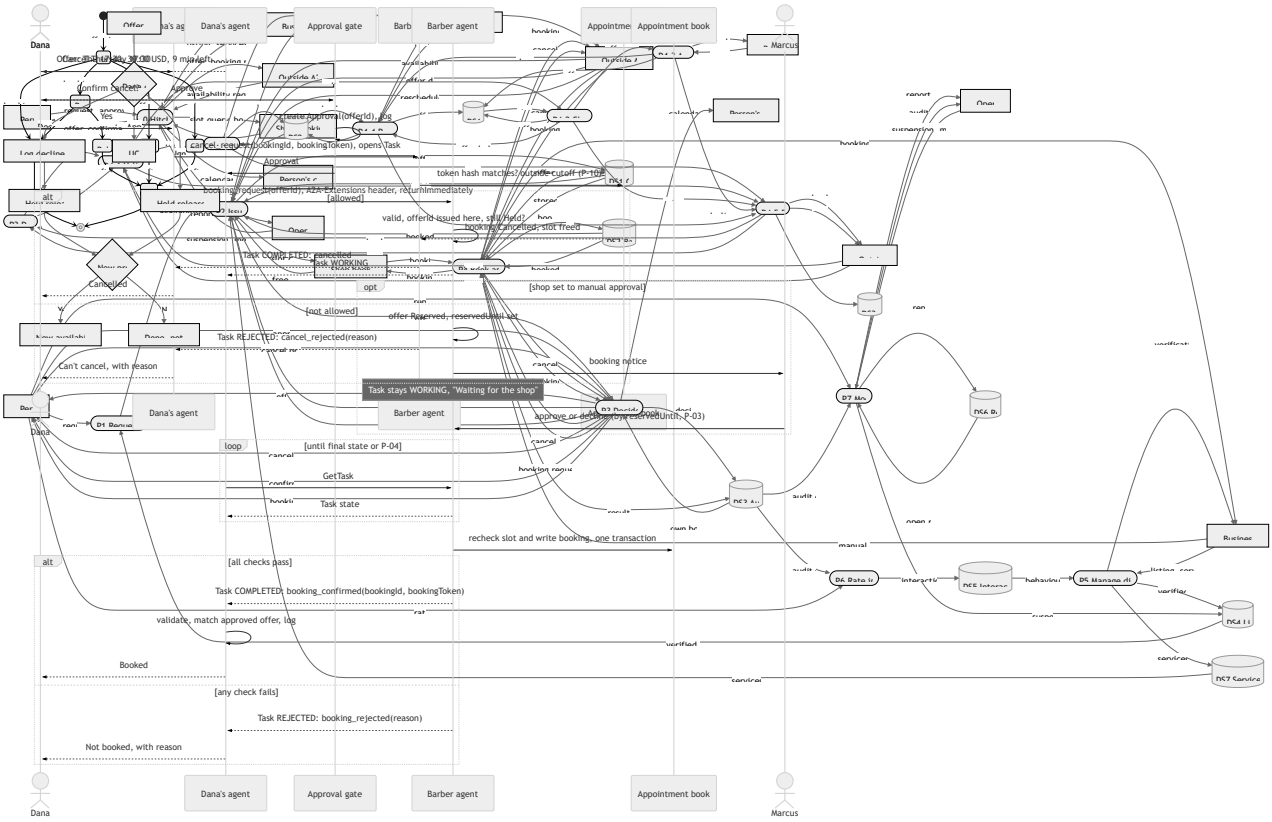
- **Postconditions:** the slot is booked in Marcus's book; both audit logs record offer, approval, request and result with the correlation fields (`contextId`, `taskId`, `offerId`, `messageId`); Dana's calendar has the appointment (from Phase 4).
- **Related:** FR-GATE-01 to FR-GATE-05, FR-BOOK-01, FR-BOOK-02, FR-APP-02, NFR-REL-02; BR-06 to BR-09, BR-18, BR-19.

Main flow

1. Dana's agent shows the offer using only validated fields, with the time left. Its local deadline is when it received the offer plus (`expiresAt` − `issuedAt`), less the clock margin (P-09), so clock skew can't let an approval arrive late.
2. Dana approves. The approval gate creates an `Approval` bound to this `offerId` (only the gate can create one), records the `contextId` with it for correlation, and logs it.
3. Her agent sends a `booking_request` with the `offerId`, declaring the contract extension in the `A2A-Extensions` header (the SDK refuses a send without it, `server/index.js:2775-2781`), with `returnImmediately: true`. The booking function only accepts an `Approval`.
4. The barber agent opens an A2A Task. It checks the request is valid, the `offerId` is one it issued, and the offer is still Held. The `offerId` is the capability; the `contextId` proves nothing, because the client chooses it. By default the shop's opening hours count as Marcus's standing approval.
5. In one transaction it rechecks the slot is free, writes the booking, mints a `bookingToken` (storing only its hash), marks the offer Booked, logs it, and completes the Task with `booking_confirmed` carrying the `bookingId` and `bookingToken`.
6. Dana's agent polls `GetTask` until a final state, validates the confirmation, checks it matches the approved offer field for field, stores the `bookingToken` securely, logs it, and adds the appointment to Dana's calendar.
7. Dana sees "Booked."

Alternate and exception flows

- **2a.** The local deadline passed before Dana approved: her agent says the offer expired and offers to ask again (back to UC-01).
- **4a.** The `offerId` is unknown or the offer is no longer Held: the Task ends `REJECTED` with `booking_rejected` `unknown_offer` or `expired`; nothing is written.
- **4b.** Marcus has switched his shop to manual approval (FR-GATE-05): the offer becomes Reserved and the Task stays `WORKING` with the status "Waiting for the shop" and a `booking_pending` data part carrying `reservedUntil` (acceptance time + P-03; the offer's `expiresAt` doesn't change). This is not input-required, which in A2A asks the client for input; see ADR 0012. Marcus is notified. If he approves by `reservedUntil`, the flow continues at step 5. If he declines, the Task ends `booking_rejected` `shop_declined`; if he doesn't answer in time, `shop_timeout`. Either way the offer is Released.
- **5a.** The recheck finds the slot taken (only possible if the shop's own system booked it outside Hitchpost): `booking_rejected` `slot_taken`; nothing is written.
- **6a.** The confirmation doesn't match the approved offer: Dana's agent treats it as a failure, logs it and tells Dana to contact the shop.
- **6b.** No final state before the booking deadline (P-04): Dana's agent tells her it couldn't confirm the booking and keeps polling in the background; it never shows "Booked" without a `booking_confirmed`.
- **3a.** Network failure after sending. If Dana's agent got the `taskId`, it retries by polling `GetTask`; it never resends with that `taskId`, which the SDK refuses once the Task is finished (`server/index.js:2789`). If it never got the `taskId`, it resends the `booking_request` with the same `offerId` and `messageId`; the SDK gives the resend a new Task (`server/index.js:2801`), which the barber agent completes at once with the original result plus `duplicateOf: <original taskId>` (BR-18). Never a second booking.



UC-03. Decline an offer or ask for another

Phase 2.

- **Actors:** Dana, Dana's agent, Marcus's agent.
- **Preconditions:** Dana has a validated offer (UC-01).
- **Trigger:** Dana declines, or asks for something different.
- **Postconditions:** nothing is booked; both sides log the decline; the hold is released at once (or at `expiresAt` if Dana just ignores the offer).
- **Related:** FR-GATE-01, FR-GATE-03, FR-BOOK-01; BR-17, BR-19.

Declining sends `offer_declined`, so Marcus's chair is freed immediately instead of sitting blocked for the rest of the offer hold (P-01). Releasing holds early also keeps a person under the open holds cap (P-07) when they ask for alternatives.

Main flow

1. Dana declines the offer.
2. Her agent logs the decline and sends `offer_declined` with the `offerId` (the capability that names the offer).
3. The barber agent marks the offer Declined, releases the hold and logs it.
4. If Dana gave a new preference ("anything later?"), her agent sends a new `availability_request` with the adjusted window (back to UC-01).

Alternate flows

- **1a.** Dana ignores the offer: nothing is sent; at `expiresAt` the barber agent marks it Expired and releases the hold.
- **2a.** `offer_declined` doesn't arrive (network failure): the hold is released at `expiresAt` anyway; nothing depends on the decline message.
- **4a.** No other slot fits: Dana sees "no slots" and can widen the window.
- **4b.** Dana's sender (her client IP until Phase 6) already has open holds up to the cap (P-07): the barber agent answers `rejected` until one is declined or expires.

UC-04. Reschedule or cancel a booking

Phase 2.

- **Actors:** Dana, Dana's agent, Marcus's agent. (Marcus cancelling from the shop side is Later; in v1 he contacts Dana outside Hitchpost.)
- **Preconditions:** a Confirmed booking exists in both audit logs.
- **Trigger:** Dana cancels or asks to move the booking.
- **Postconditions:** cancel: booking Cancelled, slot freed, both logs updated. Reschedule: the new booking is confirmed and the old one marked Rescheduled in the same transaction. Neither can bypass the shop's cancellation cutoff (P-10).
- **Related:** FR-BOOK-03, FR-MSG-10, FR-GATE-01, FR-GATE-03; BR-10, BR-11, BR-19.

Main flow (cancel)

1. Dana chooses the booking and cancels. Her agent confirms with her first (cancelling is a commitment change).
2. Her agent sends `cancel_request` with the `bookingId` and the `bookingToken` it received in `booking_confirmed`, which opens an A2A Task. Until agent authentication (Phase 6) that token is what proves the request comes from the customer who booked, so it is never shown or put in a URL. The `contextId` proves nothing: the client chooses it (`server/index.js:2815`).
3. The barber agent checks the token against the stored hash and that the booking is outside the cancellation cutoff (P-10), marks it Cancelled, frees the slot, logs it and completes the Task with `cancelled`. A resend without the `taskId` gets the same result with `duplicateOf`.
4. Dana's agent removes the calendar entry and logs it.

Main flow (reschedule)

1. Dana asks to move the booking. Her agent sends `reschedule_request` with the `bookingId`, the `bookingToken` and the new window. It is a question, so it goes as a Message, not a Task.
2. The barber agent checks the token and that the old booking is outside the cancellation cutoff (P-10), then answers with an `offer` carrying `replacesBookingId` (as in UC-01).
3. Dana approves it and the normal UC-02 flow books the new slot.
4. At the swap the barber agent checks the cutoff again. In the same transaction that writes the new booking, it marks the old one Rescheduled and frees its slot; both sides log it. The new `booking_confirmed` carries a new `bookingToken`.

Alternate and exception flows

- **3a.** Cancel refused: the Task ends `REJECTED` with `cancel_rejected`, reason `cutoff` (inside the shop's cutoff) or `unknown_booking` (unknown booking, or wrong or missing token); nothing changes.

- **Reschedule 2a.** No slot in the new window: `no_availability`; the old booking stays.
- **Reschedule 2b.** The old booking is inside the cutoff, or the token is wrong: `rejected` with reason `cutoff` or `unknown_booking`; the old booking stays.
- **Reschedule 4a.** The cutoff passed while Dana was deciding: the Task ends `booking_rejected` with reason `cutoff`; the old booking stays.
- **Reschedule 3a.** The new offer expires, is declined, or its booking is rejected: the old booking stays (the swap is atomic).
- **Later.** Marcus cancels from the shop side and Dana's agent is notified. This needs a business-to-person message the `hitchpost/1` contract doesn't have.

UC-05. Register a business agent in the directory

Phase 3.

- **Actors:** Marcus (or Priya on his behalf), Directory.
- **Preconditions:** the business has an A2A agent with a reachable agent card.
- **Trigger:** Marcus submits his agent card URL and business details.
- **Postconditions:** a verified listing is live and searchable.
- **Related:** FR-DIR-01, FR-DIR-03, FR-DIR-04.

Main flow

1. Marcus enters the shop name, area, services, IANA time zone and agent card URL (`POST /v1/listings`, status `pending`).
2. The directory fetches the card, validates it, and checks the card's interface URL has the same origin as the submitted URL.
3. The directory asks Marcus to prove control of that origin (`POST /v1/listings/{id}/verify`: a well-known token file or a DNS TXT record).
4. Marcus completes the check.
5. The listing goes live marked verified.

Alternate flows

- **2a.** The card is missing, invalid or points at another origin: registration is refused with the reason.
- **4a.** Verification fails or times out: the listing stays unpublished.
- **Later.** Marcus updates (`PATCH /v1/listings/{id}`) or closes (`DELETE`) the listing; changing `cardUrl` resets verification and repeats steps 2 to 4.

UC-06. Find a business agent

Phase 3.

- **Actors:** Dana or Dana's agent, Directory.
- **Preconditions:** verified listings exist.
- **Trigger:** a search by name, service or area.
- **Postconditions:** Dana's agent has a verified card URL to use in UC-01.
- **Related:** FR-DIR-02, FR-DIR-03, FR-DIR-05.

Main flow

1. Dana (or her agent) searches "fade near Downtown" (`GET /v1/listings?q=fade&near=…`).
2. The directory returns matching verified listings, nearest first, with verification status and, from Phase 5, rating summaries.
3. Dana picks one. Her agent fetches the card and checks its interface origin matches the listing before sending anything.

Alternate flows

- **2a.** No results: suggest widening the area or service.
- **3a.** Origin mismatch: her agent refuses, and the listing is reported automatically (UC-09).

UC-07. Add an agent as a contact and chat in the app

Phase 4.

- **Actors:** Dana, the client app with its built-in personal agent (the consumer agent at launch, A-08), a business agent.
- **Preconditions:** Dana has the app installed and signed in.
- **Trigger:** Dana adds a business from the directory, or pastes any A2A agent URL.
- **Postconditions:** the agent is in her contacts; conversations with it run UC-01 to UC-04 in the app.

- **Related:** FR-APP-01 to FR-APP-05, NFR-A11Y-01.

Main flow

1. Dana finds a business (UC-06) and taps "Add contact".
2. The app stores the contact with its verified card URL.
3. Dana opens the chat and types "cut Thursday after work". The app turns this into a structured request she confirms (service, window).
4. The conversation follows UC-01; offers appear as approval cards (UC-02).

Alternate flows

- **1a.** Dana pastes an unlisted agent URL: the app warns that it isn't verified before adding it.
- **Any step.** Dana blocks a contact: no further messages from it are shown or answered.

UC-08. Rate an interaction

Phase 5.

- **Actors:** Dana and Marcus (each rates the other side), Directory.
- **Preconditions:** a verified interaction exists: both sides logged the offer and a matching decision, and the booking reached Completed or NoShow (BR-14).
- **Trigger:** the outcome is reported, by the shop marking it on the dashboard or by Dana answering "Did it go as booked?" (E-15).
- **Postconditions:** the structured metrics update; an optional short review is attached.
- **Related:** FR-RATE-01 to FR-RATE-03.

Main flow

1. The directory computes behaviour metrics from the interaction (response time, offer honoured, stayed within its card's skills).
2. Dana is asked for an optional rating and short review.
3. The review is stored against that interaction, once per side.

Alternate flows

- **1a.** No verified interaction: rating is refused.
- **3a.** A second rating for the same interaction and side: refused.

UC-09. Report an abusive or fake agent

Phase 5.

- **Actors:** anyone (Dana, Marcus, Priya, an agent automatically), Directory, Sam.
- **Preconditions:** the agent is listed or has interacted with the reporter.
- **Trigger:** a report with a reason (impersonation, spam, misleading offers, abuse).
- **Postconditions:** the report is queued for moderation (UC-10); severe automatic signals can suspend a listing pending review.
- **Related:** FR-ADMIN-01.

Main flow

1. The reporter picks a reason and adds details.
2. The directory records the report with links to the related interactions.
3. Sam is notified.

Alternate flows

- **2a.** Many reports in a short time, or an origin mismatch: the listing is suspended automatically until Sam reviews it.

UC-10. Moderate the directory and handle reports

Phase 6.

- **Actors:** Sam, Directory, the reported business.
- **Preconditions:** reports exist (UC-09).
- **Trigger:** Sam opens the moderation queue.
- **Postconditions:** each report is resolved (dismissed, warning, suspension, removal), the business is notified with the reason, and the action is in the moderation audit trail.
- **Related:** FR-ADMIN-01, FR-ADMIN-02.

Main flow

1. Sam reviews the report and the linked audit records.
2. Sam chooses an action and a reason.

3. The directory applies it and notifies the business.
4. The action is recorded in the moderation trail.

Alternate flows

- **3a.** The business appeals: Sam re-reviews; the outcome is recorded too.

Revision history

Version	Date	Change	Author
0.1	2026-11-08	First draft	S. Jannisar
1.0	2026-11-09	Baselined: renumbered into lifecycle order, formal document control, standards conformance	S. Jannisar
1.1	2026-11-09	Remediation after independent review: UC-02 Reserved and WORKING with polling, recheck, idempotent retry, clock margin; UC-03 `offer_declined`; UC-04 `cancel_rejected`, `replacesBookingId` atomic swap, context binding, shop-side cancel Later; UC-08 verified interaction definition	S. Jannisar
1.2	2026-11-09	Second remediation after regrade: `offerId` and `bookingToken` as capabilities instead of `contextId`; extension in the `A2A-Extensions` header; retries by `GetTask` or resend with `duplicateOf`; `reservedUntil`; reschedule as a Message with the cutoff checked at the question and at the swap	S. Jannisar

HP-SAD-07 · Process and behaviour models

Field	Value
Document ID	HP-SAD-07
Version	1.2
Status	Baselined for Phase 2
Date	2026-11-09
Owner	Sanaullah Jannisar, product and engineering lead
Conforms to	ISO/IEC/IEEE 29148 (requirements analysis models), structured analysis (Yourdon/DeMarco DFDs), UML 2.5 state machines

1. Purpose and scope

This document models how data moves through Hitchpost and how its key objects change state. It covers v1 (Phases 1 to 6): agent messaging, the approval gate, booking, directory, ratings and moderation. It turns the requirements in 05 and the flows in 06 into process models, business rules, decision tables and state machines that the design in 10 and the tests in 15 are checked against. The booking protocol these models follow is recorded in ADR 0012.

Status marks follow the package convention: **Built** (in code now), **Phase N** (planned), **Later**. Timing and limit values are referenced by their normative parameter IDs (P-01 to P-20, register in 00 Document control), not repeated.

2. Notation

Mermaid has no native DFD shapes, so I use a fixed mapping. Every diagram in this document follows it.

DFD element	Mermaid shape	Naming rule
External entity	Rectangle `[Name]`	A noun: a person or outside system
Process	Rounded `([P1 Verb object])`	Numbered, verb plus object
Data store	Cylinder `[(DS1 Name)]`	Numbered, plural noun
Data flow	Labelled arrow	The data that moves, not an action

Rules I hold every diagram to: no flow goes directly between two external entities or two data stores; every process has at least one input and one output; every data store is both written and read somewhere in the set; and each level balances with its parent (every external entity and every boundary flow of the parent appears in the child, with the same name, and the child adds no new external entities).

3. Context diagram (level 0)

Hitchpost as one process, with everything it exchanges data with.

The outside A2A agent is a personal agent Hitchpost didn't build (FR-MSG-01). It talks to the business side directly, so its flows enter P2 and P4 at level 1, bypassing our own personal agent's P1 and P3.

4. Level 1 DFD

The v1 system broken into its major processes. Every level-0 entity and flow appears here.

Process	What it does	Implemented by	Status
P1	Validates the person's request, resolves the agent card, sends the request	Personal agent, `askForSlot`	Built (resolves by URL; directory Phase 3)
P2	Validates the request, applies hold caps, finds the first free slot, stores and replies with an offer; releases a hold on `offer_declined`	Business agent, `BarberExecutor`, `findFreeSlot`	Built (offer storage, caps Phase 2)
P3	Shows only validated fields, records approve or decline, creates an `Approval`, verifies the confirmation, writes the calendar	Personal agent, approval gate	Phase 2 (calendar write Phase 4)
P4	Checks and reserves the offer, waits for the shop if needed, rechecks and writes the booking	Business agent, booking handler	Phase 2
P5	Registers, verifies and updates listings	Directory service	Phase 3
P6	Builds interaction records from both sides' logs, accepts reviews	Ratings service	Phase 5
P7	Takes reports, gives the operator the queue and audit trail, suspends or restores listings	Directory admin	Phase 5 to 6

Processes are logical. Which container runs each one is in 10; one container can run several processes.

Store	Holds	Owner	Status
DS1	Issued offers with `issuedAt`, `expiresAt` and state	Business agent	Phase 2
DS2	Bookings as time ranges	Business agent or shop system	Built in memory (`Book.booked`)
DS3	Append-only audit events, with correlation fields	Each side keeps its own	Phase 2
DS4	Directory listings	Directory	Phase 3
DS5	Interaction records attested by both sides' matching audit hashes (signatures Phase 6)	Ratings service	Phase 5
DS6	Reports and moderation actions	Directory	Phase 5 to 6
DS7	Services and opening hours	Business agent	Built in memory (`Book.services`, `Book.hours`)

5. Level 2 DFD: P4 Book appointment

Booking is the first process that commits a person's time, so it gets one more level of detail. This diagram decomposes P4 only: every flow crossing its boundary is one of P4's level-1 flows, shown with its level-1 source or destination, and no new external entity appears.

P4.4 rechecks the slot and writes the booking in one transaction, so two requests for the same slot cannot both pass, even after a shop's manual wait (NFR-REL-02). P4.2 is idempotent: a resent request for an offer that already has a Task gets a new Task that completes at once with the original result and `duplicateOf` (BR-18). P4.6 checks the `bookingToken` and the shop's cancellation cutoff (P-10) before cancelling. A reschedule is not part of P4: it is a question answered by P2 with an offer carrying `replacesBookingId`, and the swap happens in P4.4 when that offer is booked. See the decision table in §7.2.

6. Business rules catalogue

ID	Rule	Requirement	Where enforced	Status
BR-01	A slot may be offered only if it starts inside the requested window, not before now, on a 30-minute boundary, and the whole service fits inside opening hours.	FR-BOOK-04	`findFreeSlot` in `packages/barber-agent/src/book.ts`	Built (UTC; shop-local Phase 6)
BR-02	A slot may not be offered if its time range overlaps any booked range or any Held or Reserved offer.	FR-BOOK-04, FR-BOOK-01	`findFreeSlot` overlap check; holds Phase 2	Built (bookings), Phase 2 (holds)
BR-03	An availability window must be strictly positive and no longer than the maximum search window (P-06).	FR-MSG-07, NFR-PERF-02	`parseAvailabilityRequest`, `MAX_WINDOW_DAYS` in `packages/core/src/booking.ts`	Built
BR-04	All instants must be strict ISO 8601 with an explicit zone and a real calendar day; they are stored as canonical UTC.	FR-MSG-06	`toInstant` in `packages/core/src/booking.ts`	Built
BR-05	A requesting agent accepts an offer only if its service equals the requested service and its start lies within `[earliest, latest]` inclusive.	FR-MSG-04	`offerMatches` in `packages/core/src/booking.ts`, `askForSlot`	Built
BR-06	An offer is Held from `issuedAt` until `expiresAt` (offer hold, P-01) and can be used for at most one booking. The business clock decides expiry; the personal agent treats it as expired the clock margin (P-09) before its own local deadline.	FR-BOOK-01, FR-BOOK-02	Offer store, booking handler, approval gate	Phase 2

ID	Rule	Requirement	Where enforced	Status
BR-07	An approval names exactly one `offerId` (the `contextId` is recorded with it for correlation only), is created only by the approval gate, and expires with its offer.	FR-GATE-02, FR-GATE-04	`Approval` type and `bookOffer(approval)`	Phase 2
BR-08	Nothing commits a person (time, money, personal data) without that person's explicit approval.	FR-GATE-01	Approval gate; the only booking path takes an `Approval`	Phase 2 (nothing books today)
BR-09	Opening hours count as the owner's standing approval unless the shop turns on manual approval. On manual approval the offer is Reserved and the booking Task stays `WORKING` until the owner decides, at most the manual approval wait (P-03), then `booking_rejected` `shop_timeout`.	FR-GATE-05	Booking handler	Phase 2
BR-10	A booking may be cancelled only by a request presenting its `bookingToken`, and only until the shop's cancellation cutoff (P-10); a cancel inside the cutoff ends in `cancel_rejected` with reason `cutoff`, and a wrong or missing token in `cancel_rejected` with reason `unknown_booking`.	FR-BOOK-03	Booking handler	Phase 2
BR-11	A reschedule is a `reschedule_request` Message presenting the `bookingToken`, answered with an offer carrying `replacesBookingId`, `no_availability`, or `rejected` with reason `cutoff`. The cutoff (P-10) is checked at the question and again at the swap (`booking_rejected` with reason `cutoff`), so a reschedule can never cancel a booking that a direct cancel would refuse. The old booking is cancelled in the same transaction that confirms the new one, so a failed reschedule leaves it intact.	FR-BOOK-03	Offer issuer (question), booking handler (swap)	Phase 2
BR-12	A listing is published only after its owner proves control of the agent card's origin, and the card's interface URL must share that origin. Hosted agents each have their own subdomain, so origins are never shared (Phase 6).	FR-DIR-01, FR-DIR-03	Directory verification worker	Phase 3
BR-13	Changing a listing's card URL resets it to unverified.	FR-DIR-01, FR-DIR-04	Directory API `PATCH`	Phase 3
BR-14	An interaction can be rated only if it is a verified interaction (both sides logged the offer and a matching decision, and the booking reached Completed or NoShow); each side rates it at most once.	FR-RATE-01	Rating ingest	Phase 5
BR-15	Text shown to a person must respect the text limit (P-19).	NFR-SEC-05	`SAFE_TEXT` in `packages/core/src/booking.ts`	Built
BR-16	A suspended listing disappears from search immediately; the business is told the reason and can appeal.	FR-ADMIN-01	Directory admin	Phase 6
BR-17	No sender (client IP until Phase 6, agent identity after) may hold more than the open holds cap (P-07); beyond it the business answers `rejected` and issues no hold. There is no per-`contextId` cap, because clients choose `contextId`. A declined offer (`offer_declined`) releases its hold at once.	FR-BOOK-01, NFR-SEC-03	Offer store	Phase 2
BR-18	A resent `booking_request` for an offer that already has a Task never creates a second booking: the new Task completes at once with the original result plus `duplicateOf: <original taskId>`. A client that holds the `taskId` retries with `GetTask` instead (the SDK refuses a send naming a finished task, `server/index.js:2789`). `cancel_request` works the same way through `bookingId → taskId`.	NFR-REL-02	Booking handler (`offerId → taskId`, `bookingId → taskId`)	Phase 2
BR-19	Authority comes from server-minted secrets, not from `contextId`, which the client chooses (`server/index.js:2815`): `offerId` authorises `booking_request` and `offer_declined` for that offer; `bookingToken` authorises `cancel_request` and `reschedule_request` for that booking. Until agent authentication (Phase 6) both are bearer capabilities: logged as hashes, never shown or put in a URL.	FR-GATE-02, NFR-SEC-01	Offer store, booking handler	Phase 2

7. Decision tables

Each table is complete: every combination of conditions maps to exactly one action. A dash means "any value". Rules are evaluated left to right; the first column that matches wins.

7.1 Can this slot be offered? (BR-01, BR-02, BR-17)

Rule	1	2	3	4	5	6	7
Service exists in the book	N	Y	Y	Y	Y	Y	Y
Sender under the hold cap (P-07)	-	N	Y	Y	Y	Y	Y
Start is in the window and not before now	-	-	N	Y	Y	Y	Y
Shop open that day, service fits before close	-	-	-	N	Y	Y	Y
Overlaps a booking	-	-	-	-	Y	N	N
Overlaps a Held or Reserved offer (Phase 2)	-	-	-	-	-	Y	N
Action	Reply `no_availability`	`rejected`	Try next slot	Try next slot	Try next slot	Try next slot	**Offer this slot**

If the search reaches `latest` without an action of "offer", the reply is `no_availability`. Rule 1 matches today's code, which answers `no_availability` for an unknown service. Rule 2 is Phase 2.

7.2 Accept a `booking_request`? (BR-06, BR-07, BR-09, BR-18, BR-19; Phase 2)

Rule	1	2	3	4	5	6	7	8	9	10	11
Request valid (shape, contract extension header)	N	Y	Y	Y	Y	Y	Y	Y	Y	Y	Y
Offer already has a Task	-	Y	N	N	N	N	N	N	N	N	N
`offerId` issued by this business	-	-	N	Y	Y	Y	Y	Y	Y	Y	Y
Offer Held and unexpired	-	-	-	N	Y	Y	Y	Y	Y	Y	Y
Offer replaces a booking and the swap is past the cutoff (P-10)	-	-	-	-	Y	N	N	N	N	N	N
Shop requires manual approval	-	-	-	-	-	N	N	Y	Y	Y	Y
Owner decision by `reservedUntil` (P-03)	-	-	-	-	-	-	-	Approve	Approve	Decline	None
Slot free at write (recheck)	-	-	-	-	-	Y	N	Y	N	-	-
Action	`rejected`	New Task returns the original result with `duplicateOf`	`unknown_offer`	`expired`	`cutoff`	**Confirm**	`slot_taken`	**Confirm**	`slot_taken`	`shop_declined`	`shop_timeout`

Rule 1 covers a missing `A2A-Extensions` header too: the SDK refuses the send with `ExtensionSupportRequiredError` before the executor runs (`server/index.js:2775-2781`). Actions other than "Confirm" and the duplicate rule end the Task `REJECTED` with a `booking_rejected` of that reason. In rules 8 to 11 the offer is Reserved while the owner decides, so a recheck can only fail if the shop's own booking system took the slot outside Hitchpost (a walk-in, for example). A confirmed reschedule (rules 6 and 8 with `replacesBookingId`) cancels the old booking in the same transaction.

7.3 Can this interaction be rated? (BR-14; Phase 5)

Rule	1	2	3	4	5
Rater was a party to the interaction	N	Y	Y	Y	Y
Both sides' audit hashes of the offer and the decision match (Phase 5; signatures Phase 6)	-	N	Y	Y	Y
Booking reached Completed or NoShow	-	-	N	Y	Y
Rater already rated it	-	-	-	Y	N
Action	Refuse	Refuse	Refuse until final	Refuse (one rating per side)	**Accept rating**

8. State machines

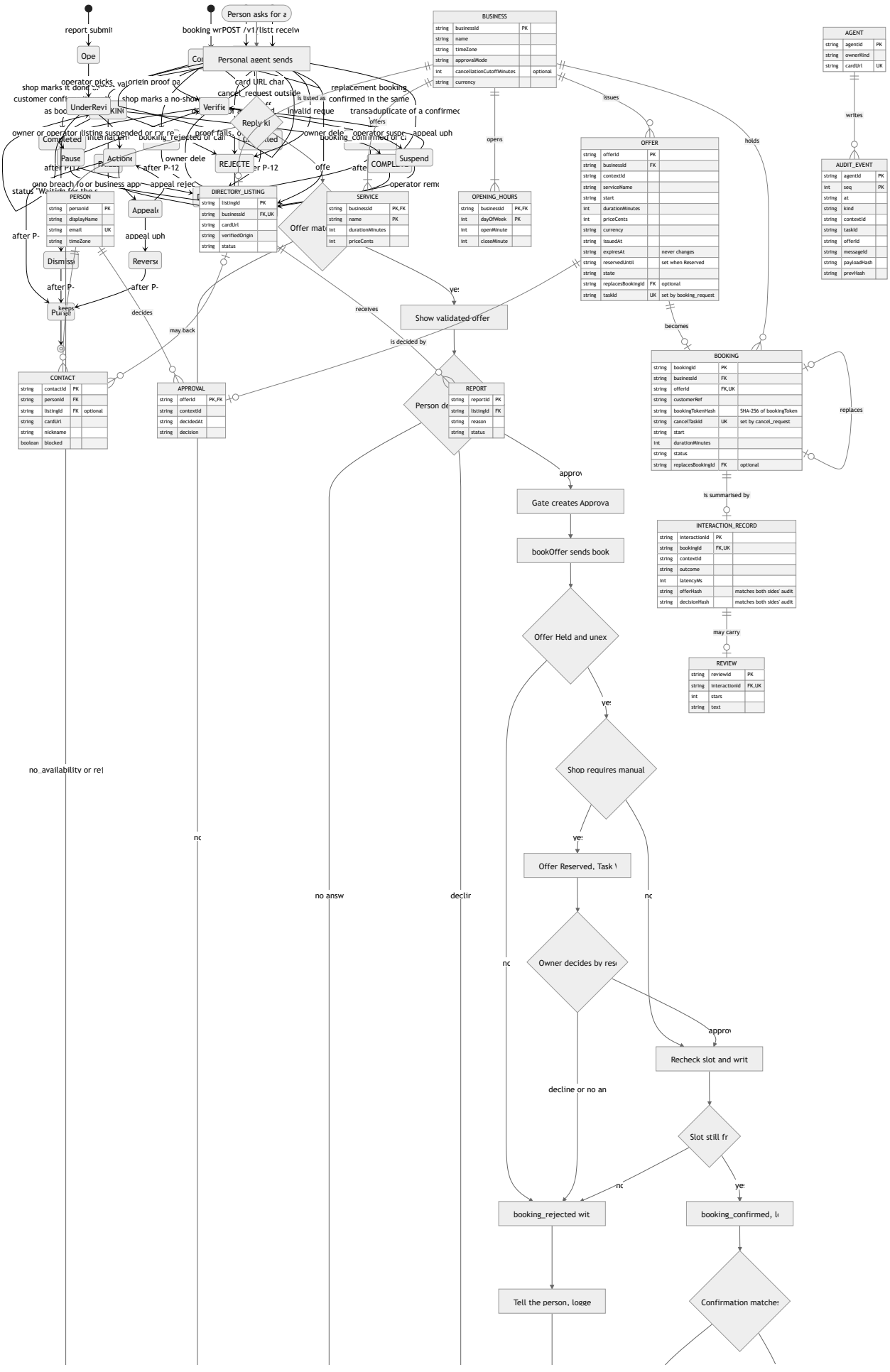
The state names below are the enumeration values `OfferState`, `BookingStatus` and `ListingStatus` used in 09 Data dictionary.

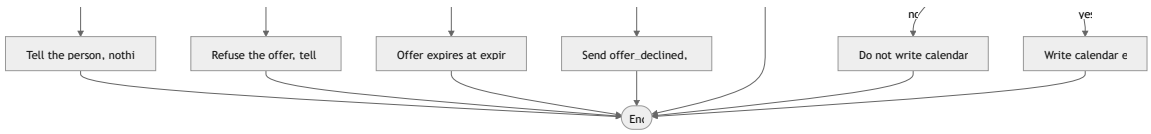
8.1 Offer (business side; Phase 2)

Held and Reserved offers block slots (BR-02). A Reserved offer keeps its `expiresAt` unchanged, because it is part of the offer the person approved and of the offer's audit hash; the reservation runs to its own `reservedUntil` (acceptance time + P-03). Booked offers are kept as part of their booking's record. Today an offer exists only as a message; nothing is stored (Built as message, Phase 2 as state).

8.2 Booking (Phase 2)

A booking exists only once it has been written; the wait for a shop's decision belongs to the offer (Reserved), not the booking.


report submit
booking wr
POST /v1/listt receiv
Person asks for a
Ope
Personal agent sends
BUSINESS
businessId PK
name
timeZone
approvalMode
cancellationCutoffMinutes optional
currency
AGENT
agentId PK
ownerKind
cardUrl UK
writes
issues
holds
opens
offers
OFFER
offerId PK
businessId FK
contextId
serviceName
start
durationMinutes
priceCents
currency
issuedAt
expiresAt never changes
reservedUntil set when Reserved
state
replacesBookingId FK optional
taskId UK set by booking_request
AUDIT_EVENT
agentId PK
seq PK
at
kind
contextId
taskId
offerId
messageId
payloadHash
prevHash
operator picks
origin proof pa
card URL char
cancel_request outside
is listed as
replacement booking
confirmed in the same
shop marks it done
customer confi
shop marks a no-show
UnderRevi
Verifie
Reply ki
invalid reque
transa duplicate of a confirmed
owner or operator listing suspended or rar re
proof fails
owner dele
operator suspe
appeal uph
Completed
booking_rejected or Can
booking_confirmed or Ca
Pause
Actione
owner dele
REJECTE
Suspend
after P-12
offe
COMPL
operator rem
ono breach fo or business app
appeal rejec
status Waitin for the s
PERSON
personId PK
displayName
email UK
timeZone
Appeale
DIRECTORY_LISTING
listingId PK
businessId FK,UK
cardUrl
verifiedOrigin
status
Offer mat
SERVICE
businessId PK,FK
name PK
durationMinutes
priceCents
OPENING_HOURS
businessId PK,FK
dayOfWeek PK
openMinute
closeMinute
after P-
appeal uph
Dismissi
Reverse
after P-
Pu sc
keeps
decides
receives
Show validated offer
may back
is decided by
becomes
BOOKING
bookingId PK
businessId FK
offerId FK,UK
customerRef
bookingTokenHash SHA-256 of bookingToken
cancelTaskId UK set by cancel_request
start
durationMinutes
status
replacesBookingId FK optional
replaces
CONTACT
contactId PK
personId FK
listingId FK optional
cardUrl
nickname
blocked
APPROVAL
offerId PK,FK
contextId
decidedAt
decision
Person de
REPORT
reportId PK
listingId FK
reason
status
is summarised by
INTERACTION_RECORD
interactionId PK
bookingId FK,UK
contextId
outcome
latencyMs
offerHash matches both sides' audit
decisionHash matches both sides' audit
may carry
REVIEW
reviewId PK
interactionId FK,UK
stars
text
appro
Gate creates Approva
bookOffer sends book
Offer Held and unex
ye
Shop requires manual
ye
Offer Reserved, Task
Owner decides by res
appro
Recheck slot and writ
decline or no an
Slot still fr
nc
ye
booking_rejected wit
booking_confirmed, l
Tell the person, logge
Confirmation matche
no_availability or rej
nc
no answ
declir
nc
nc



Completed is what the north star counts as "honored" (01). A shop-side cancellation of a Confirmed booking is Later: `hitchpost/1` has no business-to-person push.

8.3 A2A booking Task (Phase 2, ADR 0012)

The SDK's task states, as Hitchpost uses them for `booking_request` and `cancel_request`. `reschedule_request` is a question answered by a Message, so it has no Task. A resent request for an offer or booking that already has a Task gets a new Task that goes straight from SUBMITTED to the original final state, carrying `duplicateOf` (BR-18).

`INPUT_REQUIRED` is deliberately not used for the shop's decision: in A2A it asks the *client* for input, and SDK 1.3 stops draining executor events at that state (`server/index.js:2181`). The personal agent sends with `returnImmediately: true` and polls `GetTask` until a final state or its booking deadline (P-04). It treats `FAILED` and a missed deadline as "not booked" and tells the person so; it never assumes success (FR-GATE-01).

8.4 Directory listing (Phase 3)

Only `Verified` listings appear in search (BR-12, BR-16).

8.5 Report (Phase 5 to 6)

9. Activity diagram: approve and book (UC-02, UC-03)

10. Event list

ID	Event	Type	Trigger	Process	Response	Status
E-01	Person asks for availability	External	Person	P1, P2	Offer, `no_availability` or `rejected`	Built

ID	Event	Type	Trigger	Process	Response	Status
E-02	Outside agent sends a message	External	Any A2A agent	P2, P4	Validated reply or `rejected`	Built
E-03	Person approves an offer	External	Person	P3, P4	Booking confirmed or rejected	Phase 2
E-04	Person declines an offer	External	Person	P3, P2	`offer_declined` sent; hold released at once; decision logged	Phase 2
E-05	Owner decides a manual booking	External	Business owner	P4	Task completes or is rejected `shop_declined`	Phase 2
E-06	Person cancels or reschedules	External	Person	P4 (cancel), P2 (reschedule question)	`cancelled` or `cancel_rejected`; for a reschedule, an offer with `replacesBookingId`, `no_availability` or `rejected` `cutoff`	Phase 2
E-07	Offer reaches `expiresAt`	Temporal	Clock, offer hold (P-01)	P2	Hold released, offer Expired	Phase 2
E-08	Manual approval wait ends	Temporal	Clock, manual approval wait (P-03)	P4	Offer Released; `booking_rejected` `shop_timeout`	Phase 2
E-09	Appointment time passes	Temporal	Clock	P4, P6	Shop asked to mark the outcome (Phase 4); customer asked "Did it go as booked?" (Phase 5)	Phase 4
E-10	Business registers or edits a listing	External	Business owner	P5	Listing pending, verification started	Phase 3
E-11	Agent card refresh finds origin changed	Temporal	Daily card refresh	P5	Listing back to pending	Phase 3
E-12	Person submits a rating or review	External	Person	P6	Accepted or refused per §7.3	Phase 5
E-13	Someone reports a listing	External	Person or agent	P7	Report opened	Phase 5
E-14	Retention period ends	Temporal	Daily job	All	Delete per P-11 to P-14 (08 §5)	Phase 6
E-15	Outcome reported	External	Shop (dashboard) or customer	P4, P6	Booking Completed or NoShow; interaction becomes ratable	Phase 4

Revision history

Version	Date	Change	Author
1.0	2026-11-09	First baseline	S. Jannisar
1.1	2026-11-09	Remediation after independent review: balanced level 1 and level 2 DFDs, Reserved offer state, WORKING instead of input-required, recheck at write, idempotency, hold caps, context binding (BR-17 to BR-19), Booking NoShow and Completed, E-15, P-IDs	S. Jannisar
1.2	2026-11-09	Second remediation after regrade: cancel, reschedule and outside-agent `offer_declined` flows in the DFDs (P4.6 added at level 2); BR-17 to BR-19 rebuilt on SDK behaviour (per-sender cap, `duplicateOf`, `offerId` and `bookingToken` capabilities); reschedule cutoff in BR-11 and decision table 7.2; `reservedUntil`; Paused listing transitions; Phase 5 attestation by matching audit hashes	S. Jannisar

HP-SAD-08 · Data design

Field	Value
Document ID	HP-SAD-08
Version	1.2
Status	Baselined for Phase 2
Date	2026-11-09
Owner	Sanaullah Jannisar, product and engineering lead
Conforms to	IEEE 1016-2009 (information and logical viewpoints); ISO/IEC/IEEE 29148 (logical database requirements)

The entities Hitchpost handles, who owns each, where it is stored in each phase, how long it is kept and how sensitive it is. Attribute types and limits are defined once in 09 Data dictionary; timing and retention values are normative parameters (P-IDs) in 00 Document control.

1. Entity relationship model

Keys: `PK` primary key, `FK` foreign key, `UK` unique. Cardinalities match the dictionary in 09. Entities live in different stores (see §2), so a foreign key that crosses a store boundary is a logical reference, not a database constraint; those are marked "logical" in §3.

`AgentCard` is not stored as a row: each agent serves its own card at `/.well-known/agent-card.json` (Built, `barberCard()` in `packages/barber-agent/src/server.ts`); the directory keeps only `cardUrl` and the verified origin.

2. Entities

Entity	Owner (stores it)	Privacy class	Status	Notes
Person	Personal side (app)	Personal	Phase 4	Never sent to business agents beyond what a booking needs (NFR-PRIV-01).
Business	Business agent; public subset in the directory	Public	Phase 2 (agent), Phase 3 (directory)	`approvalMode`, `cancellationCutoffMinutes` (P-10) live with the agent.
Agent	Each agent publishes its own card	Public	Built	Card in `barberCard()`.
Service, OpeningHours	Business agent	Public	Built (as `Book`)	`Book.services`, `Book.hours` in `book.ts`. Hours become minutes of the local day in Phase 6 (ADR 0018).
Booking	Business agent	Personal	Built (as `Book.booked`, time ranges)	Phase 2 adds `bookingId`, `status`, `customerRef`, `replacesBookingId`, and `bookingTokenHash` (the `bookingToken` itself is never stored).
Offer	Business agent stores; personal agent keeps a copy	Personal	Phase 2	Built only as a message type (`Offer` in `core/src/booking.ts`). FR-BOOK-01.
Approval	Personal agent only	Personal	Phase 2	Never leaves the personal side; the business sees only `booking_request` or `offer_declined`. FR-GATE-02.
AuditEvent	Each side, own log	Personal	Phase 2	Append-only, correlation ids from Phase 2. FR-GATE-03.
DirectoryListing	Directory	Public	Phase 3	FR-DIR-01..03.
Contact	Personal side (app)	Personal	Phase 4	Listing link optional: contacts added by URL have none. FR-APP-01.
InteractionRecord	Ratings service, built from both sides' logs	Personal (pseudonymous)	Phase 5	One per booking; outcome includes `no_show`. Accepted only when both sides' audit hashes of the offer and the decision match (Phase 5); signatures added in Phase 6 (ADR 0017). FR-RATE-02.
Review	Ratings service	Public text, personal author	Phase 5	Only on a verified interaction. FR-RATE-01.
Report	Directory	Personal (reporter)	Phase 5 to 6	FR-ADMIN-01.

No entity holds payment data before a payments ADR. Calendars are never copied: the personal agent writes one event and keeps only the booking reference (NFR-PRIV-01).

3. Integrity rules

Rule	Enforced where	Status
No two bookings overlap in a business's book	`findFreeSlot` overlap check (Built); Phase 6 `slot_claims` exclusion constraint (§4)	Built (search), Phase 6 (database)
Held and reserved offers count as taken	Offer store consulted by slot search; re-checked inside the booking write transaction	Phase 2
A booking needs an unexpired offer issued by this business (the `offerId` is the capability; `contextId` is not checked)	Booking handler, one transaction: read offer, re-check slot, write booking	Phase 2
One booking per offer; a resent `booking_request` gets the original result with `duplicateOf`	`UK` on `Booking.offerId` and `Offer.taskId`	Phase 2
Cancel and reschedule need the booking's `bookingToken`	Compare SHA-256 of the presented token with `bookingTokenHash`	Phase 2
Open holds per sender are capped (P-07)	Offer store count before issuing	Phase 2
An Approval names exactly one offer and is made before the local deadline	`Approval` type, created only by the gate; deadline per P-09	Phase 2
Audit events are never updated or deleted, except by retention (P-12)	Append-only interface; `seq` monotonic; `prevHash` chain	Phase 2 (chain Phase 6)
A review needs a verified interaction	Ratings ingest	Phase 5
A listing's card URL origin equals its verified origin	Directory on register and on every card refresh	Phase 3
All instants stored in UTC	`toInstant` in `core/src/booking.ts`	Built
Shop hours in the shop's IANA zone	ADR 0018	Phase 6
The shop's own `Book` configuration is valid (hours, unique services, currency, parseable booked ranges)	Validation at load; invalid config refuses to start (D-15)	Phase 2
`Contact.listingId`, `Booking.customerRef`, cross-store `FK`s	Logical references, checked by the owning service; no cross-store constraint	Phase 3 to 5

4. Storage by phase

Phase	Storage	Why
1 (Built)	In memory (`Book` object passed to `BarberExecutor`); `InMemoryTaskStore`	Nothing to persist yet (ADR 0011).
2	**Business side:** SQLite file holding the SDK's `DatabaseTaskStore` tables (created with `a2a-db`) plus `offers`, `bookings`, `audit_events`. **Personal side:** append-only JSONL audit file.	Bookings and audit survive a restart from Phase 2 (NFR-REL-02); no server to run.
3	Postgres for the directory	Search, uniqueness, verification state.
4	Postgres for app accounts and contacts; the browser holds nothing sensitive beyond the session	One database to operate.
5	Postgres tables for interaction records and reviews	Same.
6	Postgres for hosted business agents, with the `slot_claims` table below; the shop's own booking system over MCP when it has one	Multi-instance hosting needs a database-level guarantee.

Phase 6 concurrency guarantee. Holds and bookings share one table, so no two can overlap even with several instances serving one shop:

```
CREATE TABLE slot_claims (
  business_id text NOT NULL,
  claim_id    text NOT NULL,          -- offerId for a hold, bookingId for a booking
  kind        text NOT NULL,          -- 'hold' | 'reserved' | 'booking'
  during      tstzrange NOT NULL,
  expires_at  timestamptz,            -- null for bookings
  PRIMARY KEY (business_id, claim_id),
  EXCLUDE USING gist (business_id WITH =, during WITH &&)
);
```

Expired holds are deleted by the expiry job before a new claim is tried, and the insert is retried once. When the shop uses its own booking system over MCP (FR-BOOK-06), the write to that system must be conditional (fails if the slot is taken); a connector that cannot do that is not supported (17 Transition plan).

5. Retention

Data	Parameter	Then
Expired or declined offers	P-11	Deleted
Bookings, audit events, interaction records	P-12	Deleted; aggregate counts without personal fields kept
Person, contacts and their personal data after account deletion	P-13	Erased, including from backups as they expire (P-15)
Resolved reports	P-14	Deleted
Reviews	Until the author deletes them or the listing closes	Deleted
Backups	P-15	Expire; no separate cold-storage export exists

The retention job (event E-14 in 07) applies these daily. 12 Security and privacy records the lawful basis for each.

6. Migrations

- SQL migrations in each service (`packages/<service>/migrations/NNNN_name.sql`), applied by CI on deploy, forward only. Phase 2 SQLite uses the same files where the SQL is portable.
- Expand then contract: add new columns or tables, deploy code that writes both, backfill, then remove the old shape in a later release.
- Message shapes on the wire follow the versioning rules in 13; stored data never depends on a field a peer may stop sending.
- The A2A SDK ships the `a2a-db` CLI for its task tables; run it as one migration step.

Revision history

Version	Date	Change	Author
0.1	2026-11-08	First draft	S. Jannisar
1.0	2026-11-09	Baselined: renumbered into lifecycle order, formal document control, standards conformance	S. Jannisar
1.1	2026-11-09	Remediation after independent review: ERD with keys, retention via P-IDs, SQLite/JSONL in Phase 2, `slot_claims` exclusion table, time zones Phase 6	S. Jannisar
1.2	2026-11-09	Second remediation after regrade: `reservedUntil` on Offer (`expiresAt` never changes); `bookingTokenHash` and `cancelTaskId` on Booking; interaction record hashes for Phase 5 attestation; integrity rules use capabilities and a per-sender hold cap instead of `contextId`	S. Jannisar

HP-SAD-09 · Data dictionary

Field	Value
Document ID	HP-SAD-09
Version	1.2
Status	Baselined for Phase 2
Date	2026-11-09
Owner	Sanaullah Jannisar, product and engineering lead
Conforms to	ISO/IEC 11179 (metadata registry naming principles), ISO/IEC 25012 (data quality model), ISO 8601, ISO 4217

1. Purpose and scope

This is the authoritative definition of every data element in Hitchpost: entities from the domain model in 08 Data design and fields of the agent message contract in 13 Interfaces. Where a field is Built, its type and limits here match `packages/core/src/booking.ts` exactly; if the two ever disagree, the code is the defect and this dictionary is the specification.

2. Naming conventions

Rule	Example
Fields are `camelCase` on the wire and in TypeScript; `snake_case` in SQL columns	`durationMinutes` / `duration_minutes`
Message `kind` values and enumerations are `snake_case` strings	`availability_request`, `slot_taken`
Units go in the name, never implied	`durationMinutes`, `priceCents`, `latencyMs`
Instants end with a verb form or `At`, and are always UTC on the wire	`start`, `expiresAt`, `decidedAt`
Identifiers end in `Id` and are opaque strings; nobody parses meaning out of them	`offerId`, `bookingId`
Money is an integer number of minor units plus an ISO 4217 code; never a float	`priceCents: 3000`, `currency: "USD"`
Entities are singular nouns (`Booking`); stores and tables are plural (`bookings`)	

3. Shared data types

Type	Definition	Enforced by (Built)
`Instant`	String, strict ISO 8601 `YYYY-MM-DDTHH:mm`, with optional `:ss` and optional 1 to 3 fractional digits, zone `Z` or `±hh:mm`. Hours 00 to 23 (no `24:00` rollover), minutes and seconds 00 to 59, offsets within -14:00 to +14:00, real calendar day. Normalised to UTC `YYYY-MM-DDTHH:mm:ss.sssZ`.	`ISO_INSTANT`, `toInstant`
`SafeText`	String of 1 to 200 characters, none in Unicode category C (control, format, surrogate, private use, unassigned).	`SAFE_TEXT = /^[^\p{C}]{1,200}$/u`
`Token`	Server-minted secret: 128 random bits, base64url without padding (22 characters). Stored only as a SHA-256 hash; logged only as that hash.	Phase 2 (booking handler)
`Id`	`SafeText` used as an opaque identifier. Generated values are UUID v4 (`crypto.randomUUID()`).	`isSafeText`; generator in `executor.ts`
`Minutes`	Safe integer, 1 to 1,440 (P-20).	`isCount(v, 1, MAX_DURATION_MINUTES)`
`Cents`	Safe integer, 0 to 10,000,000 (P-20).	`isCount(v, 0, MAX_PRICE_CENTS)`
`Currency`	Three capital letters `/^[A-Z]{3}$/` (ISO 4217 shape; not checked against the code list).	`parseBarberReply`
`IanaZone`	IANA time zone name, for example `America/Chicago`.	Phase 6 (ADR 0018)
`Url`	Absolute `https` URL (plain `http` allowed only for `127.0.0.1` in development).	Phase 3

4. Message contract elements

All messages travel as A2A data parts with `mediaType: application/json` and a required `kind`. Unknown fields are dropped on receipt (FR-MSG-03).

4.1 `availability_request` (person to business, Built)

Field	Type	Required	Constraints	Example
`kind`	enum	Yes	`"availability_request"`	`"availability_request"`
`service`	`SafeText`	Yes	Must name a service the business offers to get an offer	`"haircut"`
`earliest`	`Instant`	Yes	`earliest < latest`	`"2026-11-12T17:00:00.000Z"`
`latest`	`Instant`	Yes	`latest − earliest ≤ 31 days` (P-06, `MAX_WINDOW_DAYS`)	`"2026-11-12T19:00:00.000Z"`

4.2 `offer` (business to person, Built; `issuedAt`, `expiresAt`, `replacesBookingId` Phase 2)

Field	Type	Required	Constraints	Example
`kind`	enum	Yes	`"offer"`	`"offer"`
`offerId`	`Id`	Yes	Unique per issuing business	`"3f6c…e21a"`
`service`	`SafeText`	Yes	Must equal the request's `service` (FR-MSG-04)	`"haircut"`
`start`	`Instant`	Yes	Within the request window, inclusive (FR-MSG-04)	`"2026-11-12T17:30:00.000Z"`
`durationMinutes`	`Minutes`	Yes	1 to 1,440	`30`
`priceCents`	`Cents`	Yes	0 to 10,000,000	`3000`
`currency`	`Currency`	Yes	`/^[A-Z]{3}$/`	`"USD"`
`issuedAt`	`Instant`	Phase 2	Business clock; authoritative for expiry	`"2026-11-12T16:40:00.000Z"`
`expiresAt`	`Instant`	Phase 2	`issuedAt` + P-01	`"2026-11-12T16:50:00.000Z"`
`replacesBookingId`	`Id`	No	Present only when answering a `reschedule_request`	`"b-7c1d"`

4.3 Other Built replies

Kind	Field	Type	Required	Example
`no_availability`	`service`	`SafeText`	Yes	`"haircut"`
`rejected`	`reason`	`SafeText`	Yes	`"expected a valid availability_request"`

4.4 Phase 2 kinds

Authority comes from server-minted secrets, not from `contextId`, which the client chooses (SDK `server/index.js:2815`): `offerId` authorises acting on an offer, `bookingToken` authorises acting on a booking. Until agent authentication (Phase 6) both are bearer capabilities (see 12). Clients send the contract extension uri `https://hitchpost.dev/ext/contract/v1` in the `A2A-Extensions` header, which is where the SDK checks it (`server/index.js:2775-2781`), and also list it in each message's `extensions`.

Kind	Field	Type	Required	Constraints
`booking_request`	`offerId`	`Id`	Yes	Starts a Task. A resent request without a `taskId` for an offer that already has a Task gets a new Task that completes at once with the original result plus `duplicateOf` (BR-18)
`offer_declined`	`offerId`	`Id`	Yes	Message; releases the hold at once
`booking_pending`	`offerId`	`Id`	Yes	Data part of the `WORKING` status message while the shop decides
	`reservedUntil`	`Instant`	Yes	Acceptance time + P-03; the offer's own `expiresAt` is unchanged
`booking_confirmed`	`bookingId`	`Id`	Yes	Unique per business; data part of the COMPLETED Task
	`bookingToken`	`Token`	Yes	Server-minted, 128-bit random, base64url (22 characters); required by `cancel_request` and `reschedule_request`
	`offerId`, `service`, `start`, `durationMinutes`, `priceCents`, `currency`	as in `offer`	Yes	Must equal the approved offer field for field
	`duplicateOf`	`Id`	No	Original `taskId`, present only on a resent request
`booking_rejected`	`offerId`	`Id`	Yes	Data part of the REJECTED Task
	`reason`	enum	Yes	`BookingRejectReason` (§6)
	`duplicateOf`	`Id`	No	As for `booking_confirmed`
`cancel_request`	`bookingId`, `bookingToken`	`Id`, `Token`	Yes	Starts a Task; a wrong or missing token is answered `cancel_rejected` `unknown_booking`; idempotent on `bookingId` like `booking_request`
`cancelled`	`bookingId`	`Id`	Yes	Data part of the COMPLETED Task; `duplicateOf` on a resent request
`cancel_rejected`	`bookingId`	`Id`	Yes	Data part of the REJECTED Task
	`reason`	enum	Yes	`CancelRejectReason` (§6)
`reschedule_request`	`bookingId`, `bookingToken`	`Id`, `Token`	Yes	Message (a question): answered with an `offer` carrying `replacesBookingId`, `no_availability`, or `rejected` with reason `cutoff` (P-10)
	`earliest`, `latest`	`Instant`	Yes	Same rules as `availability_request`

5. Entities

Privacy classes: **Public** (anyone may see), **Personal** (identifies or relates to a person), **Sensitive** (Personal and harmful if leaked, for example contact details). Owner is the system that stores the record.

5.1 Business-side entities

Entity.attribute	Type	Req	Constraints	Privacy	Owner	Source	Status
Service.name	`SafeText`	Y	Unique within a business	Public	Business agent	Owner setup	Phase 2 (D-15)
Service.durationMinutes	`Minutes`	Y		Public	Business agent	Owner setup	Built
Service.priceCents	`Cents`	Y		Public	Business agent	Owner setup	Built
Book.currency	`Currency`	Y	One per business	Public	Business agent	Owner setup	Phase 2 (D-15)
OpeningHours.dayOfWeek	integer 0–6	Y	0 = Sunday; UTC until Phase 6, then `Business.timeZone`	Public	Business agent	Owner setup	Built (`Book.hours`)
OpeningHours.open / close	integer 0–24	Y	Whole hours, half-open `[open, close)`; `open < close` not yet checked	Public	Business agent	Owner setup	Built (range check Phase 2, D-15); minutes of the local day Phase 6
Booking.start	`Instant`	Y	On the business's slot grid when created by Hitchpost	Personal	Business agent	Booking handler	Built (`Booking.start`)
Booking.durationMinutes	`Minutes`	Y	No overlap with any other booking (BR-02)	Personal	Business agent	Booking handler	Built
Booking.bookingId	`Id`	Y	Unique per business	Personal	Business agent	Booking handler	Phase 2
Booking.offerId	`Id`	Y	Unique: one booking per offer	Personal	Business agent	Booking handler	Phase 2
Booking.bookingTokenHash	string	Y	SHA-256 of the `bookingToken`; the token itself is never stored	Sensitive	Business agent	Booking handler	Phase 2
Booking.cancelTaskId	`Id`	N	Set by the first `cancel_request`; unique (idempotency)	Personal	Business agent	Booking handler	Phase 2
Booking.status	enum	Y	`BookingStatus` (§6)	Personal	Business agent	Booking handler	Phase 2
Booking.customerRef	`Id`	Y	Pseudonymous reference to the personal agent's context; deleted with the booking (P-12)	Personal	Business agent	Booking handler	Phase 2
Offer.offerId	`Id`	Y	Primary key	Personal	Business agent	Offer store	Phase 2
Offer.contextId	`Id`	Y	A2A context the offer was issued in; client-chosen, for correlation only, never an authority	Personal	Business agent	Offer store	Phase 2
Offer.(service … currency)	as §4.2	Y		Personal	Business agent	Offer store	Phase 2
Offer.issuedAt	`Instant`	Y	Business clock, authoritative for expiry	Personal	Business agent	Offer store	Phase 2
Offer.expiresAt	`Instant`	Y	`issuedAt` + P-01; never changes (part of the approved offer and its audit hash)	Personal	Business agent	Offer store	Phase 2
Offer.reservedUntil	`Instant`	N	Set when Reserved: acceptance time + P-03 (P-02); the reservation ends at this instant	Personal	Business agent	Booking handler	Phase 2
Offer.state	enum	Y	`OfferState` (§6)	Personal	Business agent	Offer store	Phase 2
Offer.taskId	`Id`	N	Set by the first `booking_request`; unique (idempotency)	Personal	Business agent	Booking handler	Phase 2
Offer.replacesBookingId	`Id`	N	Set when the offer answers a `reschedule_request`	Personal	Business agent	Offer store	Phase 2
Booking.replacesBookingId	`Id`	N	Booking this one replaced; old one cancelled in the same transaction	Personal	Business agent	Booking handler	Phase 2
Business.timeZone	`IanaZone`	Y		Public	Directory and business agent	Owner setup	Phase 6 (ADR 0018)
Business.approvalMode	enum	Y	`standing` (default) or `manual` (FR-GATE-05)	Public	Business agent	Owner setup	Phase 2
Business.cancellationCutoffMinutes	integer ≥ 0	N	Absent means no cutoff (P-10)	Public	Business agent	Owner setup	Phase 2

5.2 Person-side entities

Entity.attribute	Type	Req	Constraints	Privacy	Owner	Source	Status
Approval.offerId	`Id`	Y	Exactly one offer	Personal	Personal agent	Approval gate	Phase 2

Entity.attribute	Type	Req	Constraints	Privacy	Owner	Source	Status
Approval.contextId	`Id`	Y	The offer's context, recorded for correlation only (not an authority)	Personal	Personal agent	Approval gate	Phase 2
Approval.decidedAt	`Instant`	Y	Before the local deadline (P-09); personal clock only, never compared with the business clock	Personal	Personal agent	Approval gate	Phase 2
Approval.decision	enum	Y	`approved` or `declined`	Personal	Personal agent	Approval gate	Phase 2
Person.id	`Id`	Y		Personal	App	Sign-up	Phase 4
Person.displayName	`SafeText`	Y		Personal	App	Sign-up	Phase 4
Person.email	string	Y	RFC 5322 address, verified	Sensitive	App	Sign-up	Phase 4
Person.timeZone	`IanaZone`	Y	Times shown to the person use it	Personal	App	Device or setting	Phase 4
Contact.personId	`Id`	Y		Personal	App	Add contact	Phase 4
Contact.listingId	`Id`	N	Absent for an agent added by URL	Personal	App	Add contact	Phase 4
Contact.cardUrl	`Url`	Y		Personal	App	Add contact	Phase 4
Contact.nickname	`SafeText`	N		Personal	App	Person	Phase 4
Contact.blocked	boolean	Y	Default false (FR-APP-05)	Personal	App	Person	Phase 4

5.3 Shared and platform entities

Entity.attribute	Type	Req	Constraints	Privacy	Owner	Status
AuditEvent.seq	integer	Y	Strictly increasing per log	Personal	Each agent	Phase 2
AuditEvent.at	`Instant`	Y		Personal	Each agent	Phase 2
AuditEvent.kind	enum	Y	`AuditEventKind` (§6)	Personal	Each agent	Phase 2
AuditEvent.contextId / taskId / offerId / messageId / bookingId	`Id`	N	As applicable; all logged from Phase 2 for correlation	Personal	Each agent	Phase 2
AuditEvent.payloadHash	string	Y	SHA-256 hex over the JCS (RFC 8785) canonical JSON of the data part	Personal	Each agent	Phase 2
AuditEvent.prevHash	string	Y	SHA-256 of the previous event (hash chain)	Personal	Each agent	Phase 6
DirectoryListing.id	`Id`	Y		Public	Directory	Phase 3
DirectoryListing.businessName	`SafeText`	Y		Public	Directory	Phase 3
DirectoryListing.address	string	Y	Postal address, geocoded to lat/lng	Public	Directory	Phase 3
DirectoryListing.cardUrl	`Url`	Y	Origin must equal `verifiedOrigin` (BR-12)	Public	Directory	Phase 3
DirectoryListing.verifiedOrigin	`Url` origin	N	Set when proof passes	Public	Directory	Phase 3
DirectoryListing.status	enum	Y	`ListingStatus` (§6)	Public	Directory	Phase 3
AgentCard.(name, supportedInterfaces, skills, signatures)	per A2A v1.0	Y	Card at `/.well-known/agent-card.json`	Public	Each agent	Built (`barberCard()`)
InteractionRecord.contextId	`Id`	Y		Personal (pseudonymous)	Ratings	Phase 5
InteractionRecord.outcome	enum	Y	`InteractionOutcome` (§6)	Personal (pseudonymous)	Ratings	Phase 5
InteractionRecord.latencyMs	integer ≥ 0	Y	Request to reply	Personal (pseudonymous)	Ratings	Phase 5
InteractionRecord.offerHash / decisionHash	string	Y	Each equals the `payloadHash` both sides logged for the offer and the decision; the record is accepted only if both sides' hashes match	Personal (pseudonymous)	Ratings	Phase 5
InteractionRecord.signatures	list of JWS	N	Both parties' signatures over the record (ADR 0017)	Personal (pseudonymous)	Ratings	Phase 6
Review.interactionId	`Id`	Y	Needs a two-sided record (BR-14)	Personal	Ratings	Phase 5
Review.stars	integer 1–5	Y		Public	Ratings	Phase 5

Entity.attribute	Type	Req	Constraints	Privacy	Owner	Status
Review.text	string	N	0 to 1,000 characters, no control characters	Public text, personal author	Ratings	Phase 5
Report.listingId	`Id`	Y		Public	Directory	Phase 5
Report.reason	enum	Y	`ReportReason` (§6)	Personal	Directory	Phase 5
Report.details	string	N	0 to 1,000 characters	Personal	Directory	Phase 5
Report.status	enum	Y	`ReportStatus` (§6)	Personal	Directory	Phase 5

6. Enumerations

Enumeration	Values	Status
`MessageKind`	`availability_request`, `offer`, `no_availability`, `rejected` (Built); `booking_request`, `offer_declined`, `booking_pending`, `booking_confirmed`, `booking_rejected`, `cancel_request`, `cancelled`, `cancel_rejected`, `reschedule_request` (Phase 2)	Built / Phase 2
`BookingRejectReason`	`expired`, `unknown_offer`, `slot_taken`, `shop_declined`, `shop_timeout`, `cutoff` (a reschedule swap past the shop's cutoff, P-10), `other`	Phase 2
`CancelRejectReason`	`cutoff`, `unknown_booking`, `other`	Phase 2
`OfferState`	`held`, `reserved`, `booked`, `declined`, `expired`, `released`, `purged` (states `Held` to `Purged` in 07 §8.1)	Phase 2
`BookingStatus`	`confirmed`, `cancelled`, `rescheduled`, `completed`, `no_show`, `deleted` (states in 07 §8.2; a pending shop decision is the Offer state `reserved`, not a Booking)	Phase 2 (`completed`, `no_show` recorded from Phase 4; `deleted` by the retention job)
`ApprovalMode`	`standing`, `manual`	Phase 2
`AuditEventKind`	One per state change (07 §8). Business side: `offer_issued`, `offer_declined`, `offer_expired`, `offer_reserved`, `offer_released`, `shop_timeout`, `booking_confirmed`, `booking_rejected`, `booking_cancelled`, `cancel_rejected`, `booking_rescheduled`, `outcome_recorded`. Person side: `offer_received`, `approval_recorded` (with the decision, approved or declined), `booking_requested`, `cancel_requested`, plus the received `booking_confirmed`, `booking_rejected`, `booking_cancelled` and `cancel_rejected`. Every event carries the correlation fields	Phase 2
`InteractionOutcome`	`completed`, `no_show`, `cancelled`, `rejected`	Phase 5
`ListingStatus`	`pending`, `verified`, `paused`, `suspended`, `closed`	Phase 3
`ReportReason`	`impersonation`, `spam`, `misleading_offer`, `abusive`, `other`	Phase 5
`ReportStatus`	`open`, `under_review`, `actioned`, `dismissed`, `appealed`, `reversed`	Phase 5

State transitions for `OfferState`, `BookingStatus`, `ListingStatus` and `ReportStatus` are defined in 07 §8.

7. CRUD matrix

C = create, R = read, U = update, D = delete. Use cases from 06; the last three rows are operator and system processes.

Process	Business / Service / Hours	Offer	Approval	Booking	AuditEvent	Listing	Person	Contact	InteractionRecord	Review	Report
UC-01 Ask for availability	R	C		R	C	R		R			
UC-02 Approve and book	R	R U	C	C R	C						
UC-03 Decline or ask for another	R	C U	C	R	C						
UC-04 Reschedule or cancel	R	C U	C	R U	C						
UC-05 Register a business agent	C U					C U					
UC-06 Find a business agent						R				R	
UC-07 Add contact and chat						R	R	C U D			
UC-08 Rate an interaction				R U	R				C R	C U D	
UC-09 Report an agent						R					C
UC-10 Moderate					C	U D				U D	R U
Account sign-up, edit and deletion (Phase 4)					C		C U D	D		D	
Business owner setup and closing (Phase 2 to 3)	C U D				C	U D					
Retention job (E-14)		D	D	D	D				D		D

Every entity has a creating process and a deleting process, so nothing is collected without a path to removal (NFR-PRIV-02). `AgentCard` is served, not stored, so it has no row.

8. Data quality rules

Dimensions from ISO/IEC 25012.

ID	Dimension	Rule	Check	Status
DQ-01	Accuracy	Every instant is stored as canonical UTC with an explicit zone on input	`toInstant`; unit tests	Built
DQ-02	Consistency	No two bookings in one business overlap	`findFreeSlot`; Phase 6 database exclusion constraint	Built (search)
DQ-03	Consistency	`booking_confirmed` equals the approved offer field for field	Personal agent field check (Phase 2); also gates the calendar write	Phase 2 (check), Phase 4 (calendar write)
DQ-04	Completeness	Every booking has an offer, an approval and audit events on both sides, joined on `contextId` and `offerId`	Audit reconciliation job	Phase 2
DQ-05	Validity	Every inbound field passes its §3 type rule	Parsers in `booking.ts`	Built
DQ-06	Currentness	Expired, declined and released offers never block slots; open holds capped (P-07)	Slot search ignores them; offer store counts holds	Phase 2
DQ-07	Credibility	Only verified listings are searchable; only two-sided interactions are rated	Directory and rating ingest	Phase 3, 5
DQ-08	Traceability	Each booking can be followed end to end by `contextId`, `taskId`, `offerId` and `messageId`	Audit reconciliation; trace ids added in Phase 6	Phase 2 (ids), Phase 6 (traces)

Revision history

Version	Date	Change	Author
1.0	2026-11-09	First baseline	S. Jannisar
1.1	2026-11-09	Remediation after independent review: new kinds and fields, enums aligned to state machines, complete CRUD matrix, Book config constraints marked D-15, `toInstant` limits, time zones Phase 6	S. Jannisar
1.2	2026-11-09	Second remediation after regrade: `bookingToken` (new `Token` type, stored hashed) and `duplicateOf`; `booking_pending` with `reservedUntil` (`expiresAt` never changes); `cutoff` reject reason; reschedule as a Message; `contextId` for correlation only; extension in the `A2A-Extensions` header; `AuditEventKind` covers every state change; interaction records attested by matching hashes in Phase 5, signatures Phase 6	S. Jannisar

HP-SAD-10 · System architecture

Field	Value
Document ID	HP-SAD-10
Version	1.2
Status	Baselined for Phase 2
Date	2026-11-09
Owner	Sanaullah Jannisar, product and engineering lead
Conforms to	ISO/IEC/IEEE 42010:2022 (architecture description: views, viewpoints, rationale); C4 model notation

How Hitchpost is put together today, and how it grows to v1 (Phase 6) and beyond. Status labels follow 00 Document control: **Built**, **Phase N**, **Later**. Timing values are normative parameters (P-IDs) in 00; requirements are in 05 Requirements (functional in §5, non-functional in §6).

1. Drivers and constraints

Driver	Source	Architectural consequence
Interoperate with any A2A agent	NFR-INT-01, ADR 0003	A2A v1.0 on the wire, official `@a2a-js/sdk`. No private protocol between our own parts.
Never commit a person without their yes	FR-GATE-01..03, ADR 0007	The gate is a component of the *personal* agent, and the only producer of an `Approval` value.
Other agents are untrusted	NFR-SEC-01, ADR 0010	Every boundary parses and rebuilds input (`packages/core/src/booking.ts`). Free text never drives an action.
No double booking	FR-BOOK-01..02, NFR-REL-02	The business agent owns the book; holds and bookings are claimed in one transaction (§8).
Small team, one language	ADR 0002	TypeScript monorepo, Node 24, shared types in `@hitchpost/core`.
Responsive conversations	NFR-PERF-01 (p95 under 2 s per availability exchange)	Synchronous request and reply for availability; Tasks only where state must persist.
Directory uptime	NFR-REL-01 (99.5%)	Directory is a separate stateless service with its own database, so agents keep working peer to peer if it is down.
Data minimisation	NFR-PRIV-01	Agents share a free slot, never a calendar. Personal data stays on the person's side.

Constraints: open source under MIT (ADR 0004); Node type stripping, so only erasable TypeScript syntax (see bug log); no paid infrastructure before Phase 6; A2A SDK 1.3 behaviour (for example, it stops draining a task's events at `INPUT_REQUIRED`, `server/index.js:2181`).

2. Architecture description framework (ISO/IEC/IEEE 42010)

2.1 Stakeholders and concerns

Stakeholder	Key concerns
Dana (customer)	Nothing booked without her yes; correct times; her calendar stays private
Marcus (shop owner)	No double bookings; control over approvals; works with his booking tool
Priya (agent developer)	Stable, documented contract; fair verification; how to prove identity
Sam (operator)	Uptime, abuse handling, cost, recoverability
Maintainer (me)	Simplicity, testability, one language, safe evolution of the contract
Assessor or reviewer	Traceability from requirements to design to tests

2.2 Viewpoint catalogue

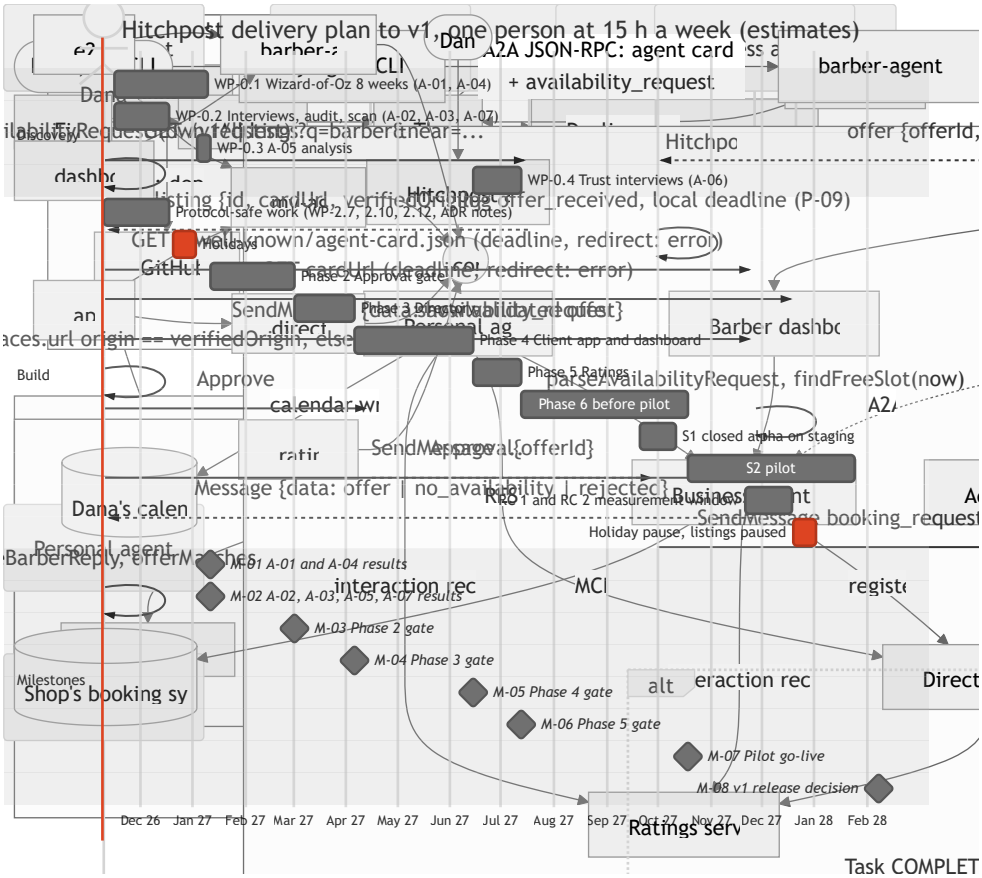
Viewpoint	Concerns framed	Stakeholders	Model kinds	View in this document
Context	Scope, external actors and systems, trust	All	C4 system context (Mermaid flowchart)	§3
Logical (containers)	Responsibilities, dependencies, ownership of data	Maintainer, Priya, assessor	C4 container table and dependency graph	§4
Component	Internal structure of each container	Maintainer	Component tables	§5
Behaviour (interaction)	Message order, failure paths, state across agents	Maintainer, Priya, Marcus	UML sequence diagrams; state machines in 07	§6
Deployment	Where things run, tenancy, keys, scaling	Sam, maintainer	C4 deployment diagram, option table	§7
Cross-cutting	Concurrency, time, identity, errors, observability, limits	All engineering	Rule tables	§8
Information	Entities, keys, retention	Maintainer, Sam, assessor	ERD in 08, dictionary in 09	external
Security	Trust boundaries, threats, controls	Sam, Dana, Marcus	Boundary diagram, STRIDE table in 12	external

2.3 Correspondence rules

ID	Rule	Checked by
CR-1	Every container in §4 appears in the deployment view (§7) or is marked test-only (`e2e`)	Review at each phase gate
CR-2	Every message in the §6 sequences is a kind defined in 13 Interfaces and 09 §4	Package consistency check
CR-3	Every state reached in a §6 sequence exists in the matching state machine in 07 §8	Review
CR-4	Every entity a component stores is in the ERD in 08 with the same owner	Review
CR-5	Every trust boundary crossed in §6 has threats in 12	Review
CR-6	Every timing value is a P-ID from 00, never a literal repeated across documents	Package consistency check

3. Context

Today (Phase 1, Built)



Both agents run on one machine, bound to `127.0.0.1` (`packages/barber-agent/src/server.ts`).

v1 (Phase 6)

4. Containers

Container	Responsibility	Status	Code
core	Message types, validators, A2A part helpers. No I/O.	Built	`packages/core/src/booking.ts`, `packages/core/src/a2a.ts`

Container	Responsibility	Status	Code
barber-agent (business agent host)	A2A server per business: agent card, availability, booking, cancel. Owns the book, offers and its audit log.	Built (availability only)	`packages/barber-agent/src/`
my-agent (personal agent)	Asks business agents, validates replies, runs the approval gate, polls booking Tasks, writes the calendar event.	Built (ask only)	`packages/my-agent/src/`
e2e	End-to-end tests that start several agents together. Replaces my-agent's dev dependency on barber-agent.	Phase 2	`packages/e2e/`
directory	Register, verify and search business agents. REST API. Hosts the admin console.	Phase 3	`packages/directory/`
dashboard (barber dashboard)	Web UI for shop owners: services, hours, approval mode, manual-approval queue, mark completed or no-show.	Phase 3 (setup), Phase 4 (queue and outcomes)	`packages/dashboard/`
app	Web client for people: contacts are agents, chat, approval sheet, bookings. Hosts the personal agent per person.	Phase 4	`packages/app/`
ratings	Builds interaction records from both sides' logs (accepted only when both sides' JCS hashes of the offer and decision match; signatures from Phase 6), computes behaviour metrics, accepts verified reviews.	Phase 5	`packages/ratings/`

Rule: `core` depends only on SDK *types*. Nothing depends on `e2e`. Services talk over A2A or REST, never by importing each other's internals; the dashboard uses the business agent host's owner API, the app hosts my-agent as a library.

5. Components

Business agent (barber-agent)

Component	Role	Status
`server.ts` `startBarberAgent(name, executor, port)`	Express app: agent card, JSON-RPC handler, JSON error handler, `x-powered-by` off	Built
`executor.ts` `BarberExecutor`	Parses the request, finds a slot, replies with one Message	Built
`book.ts` `findFreeSlot`	Slot search over time ranges, never in the past	Built
Book loader	Validates the shop's configuration at start (hours, unique services, currency, booked ranges); refuses to start if invalid (D-15)	Phase 2
Offer store	Offers with `issuedAt`, `expiresAt`, state and `taskId`; held and reserved offers count as taken; caps open holds (P-07)	Phase 2
Booking handler	`booking_request` → Task; idempotent on `offerId`; one transaction re-checks the slot and writes (§8)	Phase 2
Approval queue	Manual mode: Task stays `WORKING` with a "waiting for the shop" status until the owner decides or P-03 passes	Phase 2
Audit log	`append(event)` with `contextId`, `taskId`, `offerId`, `messageId`; SQLite table	Phase 2
Rate limiter	P-08 per client IP	Phase 2
Booking tool adapter	Replaces the local book with an MCP client to the shop's system; writes must be conditional	Phase 6

Personal agent (my-agent)

Component	Role	Status
`ask.ts` `askForSlot`	Card discovery and message under one deadline (P-05), no redirects, reply validated and matched	Built
`main.ts`	CLI; prints only validated fields and its own errors	Built
Approval gate	Shows the validated offer with a local deadline (P-09), records the decision, returns an `Approval` (only constructor)	Phase 2
`bookOffer(approval)`	The only function that sends `booking_request` (with `returnImmediately: true`); polls `GetTask` until a terminal state or P-04	Phase 2
`declineOffer`	Sends `offer_declined` so the hold is released at once	Phase 2
Audit log	JSONL file, same event shape as the business side	Phase 2
Directory client	Resolves a listing, checks the card's interface URL origin against the listing	Phase 3

Component	Role	Status
Calendar adapter	Writes the confirmed booking to the person's calendar	Phase 4
Language front end	Turns "Thursday after work" into an `availability_request`. Never decides what is booked.	Later

Directory, dashboard, app, ratings

Component	Role	Status
Directory API	`POST /v1/listings`, verification, search, card fetch with SSRF guards	Phase 3
Verification worker	Domain proof (`/.well-known` token or DNS TXT); in person for shops without a site (D-14)	Phase 3
JWKS registry	Stores each listing's JWKS URL and verifies card signatures on refresh	Phase 6
Dashboard	Shop setup, approval mode, manual-approval queue, outcome marking	Phase 3 to 4
App shell	Contacts list, chat thread, approval sheet, bookings	Phase 4
Rating ingest	Builds interaction records from both sides' audit events	Phase 5
Review service	Reviews only on verified interactions	Phase 5
Moderation	Report queue, takedown, appeal	Phase 6

6. Key sequences

Availability (Built, UC-01)

Approve and book (Phase 2, UC-02)

Failure paths: expired or unknown offer, slot taken, shop declined or shop timeout (P-03) end the Task `REJECTED` with `booking_rejected {reason}`. A decline sends `offer_declined` and releases the hold at once (UC-03). The Task never uses `INPUT_REQUIRED`: in A2A that state asks the *client* for input, and SDK 1.3 stops processing the task's events there.

Directory lookup with origin check (Phase 3, UC-06)

7. Deployment view

Option	Fit	Cost	Notes
A. One container host (Fly.io, Render or Railway) + managed Postgres	Good	Low	Several instances share Postgres; one subdomain per hosted business agent. Simplest to run.
B. Serverless functions + serverless Postgres	Medium	Lowest at idle	Cold starts threaten p95 under 2 s; long-lived booking Tasks awkward.
C. Kubernetes	Poor at this stage	High	Operational load out of proportion to one area of barbers.

Recommendation: A (to be recorded as ADR 0014). One region near the pilot area, Postgres for directory, offers, bookings, audit and ratings, a CDN in front of the app and dashboard.

Tenancy. Each hosted business agent gets its own subdomain, `<slug>.agents.hitchpost.dev`, served by the shared host. Path routing (`/a/<listingId>/`) was rejected: every shop would share one origin, so origin verification (BR-12) could not tell them apart, and `/.well-known/` is only defined at an origin's root (RFC 8615). Self-hosted agents keep their own origin.

Keys (Phase 6, ADR 0017). Agent cards are signed with JWS over the JCS (RFC 8785) canonical card. Keys are published as a JWKS at a URL registered on the listing. For hosted agents the platform holds one key per tenant in a managed KMS; self-hosted agents hold their own. Scheduled rotation keeps the old key valid for verification for 30 days; a suspected compromise revokes it at once (removed from the JWKS, listing flagged).

8. Cross-cutting concerns

Concern	Today	Design
Time zones	UTC only; inputs must carry a zone and are normalised to UTC (`toInstant` in `booking.ts`)	Phase 6 (ADR 0018), before any real booking: hours as minutes of the local day in the shop's IANA zone; slot grid starts from the local opening time; skipped local times give no slot; repeated local times are offered once (first occurrence). Wire format stays UTC.
Clocks	Not needed	The business clock is authoritative: offers carry `issuedAt` and `expiresAt`. The personal agent never compares clocks; it sets a local deadline of receive time plus the hold, minus P-09.
Idempotency	Not needed (availability is read-only)	SDK 1.3 mints a new Task for every send without a `taskId` (`server/index.js:2801`) and refuses sends to a finished Task (line 2789). So a client that has the `taskId` retries with `GetTask`; a client that lost the response resends, and the business looks up `offerId → taskId` and completes the new Task at once with the same `booking_confirmed` plus `duplicateOf`. Never a second booking.
Contract extension	None	Clients declare `https://hitchpost.dev/ext/contract/v1` in the `A2A-Extensions` request header; SDK 1.3 checks required extensions against that header, not the message body (`server/index.js:2775`), so a client that only lists it in `message.extensions` is refused (AR-7).
Concurrency	None	Phase 2: one SQLite transaction re-checks the slot against holds and bookings and writes. Phase 6: the `slot_claims` exclusion table in 08 §4 makes it safe across instances; MCP writes must be conditional.
Persistence	In memory	Phase 2: SQLite on the business side (SDK `DatabaseTaskStore` plus offers, bookings, audit), JSONL audit on the personal side. Phase 6: Postgres.
Errors	Server returns `{"error":"bad request"}`; CLI shows only its own messages (`AskError`)	Error model in 13; never echo remote text to a person.
Configuration	`PORT` env var in `barber-agent/src/main.ts`	Env vars only (`PUBLIC_URL`, `DATABASE_URL`, limits). Public card URL from config, not the bind address.
Observability	Console logs	Phase 2: every audit event carries `contextId`, `taskId`, `offerId`, `messageId`. Phase 6 (NFR-OBS-01): structured JSON logs and OpenTelemetry traces across agents.
Auth between agents	None, localhost only	Phase 2: server-minted capabilities, `offerId` for booking and `bookingToken` for cancel and reschedule; `contextId` is client-chosen (SDK 1.3 keeps it, `server/index.js:2815`) and used for correlation only. Phase 6 (NFR-SEC-02): signed cards, signed interaction records and per-contact tokens (ADR 0017).
Abuse limits	None	Phase 2: P-07 hold caps and P-08 rate limit per client IP. Phase 6 (NFR-SEC-03): per agent identity, at the edge and in the host.

9. Architecture decisions

Existing: 0002 monorepo, 0003 A2A and MCP, 0005 CI and review, 0007 approval gate, 0010 typed data, 0011 in-memory book.

New and proposed:

ADR	Title	Needed by
0012	Booking protocol: Tasks for commitments, holds and reservations, manual approval as `WORKING`, idempotency	Phase 2
0013	Approval is a type only the gate can create	Phase 2
0014	Hosting: one container platform plus managed Postgres, subdomain per tenant	Phase 6 (decide in Phase 3)
0015	Directory verifies origin; clients enforce card URL origin	Phase 3
0016	Compile packages for deployment instead of running `.ts` from `node_modules`	Phase 6
0017	Agent-to-agent authentication: signed cards (JWS over JCS), JWKS, per-tenant KMS keys, per-contact tokens	Phase 6
0018	Shop time zones: IANA zone per business, minutes of the local day, UTC on the wire	Phase 6

Revision history

Version	Date	Change	Author
0.1	2026-11-08	First draft	S. Jannisar
1.0	2026-11-09	Baselined: renumbered into lifecycle order, formal document control, standards conformance	S. Jannisar
1.1	2026-11-09	Remediation after independent review: 42010 viewpoint catalogue and correspondence rules, corrected booking sequence (Reserved, `WORKING`, polling), deployment with personal agents, ratings, dashboard, subdomain tenancy and signing keys, concurrency, time zones Phase 6	S. Jannisar
1.2	2026-11-09	Second remediation after regrade: booking sequence and cross-cutting rows matched to SDK 1.3 behaviour (extension header, duplicate handling, client-chosen contextId); capabilities offerId and bookingToken; interaction records attested by hashes in Phase 5, signed in Phase 6	S. Jannisar

HP-SAD-11 · Quality attributes

Field	Value
Document ID	HP-SAD-11
Version	1.2
Status	Baselined for Phase 2
Date	2026-11-09
Owner	Sanaullah Jannisar, product and engineering lead
Conforms to	ISO/IEC 25010:2023 (product quality model), SEI Architecture Tradeoff Analysis Method (ATAM), ISO/IEC/IEEE 42010

1. Purpose and scope

This document makes the non-functional requirements in 05 §6 testable and ties each to the architecture in 10. It uses the ATAM structure: a utility tree that ranks quality attributes, six-part scenarios that state each one precisely, the tactics chosen to meet them, and the sensitivity points, trade-offs and risks that follow. Each scenario names how it is verified in 15 Test strategy. Timing values are P-IDs from 00 Document control.

Limit of this analysis: I ran the ATAM steps myself, with the stakeholder concerns taken from 04 and 10 §2. A workshop with real shop owners and an outside architect is planned before Phase 6 and may re-rank the tree.

2. Business drivers

The architecture serves four drivers from 01 Vision and 03 Business case:

1. **Trust.** A person must never be committed without their yes, and must never be shown a misleading offer. This is the product's floor.
2. **Interoperability.** Any A2A agent can talk to a Hitchpost agent, so the directory can grow beyond our own code.
3. **Low cost to run.** One maintainer, one neighborhood, small budget through Phase 6.
4. **Learning speed.** The wedge may change after the assumption tests, so the system must be cheap to change.

3. Utility tree

Ranks are (importance to the business, difficulty to achieve), each H, M or L. Scenarios ranked (H, H) get design attention first.

Quality attribute (ISO/IEC 25010)	Refinement	Scenario	Rank
Security: integrity	No commitment without approval	QAS-01	(H, H)
	Hostile peer can't mislead the person	QAS-02	(H, M)
	Fake business can't be listed	QAS-03	(H, H)
Security: resistance	Flooding can't take an agent down or hoard slots	QAS-04	(H, M)
Reliability: fault tolerance	No double bookings under concurrency	QAS-05	(H, H)
	Retries never duplicate a booking	QAS-06	(H, M)
Reliability: availability	Directory stays up	QAS-07	(M, M)
Performance efficiency	Fast offer round trip	QAS-08	(M, L)
	Bounded work per request	QAS-09	(H, L)
Privacy (security: confidentiality)	Share a slot, never a calendar	QAS-10	(H, M)
	Deletion on request	QAS-11	(M, M)
Compatibility: interoperability	Works with outside A2A agents	QAS-12	(H, M)
	Contract changes don't break peers	QAS-13	(M, M)
Interaction capability: accessibility	Approval usable by keyboard and screen reader	QAS-14	(H, M)
Maintainability: modifiability	Swap the booking backend	QAS-15	(M, M)
	Every change verified	QAS-16	(H, L)
Operability (observability)	Trace one booking end to end	QAS-17	(M, M)

4. Quality attribute scenarios

Each scenario has the six ATAM parts. "Measure" is what a test or monitor checks.

ID	Source	Stimulus	Artifact	Environment	Response	Measure	NFR / FR
QAS-01	Any code path or peer agent	Attempts to send a `booking_request` without the person's approval	Personal agent	Normal operation	Impossible: the only sending function requires an `Approval` that only the gate creates	0 compile-time paths; tests prove no booking without approval	FR-GATE-01, FR-GATE-04

ID	Source	Stimulus	Artifact	Environment	Response	Measure	NFR / FR
QAS-02	Hostile business agent	Replies with a mismatched offer, escape codes, prose in a date, or absurd values	Personal agent parsers	Normal operation	Reply refused; person sees only a fixed safe message	100% of the audit's attack set refused (22 tests today)	NFR-SEC-01, NFR-SEC-05, FR-MSG-04
QAS-03	Impostor	Registers a listing pointing at someone else's agent card	Directory	Normal operation	Listing stays `pending`; card URL origin must match proven origin	0 unverified listings in search	FR-DIR-01, FR-DIR-03
QAS-04	Scripted sender	Sends 10,000 availability requests in a minute to hoard slots	Business agent, directory	Phase 2 onward	Requests above P-08 per sender get HTTP 429; no sender holds more than P-07 open offers	p95 for other senders stays under 2 s; no customer is refused a slot because of one sender's holds	NFR-SEC-03, NFR-PERF-01
QAS-05	Two personal agents	Send `booking_request` for the same slot within 1 ms, one while the shop is deciding on manual approval	Booking handler	Normal load; Phase 6 with two instances	Exactly one confirmed; the other `booking_rejected` `slot_taken`; a Reserved offer is never re-offered	0 double bookings in 1,000 concurrent trials	NFR-REL-02, FR-BOOK-01
QAS-06	Personal agent	Resends a `booking_request` after a timeout, including while the first is still pending	Booking handler	Network fault	Client with the `taskId` uses `GetTask`; a lost-response resend gets a new Task that completes at once with the same `booking_confirmed` plus `duplicateOf`; no second booking	0 duplicates across retry tests	NFR-REL-02, FR-BOOK-02
QAS-07	Infrastructure	One instance of the directory crashes	Directory service	Production	Traffic served by the remaining instance; crashed one restarts	99.5% monthly availability	NFR-REL-01
QAS-08	Person	Asks for availability	Both agents	Production, normal load	Validated offer shown	p95 under 2 s request to validated offer	NFR-PERF-01
QAS-09	Any sender	Requests the widest possible window on a fully booked book	Slot search	Any	Work capped by the 31-day window	At most 1,488 slot checks per request	NFR-PERF-02, FR-MSG-07
QAS-10	Business agent	Asks for anything beyond the slot (calendar, contacts)	Message contract	Any	No message kind carries it; extra fields are dropped	0 calendar or contact fields in any message kind	NFR-PRIV-01
QAS-11	Person	Requests account deletion	App, directory, ratings, backups	Production	Personal data erased across stores; backups expire per P-15	Done within P-13; verified by a deletion test	NFR-PRIV-02
QAS-12	Outside developer (Priya)	Points a standard A2A v1.0 client at a Hitchpost agent	Business agent	Development	Card discovered at the standard path; JSON-RPC exchange works	Conformance suite passes with the official SDK	NFR-INT-01
QAS-13	Maintainer	Ships contract version 2	Message contract	Production with mixed peers	Peers declaring only the v1 extension keep working	v1 supported for P-18 after v2 ships; contract tests green	FR-MSG-09
QAS-14	Person using a screen reader	Receives an offer and approves it	App approval sheet	Phase 4 app	Offer announced; Approve and Decline reachable by keyboard; expiry shown as text	WCAG 2.2 AA automated audit clean plus manual pass	NFR-A11Y-01, FR-APP-02
QAS-15	Maintainer	Replaces the in-memory book with a shop's booking system over MCP	Business agent	Development	Change confined to the booking tool adapter	No changes outside the adapter and its tests	FR-BOOK-06
QAS-16	Contributor	Opens a pull request	Repository	CI	Lint, type check and tests run; merge blocked if red	100% of merges to `main` have a green run	NFR-MAINT-01, NFR-MAINT-02
QAS-17	Operator (Sam)	Investigates a disputed booking	Audit logs and traces	Production	Every event for the booking found on both sides by `contextId`, `taskId`, `offerId`, `messageId`	Full history retrieved in under 5 minutes	NFR-OBS-01

5. Architectural tactics

Scenario	Tactic (SEI catalogue term)	Where it lives in 10	Status
QAS-01	Limit access; capability token (the `Approval` type)	§5 Personal agent: approval gate, `bookOffer(approval)`	Phase 2
QAS-02, QAS-10	Validate input; sanitize output; minimal message contract	§5 `ask.ts`, `booking.ts` parsers	Built
QAS-03	Authenticate actors; verify origin	§5 Directory: verification worker	Phase 3
QAS-04	Limit event rate; cap open holds per sender	§5 business agent rate limiter and offer store; §8 abuse limits	Phase 2 (per IP), Phase 6 (per identity)
QAS-05	Serialize conflicting writes in one transaction; database exclusion constraint over holds and bookings	§5 booking handler; §8 concurrency; 08 §4	Phase 2 (one transaction), Phase 6 (constraint)

Scenario	Tactic (SEI catalogue term)	Where it lives in 10	Status
QAS-06	Idempotent operations keyed by `offerId` (`offerId → taskId`), answered as `duplicateOf` because SDK 1.3 mints a Task per send	§5 booking handler; §8 idempotency	Phase 2
QAS-07	Redundancy (two instances); health checks; restart	§7 deployment view	Phase 6
QAS-08, QAS-09	Bound execution time; limit work per request; timeouts	§5 `findFreeSlot`, `MAX_WINDOW_DAYS` (P-06), `askForSlot` deadline (P-05)	Built
QAS-11	Data lifecycle jobs; deletion propagation; backup expiry	§8 persistence; 08 §5	Phase 6
QAS-12, QAS-13	Adhere to standards (A2A v1.0); versioned interface; tolerant reader	§4 containers; 13 §2	Built (A2A), Phase 2 (versions)
QAS-14	Semantic markup; live regions; no colour-only cues	13 §4, 14	Phase 4
QAS-15	Encapsulate; use an intermediary (adapter)	§5 booking tool adapter (conditional writes)	Phase 6
QAS-16	Gate on automated checks	`.github/workflows/ci.yml`	Built (enforced on first push)
QAS-17	Correlation ids from Phase 2; structured logging and distributed tracing in Phase 6	§8 observability; 18	Phase 2 (ids), Phase 6 (traces)

6. Analysis

6.1 Sensitivity points

A sensitivity point is a design choice that a quality attribute depends on heavily.

ID	Choice	Attributes affected
SP-1	Offer hold (P-01) and reserved hold (P-02)	Reliability (QAS-05), usability, slot utilisation, abuse (QAS-04)
SP-2	Window cap (P-06)	Performance (QAS-09), usefulness for far-ahead bookings
SP-3	Strictness of the message parsers	Security (QAS-02), interoperability (QAS-12)
SP-4	Where the check-and-write runs (process vs database)	Reliability (QAS-05), scalability
SP-5	Rate limit and hold cap per sender (P-08, P-07)	Resistance (QAS-04), legitimate heavy users, shared IPs

6.2 Trade-offs

ID	Trade-off	Decision and reason
TO-1	Strict parsing (security) against tolerance for slightly off peers (interoperability)	Strict. A rejected peer gets a clear `rejected`; a misled person is worse. Tolerance applies only to unknown fields, which are dropped.
TO-2	Longer offer hold (person has time to decide) against shorter hold (chair free for others)	P-01 for the person's decision; the slot stays reserved only while the shop decides (P-02, P-03), so a manual approval never lets the hold lapse. Revisit with A-01 and A-02 data.
TO-3	Typed messages (testable, safe) against natural language between agents (flexible)	Typed. A language model may only produce a typed request on the person's side (ADR 0010).
TO-4	Manual shop approval (owner control) against standing approval (speed)	Standing by default with a switch (FR-GATE-05); confirm in barber interviews (A-02).
TO-5	One shared host for business agents (cost) against one host per business (isolation)	Shared host, one subdomain per tenant so origins stay distinct, per-tenant signing keys (ADR 0014, ADR 0017).

6.3 Risks and non-risks

ID	Type	Statement	Linked
AR-1	Risk	The Phase 2 SQLite transaction is correct only while one process owns a book; running a second instance before the Phase 6 `slot_claims` constraint would allow double bookings.	QAS-05, SP-4, Phase 6
AR-2	Risk	Free-text fields (`service`, `reason`) are safe to display but not safe to feed a language model unguarded.	QAS-02, 12
AR-3	Risk	UTC-only, whole-hour opening hours give wrong slots for real shops until ADR 0018 lands in Phase 6; no real booking happens before then.	FR-BOOK-05, ADR 0018
AR-4	Risk	Unsigned agent cards let anyone who controls a URL impersonate an agent until signed cards and auth land.	NFR-SEC-02, QAS-03
AR-5	Risk	Until agent auth (Phase 6) the capabilities are bearer secrets: anyone who learns an `offerId` can book that offer, and anyone who learns a `bookingToken` can cancel or reschedule that booking. `contextId` grants nothing, because the client chooses it.	T-04, 12
AR-6	Risk	A booking system reached over MCP that cannot do a conditional write can double book against walk-ins entered there.	QAS-05, QAS-15, FR-BOOK-06
NR-1	Non-risk	Bounded work per request: the 31-day cap and slot grid make worst-case search cost fixed and small.	QAS-09
AR-7	Risk	The contract extension is `required: true`, and SDK 1.3 checks it against the `A2A-Extensions` header only (`server/index.js:2775`). Any client that doesn't send the header, including our own `ask.ts` until WP-2.12, is refused with `ExtensionSupportRequiredError`, which also hurts third-party interop. Mitigation: WP-2.12, TC-51, and the header documented in 13.	QAS-12, FR-MSG-09

ID	Type	Statement	Linked
NR-3	Non-risk	Approval as a type: bypassing the gate needs a deliberate type-system workaround that review and tests would catch.	QAS-01

7. Verification

Scenario	How it is verified (15)	Status today
QAS-01	Unit tests that booking can't be reached without an `Approval`; approval for offer A can't book offer B	Phase 2
QAS-02, QAS-10	Adversarial parser tests and end-to-end tests with a sneaky barber agent	Built (`booking.test.ts`, `ask.test.ts`)
QAS-03	Directory integration tests: origin mismatch refused, unverified listings not searchable	Phase 3
QAS-04, QAS-07, QAS-08	Load test on staging; SLO monitors in production	Phase 6
QAS-05, QAS-06	Concurrency, manual-approval and retry tests in `packages/e2e`; two-instance test against Postgres in Phase 6	Phase 2, 6
QAS-09	Window cap and bounded-search tests	Built
QAS-11	Deletion propagation test across stores	Phase 6
QAS-12, QAS-13	Conformance suite with the official SDK; versioned contract tests	Built (SDK on both sides), Phase 2 (versions)
QAS-14	Automated accessibility audit plus a manual screen-reader pass	Phase 4
QAS-15	Adapter contract test run against the in-memory book and the MCP adapter	Phase 6
QAS-16	Branch protection requiring the `lint, typecheck, test` check	Workflow Built; enforced on first push
QAS-17	Audit reconciliation test on correlation ids (Phase 2); operational drill tracing a seeded booking (Phase 6)	Phase 2, 6

Revision history

Version	Date	Change	Author
1.0	2026-11-09	First baseline	S. Jannisar
1.1	2026-11-09	Remediation after independent review: scenarios aligned to the corrected booking protocol, hold caps, idempotency, correlation ids, P-IDs, section references, stated limits of a self-run ATAM, new risks AR-5 and AR-6	S. Jannisar
1.2	2026-11-09	Second remediation after regrade: QAS-06 matched to SDK duplicate handling; AR-5 restated for server-minted capabilities; the interoperability non-risk replaced by risk AR-7 (required extension rejects clients that don't send the A2A-Extensions header)	S. Jannisar

HP-SAD-12 · Security and privacy

Field	Value
Document ID	HP-SAD-12
Version	1.2
Status	Baselined for Phase 2
Date	2026-11-09
Owner	Sanaullah Jannisar, product and engineering lead
Conforms to	STRIDE threat modelling; OWASP ASVS 4 (informative); ISO/IEC 27002 controls (informative); GDPR and CCPA principles (not legal advice)

Hitchpost lets agents act for people, so security is part of the product. This document covers the trust boundaries, the threat model, how injection is handled once a language model arrives, identity, privacy, abuse controls and the security process.

Status labels follow 00 Document control: **Built** means it's in the code now (with a path). Retention and patching values are P-IDs from 00.

1. Trust boundaries

The rule for B2 holds in both directions: **whatever arrives from another agent is data, never instructions** (ADR 0007, ADR 0010).

2. Threat model (STRIDE)

S = spoofing, T = tampering, R = repudiation, I = information disclosure, D = denial of service, E = elevation of privilege.

B2: agent to agent

ID	STRIDE	Threat	Control	Status	Requirement
T-01	T	Hostile agent sends malformed or oversized data to crash or confuse the other side	Strict validation and rebuild of every inbound message; unknown fields dropped; 100 kB body limit (Express default)	**Built** `packages/core/src/booking.ts` (`parseAvailabilityRequest`, `parseBarberReply`)	FR-MSG-03, NFR-SEC-01
T-02	T	Free text hidden in typed fields ("IGNORE PREVIOUS INSTRUCTIONS 2026-11-10")	Strict ISO 8601 with zone, rebuilt as canonical UTC; text fields reject control characters, max 200 chars	**Built** `booking.ts` (`toInstant`, `SAFE_TEXT`)	FR-MSG-03, NFR-SEC-01
T-03	T	Well formed but wrong offer (other service, other time, absurd price) shown to the person for approval	`offerMatches` binds offer to request; duration and price caps	**Built** `booking.ts`, `packages/my-agent/src/ask.ts`	FR-MSG-04
T-04	T, E	Acceptance of an offer the barber never made, approval of offer A used to book offer B, or a `cancel_request` or `reschedule_request` from someone who isn't the booking's owner	Server-minted capabilities authorise every state change: `offerId` (random UUID) for booking or declining that offer, `bookingToken` (128-bit random, returned only in `booking_confirmed`) for cancel and reschedule (ADR 0012). `contextId` authorises nothing: SDK 1.3 keeps whatever `contextId` the client sends (`server/index.js:2815`). Capabilities are logged only as hashes and never shown in UIs or URLs. Approval is a type only the gate can create, bound to one offer (ADR 0013). Phase 6 adds caller authentication and per-contact tokens	Phase 2 (capabilities, offer binding), Phase 6 (caller auth)	FR-GATE-02, FR-BOOK-01, FR-BOOK-03
T-05	D	Huge search window pins the barber's CPU	Window capped (P-06); slot search starts no earlier than now	**Built** `booking.ts` (`MAX_WINDOW_DAYS`), `packages/barber-agent/src/book.ts`	NFR-PERF-02
T-06	D	Request flood or slot hoarding from one sender (each offer holds a slot)	Rate limit (P-08) and open-hold cap (P-07) per sender: client IP in Phase 2, agent identity in Phase 6 (no per-`contextId` cap, since clients choose `contextId`); `offer_declined` releases holds at once; contact-request flow before first message (Phase 4)	Phase 2 (per IP), Phase 4 (contacts), Phase 6 (per identity)	NFR-SEC-03

ID	STRIDE	Threat	Control	Status	Requirement
T-07	S	Fake agent claims to be Main Street Barbers	Verified business identity in the directory; signed Agent Cards; client checks card origin against directory entry (ADR 0015, ADR 0017)	Phase 3 (directory checks), Phase 6 (signatures required)	FR-DIR-03, NFR-SEC-02
T-08	I	Error pages leak stack traces and file paths	Final JSON error handler; `x-powered-by` off	**Built** `packages/barber-agent/src/server.ts`	NFR-SEC-04
T-09	R	A party denies an offer, approval or booking happened	Append-only audit log on both sides with `contextId`, `taskId`, `offerId`, `messageId`; payload hash over JCS canonical JSON; hash chain in Phase 6	Phase 2	FR-GATE-03
T-10	E	An agent commits a person's time or money without their yes	Approval gate: only the gate can create an approval; only booking takes one	Phase 2	FR-GATE-01

B1: person to own agent (CLI and app)

ID	STRIDE	Threat	Control	Status	Requirement
T-11	S, T	Terminal escape codes paint a fake "BOOKED and APPROVED"	Control characters rejected in all text fields (P-19); CLI prints only its own error messages	**Built** `booking.ts`, `packages/my-agent/src/main.ts`	NFR-SEC-05
T-12	D	Agent card discovery hangs forever	One deadline over the whole exchange (P-05), card fetch included; redirects refused	**Built** `ask.ts`	FR-MSG-05
T-13	I	Directory supplies a URL that steers the client to an internal host (SSRF)	Card interface URL must match the directory entry's origin; block private and link-local addresses; response size cap	Phase 3	NFR-SEC-01
T-14	S	Someone else uses Dana's app session to approve bookings	Device-bound sign-in, re-confirmation for approvals over a set value	Phase 4	FR-APP-02, NFR-SEC-02

B3: business agent to its booking tool

Today the book is local configuration (Built). From Phase 6 a shop may connect its own booking system over MCP (FR-BOOK-06).

ID	STRIDE	Threat	Control	Status	Requirement
T-23	T	Shop's own configuration is malformed (unparseable booked ranges, overlapping hours), so a booked slot stops blocking and is offered again	Validate the book at load and on every MCP read; refuse to start or to offer on invalid data	Phase 2 (local book, D-15), Phase 6 (MCP reads)	FR-BOOK-04
T-24	T	Non-atomic write to the shop's system: a walk-in entered there between our check and our write gets double booked	Only connectors that support a conditional write (fails if the slot is taken) are allowed; otherwise not supported	Phase 6	FR-BOOK-06, NFR-REL-02
T-25	S	A spoofed or redirected MCP endpoint answers instead of the shop's real system	Endpoint configured by the owner in the dashboard, HTTPS only, pinned host, no redirects	Phase 6	FR-BOOK-06, NFR-SEC-01
T-26	I	The MCP connector over-reads the shop's system (customer names, phone numbers)	Least-privilege scope: read free and busy ranges and write our own bookings only; customer fields never requested	Phase 6	NFR-PRIV-01
T-27	E	Theft of the credential the agent uses for the shop's system	Stored encrypted in the platform KMS per tenant, scoped to one shop, rotated on owner request and on suspicion	Phase 6	NFR-SEC-02

B4 and B5: directory and operator

ID	STRIDE	Threat	Control	Status	Requirement
T-15	S	Business listed by someone who doesn't own it, or a hosted shop posing as another	Ownership proof (domain token or DNS TXT; in person for shops without a site, D-14) before a listing goes live; one subdomain per hosted tenant so origins differ (ADR 0014)	Phase 3, Phase 6 (hosting)	FR-DIR-01
T-16	T	Fake reviews and rating manipulation	Only verified interactions can be rated: in Phase 5 both sides' audit events must carry matching JCS SHA-256 hashes of the offer and the decision; signed interaction records in Phase 6 (ADR 0017); one review per completed booking	Phase 5	FR-RATE-01
T-17	E	Operator account takeover alters or removes listings	Operator sign-in with 2FA; all moderation actions logged	Phase 6	FR-ADMIN-01
T-18	I	Directory leaks private contact data	Directory holds business data only; reviews live in the ratings service with pseudonymous authors	Phase 3	NFR-PRIV-01

B6: CI/CD and supply chain

ID	STRIDE	Threat	Control	Status	Requirement
T-19	T	Compromised action tag steals the `ANTHROPIC_API_KEY`	Actions pinned to commit SHAs; `persist-credentials: false`; default token read-only	**Built** `.github/workflows/*.yml` (SHA pins); token setting at first push	NFR-MAINT-01
T-20	E	PR content steers the review bot	Runs on `pull_request`, not `pull_request_target`; forks and Dependabot skipped; tools limited to diff, view and commenting on its own PR; review is advisory	**Built** `.github/workflows/claude-review.yml`	NFR-SEC-01

ID	STRIDE	Threat	Control	Status	Requirement
T-21	T	Malicious dependency update	Frozen lockfile in CI; pnpm blocks install scripts by default; Dependabot PRs go through CI; `pnpm audit` in CI	Built (lockfile, scripts), Phase 6 (`pnpm audit`, release-age delay)	NFR-MAINT-01
T-22	T	Unreviewed code reaches `main`	Ruleset: PRs required, squash only, required check `lint, typecheck, test`	At first push	NFR-MAINT-01

3. Prompt injection once a language model is added

Phase 1 has no model. The plan for when one arrives (ADR 0010):

1. **The model only translates the person's own words into a typed request.** "Thursday after work" becomes an `availability_request`. It never reads another agent's messages as instructions.
2. **Messages from other agents never reach the model's instruction channel.** If a model must summarise an offer, it gets the validated typed fields, quoted and labelled as untrusted data.
3. **Free-text fields from other agents (`service`, `reason`) are shown to the person, not acted on.** Before a model reads them they are length-limited, control-character-free (Built) and wrapped as data.
4. **Actions only through typed tool calls behind the gate.** No model output can book, pay or share data without an approval value from the person (T-10).
5. **Adversarial tests:** a fixed corpus of injection strings runs against every model-facing path in CI (see 15).

4. Identity and authentication roadmap

Stage	Who proves what	Mechanism	Phase
Today	Nothing; local only, bound to `127.0.0.1`	`UserBuilder.noAuthentication` in `server.ts`	Built
Directory listing	Business owns the listing	Domain token or DNS TXT; in person for shops without a site (pilot only, D-14)	3
Agent identity	The card really belongs to the listed business	JWS over the JCS-canonical card; keys as a JWKS at a URL registered on the listing; platform-held per-tenant keys in a KMS for hosted agents; scheduled rotation keeps old keys 30 days for verification, compromise revokes at once (ADR 0017)	6
Agent to agent calls	The caller is who it says	Signed cards plus per-contact tokens issued when a contact is accepted (ADR 0017)	6
Person to app	Dana is Dana	Passkeys first, email link fallback	4
Operator	Sam is Sam	SSO or passkey with 2FA	6

5. Privacy

Not legal advice. A lawyer reviews this before production.

Data inventory (summary)

Full model and retention rules in 08. Risk R-08 (privacy) in the business case points here.

Data	Whose	Where	Class
Business listing (name, services, hours, prices, agent URL)	Business	Directory	Public
Appointment book	Business	Business agent	Business confidential
Requests, offers, bookings	Person and business	Both agents' logs	Personal
Contacts, chat history, approvals	Person	Client app	Personal
Reviews	Person, about a business	Ratings service	Public once posted, author pseudonymous
Operator and moderation logs	Platform	Directory	Internal

Lawful basis notes (GDPR / CCPA)

- **Bookings and approvals:** performance of a contract the person asked for.
- **Audit logs:** legitimate interest (proving what was approved), with limited retention.
- **Reviews:** consent at posting time, withdrawable.
- **No sale or sharing of personal data** for advertising, so CCPA "sale" opt-outs are not triggered. This needs confirming before production.

Minimisation (NFR-PRIV-01)

- My agent shares a **window**, not a calendar. The barber learns only the slot picked.
- Requests carry no name or contact details until the person approves a booking.
- The directory never stores customer data.

Retention, deletion and export

Values are defined once in 00; 08 §5 applies them.

Data	Retention	Deletion and export
Expired or declined offers	P-11	Automatic
Bookings, audit events, interaction records	P-12, then deleted (aggregates without personal fields kept)	Exported on request as JSON
Everything tied to a deleted account	Erased within P-13; backups expire per P-15	Export offered before deletion
Resolved abuse reports	P-14	Not exported (contains third-party data)
Chat history	Until the person deletes it	Delete per contact or all; export as JSON
Reviews	Until withdrawn	Author can withdraw at any time
Server logs	30 days, no message bodies	Not exported; no personal data in them by design

Roles

Not legal advice. My working view, for a lawyer to confirm before production:

Processing	Controller	Processor
Directory listings, moderation, ratings	Hitchpost (the operator)	Hosting provider
Personal agent and app data (contacts, approvals, chat)	Hitchpost, on the person's behalf	Hosting provider
A shop's bookings and audit log in a hosted business agent	The shop	Hitchpost (hosting the agent), hosting provider
A self-hosted business agent	The shop	Whoever the shop chooses

A data processing agreement with each pilot shop is part of onboarding (17).

Record of processing activities (summary)

Activity	Purpose	Data subjects	Data	Lawful basis	Retention	Recipients
Availability and booking	Book the appointment the person asked for	Customers	Window, service, booking time, pseudonymous customer ref	Contract	P-11, P-12	The chosen shop
Approval and audit	Prove what was approved	Customers, shop owners	Decisions, timestamps, correlation ids, payload hashes	Legitimate interest	P-12	Only the party that wrote the log; operator on dispute
App account	Run the person's agent	Customers	Name, email, time zone, contacts	Contract	Until deletion, then P-13	None
Directory	Let people find shops	Shop owners	Business details, verification state	Legitimate interest	While listed	Public
Ratings and reviews	Trust signals	Customers, shops	Interaction outcomes, review text	Legitimate interest (metrics), consent (review text)	P-12 (records), until withdrawn (reviews)	Public (aggregates and reviews)
Abuse reports	Keep the directory safe	Reporters, reported parties	Report details	Legitimate interest	P-14	Operator

Data protection impact assessment (summary)

A full DPIA is due before the Phase 6 pilot. The screening today:

Question	Answer
Large-scale or special-category data?	No. One neighbourhood; no health, payment or identity documents in v1.
Automated decisions with legal or similar effect?	No. Agents propose; a person decides every commitment (ADR 0007).
Systematic monitoring?	Limited: interaction outcomes feed ratings. Mitigated by pseudonymous records and verified-only reviews.
Main risks to people	Wrong or unwanted bookings (T-03, T-04, T-10); exposure of booking history (T-18, T-26); fake reviews (T-16).
Main mitigations	Approval gate, offer binding, minimisation (a slot, never a calendar), P-IDs for retention, pseudonymous ratings.
Residual risk	Low to medium until agent auth in Phase 6: a leaked `bookingToken` lets its holder cancel or reschedule that one booking (T-04); accepted for the closed pilot only.

6. Abuse and spam controls

- **Contact requests** (Phase 4): an unknown agent's first message lands as a request the person accepts or blocks, like a messaging app.
- **Rate limits and hold caps** (Phase 2 per client IP, Phase 6 per agent identity): P-08 and P-07, plus global limits at the proxy in Phase 6.
- **Sender reputation** (Phase 5): agents with many rejected or reported interactions get throttled, then delisted after review.
- **Reports** (UC-09, Phase 5) go to the moderation queue (UC-10, FR-ADMIN-01).
- **Request bounds** (Built): window cap, body size limit, validation before any work.

7. Security process

- **Reporting:** private vulnerability reporting through GitHub, described in SECURITY.md. Acknowledgement within 72 hours.

- **Disclosure:** coordinated. A fix ships first, then a GitHub Security Advisory with credit to the reporter.
- **Dependencies:** Dependabot weekly for npm and Actions (`.github/dependabot.yml`), actions pinned to SHAs, frozen lockfile, CVEs patched per P-16 (19).
- **Reviews:** every PR gets the automated review. Changes touching validation, the gate or auth also get a manual security check against this threat model.
- **Re-audit:** before Phase 2 ships, before production, and yearly after that, in the same five-reviewer format as the Phase 1 audit. Those reviews are run as separate Claude Code agents under my direction; an outside human security review is planned before production.

Revision history

Version	Date	Change	Author
0.1	2026-11-08	First draft	S. Jannisar
1.0	2026-11-09	Baselined: renumbered into lifecycle order, formal document control, standards conformance	S. Jannisar
1.1	2026-11-09	Remediation after independent review: B3 threats T-23 to T-27, T-04 on `contextId` and bearer risk, corrected requirement traces, roles, record of processing, DPIA screening, R-08, retention and patching via P-IDs, signed cards Phase 6	S. Jannisar
1.2	2026-11-09	Second remediation after regrade: T-04 rewritten: server-minted offerId and bookingToken are the capabilities, contextId authorises nothing (SDK 1.3 keeps the client's contextId); T-06 hold cap per sender only; T-16 Phase 5 hash attestation, signed interaction records in Phase 6; DPIA residual risk restated	S. Jannisar

HP-SAD-13 · Interface design

Field	Value
Document ID	HP-SAD-13
Version	1.2
Status	Baselined for Phase 2
Date	2026-11-09
Owner	Sanaullah Jannisar, product and engineering lead
Conforms to	IEEE 1016-2009 (interface viewpoint); A2A protocol specification v1.0

The contracts Hitchpost exposes: the agent message contract (agent to agent), the directory REST API (app and agents to directory) and the client app's screens. The booking protocol's rationale is in ADR 0012. Timing and limit values are not repeated here: they are the normative parameters P-01 to P-20 in 00 Document control, referenced by ID.

1. Agent message contract

Messages travel as A2A **data parts** (`mediaType: application/json`), built with `dataPart()` in `packages/core/src/a2a.ts`. Every message has a `kind`. Every receiver validates and rebuilds what it gets; unknown fields are dropped (NFR-SEC-01, FR-MSG-03).

Shared field rules (Built, `packages/core/src/booking.ts`)

Type	Rule
Instant	Strict ISO 8601 with `Z` or `±hh:mm`, real calendar day, rebuilt as UTC `toISOString()`
Text (`service`, `reason`, `offerId`)	Text limit (P-19): 1 to 200 characters, no control characters (`\p{C}`)
`durationMinutes`	Safe integer within the duration cap (P-20)
`priceCents`	Safe integer within the price cap (P-20)
`currency`	Three capital letters (ISO 4217 shape)
Window	`earliest < latest`, within the maximum search window (P-06)

All instants are UTC on the wire. Shop-local time zones arrive in Phase 6 (ADR 0018); before then every booking is a UTC demo booking.

Kinds

Kind	Direction	Fields	Carried in	Status
`availability_request`	person → business	`service`, `earliest`, `latest`	Message	Built
`offer`	business → person	`offerId`, `service`, `start`, `durationMinutes`, `priceCents`, `currency`; Phase 2 adds `issuedAt`, `expiresAt` and, for a reschedule, `replacesBookingId`	Message	Built
`no_availability`	business → person	`service`	Message	Built
`rejected`	business → person	`reason`	Message	Built
`offer_declined`	person → business	`offerId`	Message (releases the hold at once)	Phase 2
`booking_request`	person → business	`offerId` (the capability to book that offer)	Task	Phase 2
`booking_pending`	business → person	`offerId`, `reservedUntil`	Status message of the `WORKING` Task	Phase 2
`booking_confirmed`	business → person	`bookingId`, `bookingToken`, `offerId`, `service`, `start`, `durationMinutes`, `priceCents`, `currency`; `duplicateOf` when answering a resent request	Task `COMPLETED`	Phase 2
`booking_rejected`	business → person	`offerId`, `reason`: `expired`, `unknown_offer`, `slot_taken`, `shop_declined`, `shop_timeout`, `cutoff`, `other`	Task `REJECTED`	Phase 2
`cancel_request`	person → business	`bookingId`, `bookingToken`	Task	Phase 2
`cancelled`	business → person	`bookingId`; `duplicateOf` when answering a resent request	Task `COMPLETED`	Phase 2
`cancel_rejected`	business → person	`bookingId`, `reason`: `cutoff`, `unknown_booking`, `other`	Task `REJECTED`	Phase 2
`reschedule_request`	person → business	`bookingId`, `bookingToken`, `earliest`, `latest`; answered with an `offer` carrying `replacesBookingId`, or `no_availability`, or `rejected` with reason `cutoff`; then the normal approve and book flow	Message (a question)	Phase 2

The receiving personal agent also checks that an offer answers its own request (`offerMatches`: same service, start within the window), FR-MSG-04. A `booking_confirmed` must match the approved offer field for field before it is written to a calendar.

Protocol rules (Phase 2, ADR 0012)

- **Offer clock.** The business clock is authoritative. `expiresAt` = `issuedAt` + offer hold (P-01). The personal agent computes its own local deadline as receivedAt + (`expiresAt` − `issuedAt`) and treats the offer as expired the clock margin (P-09) before it, so clock skew between machines never lets an approval land after the business considers the offer gone.
- **Reserved.** When a `booking_request` is accepted for a shop on manual approval (FR-GATE-05), the offer moves from Held to Reserved and stays held until the shop decides, at most the manual approval wait (P-03). The offer's own `expiresAt` never changes (it is part of the offer the person approved); the reservation gets a separate `reservedUntil` = acceptance time + P-03, sent in the `WORKING` status message's data part. A shop on standing approval goes straight from Held to Booked.
- **Recheck at write.** The slot is checked again inside the same transaction that writes the booking. If it is no longer free, the Task ends `REJECTED` with `slot_taken`.
- **Waiting on the shop.** The Task stays `WORKING` with a status message "Waiting for the shop", never `INPUT_REQUIRED`: in A2A that state asks the *client* for input, and SDK 1.3 stops draining executor events at it (`server/index.js:2181`). The personal agent sends `booking_request` with `returnImmediately: true` and polls `GetTask` until a final state or its booking deadline (P-04). There are no push notifications in v1.
- **Capabilities, not contexts.** Authority comes from server-minted secrets, never from `contextId`. The SDK keeps whatever `contextId` the client sends (`server/index.js:2815`), so a client can choose it and it proves nothing. `offerId` (random UUID v4, minted by the business) authorises `booking_request` and `offer_declined` for that offer. `booking_confirmed` carries a server-minted `bookingToken` (128-bit random, base64url) that `cancel_request` and `reschedule_request` must present with the `bookingId`; a wrong or missing token is answered `unknown_booking`. `contextId` is kept for correlation only. Until agent authentication in Phase 6 these secrets are bearer capabilities: logged as hashes, never shown in a UI and never put in a URL.
- **Idempotency.** The SDK gives a send without `taskId` a new random task id (`server/index.js:2801`) and throws `UnsupportedOperationError` when a send names a finished task (`server/index.js:2789`), so retries work like this. A client that has the `taskId` retries with `GetTask`, never with a new send. A client that lost the response resends `booking_request` without a `taskId`; the business looks up `offerId → taskId` and the new Task completes at once with the same `booking_confirmed` payload plus `duplicateOf: <original taskId>` (or the same `booking_rejected`). No second booking is made. `cancel_request` works the same way through `bookingId → taskId`. Clients reuse the same `messageId` on a resend.
- **Hold caps.** At most the open holds cap (P-07) per sender (the client IP until agent authentication in Phase 6). There is no per-`contextId` cap, because clients choose `contextId`. Beyond the cap the business answers `rejected` and issues no new hold. Requests per sender are limited by the rate limit (P-08).
- **Reschedule.** `reschedule_request` is a question, so it is a Message: the business checks the token and the shop's cancellation cutoff (P-10) and answers with an offer carrying `replacesBookingId`, `no_availability`, or `rejected` with reason `cutoff`. The person approves that offer like any other. At the swap the business checks P-10 again: past the cutoff the Task ends `booking_rejected` with reason `cutoff`. Otherwise the old booking is cancelled only in the same transaction that confirms the new one; if the new booking fails, the old one stands.
- **Shop-side cancellation** of a confirmed booking is Later: `hitchpost/1` has no business-to-person push. In v1 the shop contacts the customer outside Hitchpost.
- **Correlation.** From Phase 2 both sides record `contextId`, `taskId`, `offerId` and `messageId` on every audit event. Audit `payloadHash` is SHA-256 over the JCS (RFC 8785) canonical JSON of the data part.

A2A usage

Exchange	A2A shape	Why
Availability, decline, reschedule question	`SendMessage` → `Message` reply	Questions; nothing to track (availability Built, `executor.ts`).
Booking, cancel	`SendMessage` (`returnImmediately: true`) → `Task`; `WORKING` while the shop decides; `COMPLETED` or `REJECTED` with a data part	A durable id for audit, polling and idempotent retries (ADR 0012).
Agent card	`GET /.well-known/agent-card.json`	Skills: `offer_appointment` (Built), `book_appointment`, `cancel_appointment` (Phase 2). Modes `application/json`.

Transport: JSON-RPC binding (Built). REST and gRPC bindings are available in the SDK but not advertised until tested (NFR-INT-01).

2. Versioning and compatibility

- **Where the version lives.** The A2A `AgentCard` has no metadata field. The contract is declared as an entry in `capabilities.extensions`: uri `https://hitchpost.dev/ext/contract/v1`, `required: true`.
- **How a client declares it.** The SDK checks required extensions against `context.requestedExtensions`, which comes from the `A2A-Extensions` HTTP header, not from `message.extensions` (`server/index.js:2775-2781`). A client that leaves the header out gets `ExtensionSupportRequiredError` on every send. So every client sends the uri in the `A2A-Extensions` header (in the JS SDK, through `serviceParameters` on each call) and also lists it in each message's `extensions`. Today's `askForSlot` sends neither: adding it is Phase 2 work, proved by a contract test.
- **Major versions only.** Additive changes (a new optional field, a new `kind`) keep the version. Receivers ignore unknown fields and reply `rejected` to unknown kinds. There are no minor versions.
- **Breaking changes** (removing or retyping a field, tightening a limit) publish a new extension uri, `.../contract/v2`. An agent lists every version it accepts; a sender uses the highest one both cards list.
- Each major version is supported for the period in P-18 after its successor ships (see 19 Maintenance).
- Contract tests in `packages/e2e` run each supported version against the current agents (Phase 2).

3. Directory REST API (Phase 3)

Base path `/v1`. JSON only. Errors use the model in section 5.

Method and path	Auth	Purpose
`POST /v1/listings`	Business account	Create a listing with `cardUrl`; status `pending`
`POST /v1/listings/{id}/verify`	Business account	Start origin verification (well-known token or DNS TXT)
`GET /v1/listings/{id}`	None	Public listing: name, address, services summary, `cardUrl`, `verifiedOrigin`, rating summary
`GET /v1/listings?q=&near=lat,lng&radiusKm=&service=&cursor=&limit=`	None	Search verified listings (FR-DIR-02). `limit` 1 to 50, default 20; cursor pagination
`PATCH /v1/listings/{id}`	Business account	Update public fields; changing `cardUrl` resets verification
`DELETE /v1/listings/{id}`	Business account	Close the listing
`POST /v1/reports`	Person account	Report a listing (FR-ADMIN-01)
`GET /v1/admin/reports`, `POST /v1/admin/listings/{id}/suspend`	Operator role	Moderation (Phase 6)

Rules: the directory fetches cards server-side with a timeout, no redirects, a size cap and private-address blocking (NFR-SEC-01). Search returns only `verified` listings. Rate limits per IP and per account (P-08, NFR-SEC-03); a `429` carries `Retry-After`. Hosted business agents each get their own subdomain so origin verification can tell them apart (Phase 6).

4. Client app (Phase 4)

Screens

Screen	Purpose	Requirement
Contacts	Agents you've added, with verified badge and rating	FR-APP-01
Find	Directory search and add contact	FR-DIR-02
Thread	Conversation with one business agent; typed cards for offers	FR-MSG-02
Approval sheet	The validated offer, the business's verified name, Approve and Decline	FR-APP-02, FR-GATE-01
Bookings	Upcoming and past bookings; cancel, reschedule	FR-BOOK-03
Rate	Stars and optional text after a completed booking	FR-RATE-01
Settings	Account, data export and deletion	NFR-PRIV-01

Full screen designs are in 14 User interface design.

Main flow

The approval sheet renders only fields that passed validation, from structured data, never from free text, and states plainly that nothing is booked until Approve is pressed. Decline sends `offer_declined`, so the shop's chair is freed at once.

Accessibility (NFR-A11Y-01, WCAG 2.2 AA)

- Approve and Decline are real buttons, at least 24 by 24 CSS px, reachable by keyboard, never colour-only.
- Times shown in the person's time zone with the zone named; prices with currency.
- Offer cards and status changes announced through a polite live region.
- No time limit on approving shorter than the offer's own local deadline (P-01, P-09), and the remaining time is shown as text.

5. Error model

Layer	Shape	Rule
Agent message	`rejected {reason}`, `booking_rejected {offerId, reason}`, `cancel_rejected {bookingId, reason}`	Reasons are the listed codes or short plain sentences; no stack traces

Layer	Shape	Rule
A2A transport	JSON-RPC error	Logged with `contextId`; never shown to a person verbatim
HTTP (agent host, directory)	`{"error": "<code>", "message": "<safe text>"}` with matching status	Built in minimal form: `{"error":"bad request"}` from the error handler in `server.ts`
CLI and app	Own messages only	Built: `AskError` in `my-agent/src/ask.ts`; any other error shows a fixed message

Revision history

Version	Date	Change	Author
0.1	2026-11-08	First draft	S. Jannisar
1.0	2026-11-09	Baselined: renumbered into lifecycle order, formal document control, standards conformance	S. Jannisar
1.1	2026-11-09	Remediation after independent review: booking protocol rules (Reserved, WORKING not input-required, recheck, polling, idempotency, hold caps, clock), new kinds, contract version in card extensions, P-IDs	S. Jannisar
1.2	2026-11-09	Second remediation after regrade: extension declared in the `A2A-Extensions` header; idempotency rebuilt on SDK behaviour (GetTask, `duplicateOf`); `offerId` and `bookingToken` as capabilities instead of `contextId`; hold cap per sender only; reschedule as a Message with cutoff checks; `reservedUntil`; `cutoff` reject reason	S. Jannisar

HP-SAD-14 · User interface design

Field	Value
Document ID	HP-SAD-14
Version	1.1
Status	Baselined for Phase 2
Date	2026-11-09
Owner	Sanaullah Jannisar, product and engineering lead
Conforms to	IEEE 1016 (interface viewpoint), ISO 9241-110 (dialogue principles), WCAG 2.2 AA

1. Purpose and scope

This document designs the human-facing surfaces of Hitchpost: the client app Dana uses (Phase 4), the barber dashboard Marcus uses (Phase 4, including the manual-approval queue and outcome marking), and the report flow (Phase 5). It sets the principles, the navigation, low-fidelity wireframes, interaction states, exact copy for the moments that matter, accessibility rules and the usability test plan.

Today (Phase 1) the only interface is the command line in `packages/my-agent/src/main.ts`. Its rules (show only validated fields, show only my own error messages, say plainly that nothing is booked) are the seed of everything below. In Phases 2 and 3 a command-line stand-in plays both sides, including the shop's manual approval; the screens below replace it in Phase 4 (00 phase map).

Timing values shown on screen come from the parameter register in 00: offer hold P-01, manual approval wait P-03, clock margin P-09. The strings below quote today's values; if a P-value changes, the strings change with it.

Related: screen inventory and agent contract in 13 Interfaces, personas in 04 Stakeholders and personas, flows in 06 Use cases, states in 07 Process and behaviour models.

2. Design principles

UI principles are numbered UP-1 to UP-7 so they don't collide with the DFD processes P1 to P7 in 07 or the parameters P-01 to P-20 in 00.

#	Principle	What it means on screen	Requirement
UP-1	Nothing commits without a visible yes	The only control that books is a button labelled **Approve**. No swipe, auto-confirm or default-on toggle commits anything.	FR-GATE-01
UP-2	Approval clarity	The approval sheet shows who, what, when, how long, how much and when the offer expires, all from validated structured data, before the button.	FR-APP-02
UP-3	Structured over chatty	Offers, bookings and refusals render as typed cards, never as free text from the other agent. The other agent's words never appear in a bold or system style.	FR-MSG-03, NFR-SEC-05
UP-4	Plain language	Short sentences, no jargon. "Approve" not "Confirm transaction". Times say the day and zone.	NFR-A11Y-01
UP-5	Honest states	Expired, refused, declined, timed-out and failed states are said out loud, with what happens next. Nothing silently disappears.	FR-MSG-04, FR-MSG-05
UP-6	Trust is visible	Verified badge, rating and listing origin appear wherever a business agent is named. Unverified agents look different and say so.	FR-DIR-05, FR-DIR-03
UP-7	Reversible where possible	Decline releases the hold at once; cancel and reschedule are one tap from a booking, within the shop's rules.	FR-BOOK-03, FR-BOOK-08, FR-BOOK-10

3. Information architecture

Three tabs for Dana, one dashboard for Marcus. Everything Dana does starts from a contact or a booking.

4. Wireframes

Low fidelity, mobile first, 360 px wide. `[ ]` is a button, `( )` a toggle, `>` a navigation row.

4.1 Chats list (FR-APP-01)

```
+--------------------------------------+
| Chats                    [Find]      |
+--------------------------------------+
| (MS) Main Street Barbers  ✓ 4.8      |
|      Offer: Thu 5:30 pm · expires 8m |
|--------------------------------------|
| (CL) Corner Laundry       ✓ 4.5      |
|      Booked: Sat 10:00 am            |
|--------------------------------------|
| (??) Quick Cuts         Not verified |
|      You declined an offer           |
+--------------------------------------+
| [Chats]     [Bookings]    [Settings] |
+--------------------------------------+
```

4.2 Agent chat (FR-MSG-02)

```
+--------------------------------------+
| < Main Street Barbers  ✓ 4.8   [...] |
|   mainstreetbarbers.example          |
+--------------------------------------+
|                 You: Haircut Thursday|
|                      after 5 pm      |
|                                      |
| +----------------------------------+ |
| | OFFER                            | |
| | Haircut · 30 min                 | |
| | Thu 12 Nov, 5:30 pm (CST)        | |
| | $30.00 USD                       | |
| | Expires in 8 min                 | |
| | [Review and approve]             | |
| +----------------------------------+ |
|                                      |
+--------------------------------------+
| [ Ask for a time...            ][>] |
+--------------------------------------+
```

4.3 Offer card states

```
Valid              Expired                   Refused by my agent
+---------------+  +----------------------+  +-------------------------+
| OFFER         |  | OFFER EXPIRED        |  | OFFER NOT SHOWN         |
| Haircut 30min |  | The slot was held    |  | This offer didn't match |
| Thu 5:30 pm   |  | for 10 minutes.      |  | what you asked for, so  |
| $30.00 USD    |  | [Ask again]          |  | I didn't show it.       |
| Expires in 8m |  +----------------------+  | [Ask again] [Report]    |
| [Review]      |                            +-------------------------+
+---------------+
```

4.4 Approval sheet (FR-APP-02, FR-GATE-01)

```
+--------------------------------------+
| Approve this booking?                |
+--------------------------------------+
| Main Street Barbers   ✓ Verified     |
| mainstreetbarbers.example            |
|                                      |
| Service   Haircut                    |
| When      Thu 12 Nov, 5:30 pm CST    |
| Length    30 minutes                 |
| Price     $30.00 USD, pay at shop    |
| Offer     expires in 7 min 40 s      |
|                                      |
| Nothing is booked until you approve. |
|                                      |
| [ Decline ]          [ Approve ]     |
+--------------------------------------+
```

Approve is the primary button but never pre-focused. Decline sits on the left so a reflexive thumb tap on the right edge on small phones still lands on a deliberate target, and both meet the size rule in section 7.

Decline sends `offer_declined`, which releases the shop's hold at once (FR-BOOK-08), and the card changes to "You declined this offer." **Expiry** shown here uses the clock margin P-09: my agent counts down from its own receipt time and treats the offer as expired 30 seconds early, so Approve is never pressed on an offer the shop has already let go.

4.5 Booking confirmation (UC-02 postcondition)

```
+--------------------------------------+
|              Booked                  |
|                                      |
| Haircut at Main Street Barbers       |
| Thu 12 Nov, 5:30 pm CST              |
| Added to your calendar               |
|                                      |
| [View booking]      [Done]           |
+--------------------------------------+
```

Shown only after `booking_confirmed` arrives and matches the approved offer field for field (13 Interfaces); only then is it written to the calendar (FR-APP-06). Until then the sheet shows "Booking…" with the Approve button disabled. If the shop is on manual approval the sheet switches to "Waiting for the shop" (section 5) and my agent polls the booking Task (P-04); the person can close the sheet and gets a notification when the shop answers.

4.6 Bookings list and detail (FR-APP-04, FR-BOOK-03)

```
+--------------------------------------+   +--------------------------------------+
| Bookings                             |   | < Booking                            |
| Upcoming                             |   | Haircut · Main Street Barbers        |
| > Thu 12 Nov 5:30 pm  Haircut        |   | Thu 12 Nov, 5:30 pm CST · 30 min     |
| > Sat 14 Nov 10:00 am Laundry pickup |   | $30.00 USD, pay at shop              |
| Past                                 |   |                                      |
| > Thu 15 Oct 6:00 pm  Haircut [Rate] |   | [Reschedule]   [Cancel booking]      |
| > Thu 22 Oct 5:30 pm  Haircut        |   +--------------------------------------+
|   Did it go as booked? [Yes] [No]    |
+--------------------------------------+
```

4.7 Directory search (FR-DIR-02)

```
+--------------------------------------+
| < Find                               |
| [ fade near Downtown             ][Q]|
| Filters: (✓) Verified only  Open now |
+--------------------------------------+
| Main Street Barbers   ✓ 4.8 (212)    |
| Haircut, beard trim · 0.4 mi         |
|--------------------------------------|
| Fade Factory          ✓ 4.6 (88)     |
| Haircut, fade · 0.9 mi               |
+--------------------------------------+
```

Verified only is on by default. Turning it off shows unverified listings with a grey "Not verified" label, never the check mark.

4.8 Listing detail (FR-DIR-05, FR-RATE-02)

```
+--------------------------------------+
| < Main Street Barbers                |
| ✓ Verified business (domain checked) |
| mainstreetbarbers.example            |
|                                      |
| Rating 4.8 from 212 verified visits  |
| Agent record: answers in 1 s ·       |
|   offers honored 99% · 0 reports     |
|                                      |
| Services  Haircut 30 min $30         |
|           Beard trim 15 min $15      |
| Hours     Tue to Sat, 9 am to 6 pm   |
|                                      |
| [Add contact]          [Report]      |
+--------------------------------------+
```

The agent record line is the structured behaviour metric from FR-RATE-02, separate from human stars.

4.9 Barber dashboard: manual-approval queue and outcomes (FR-GATE-05, FR-RATE-04)

```
+-------------------------------------------------------------------------+
| Main Street Barbers · Today, Thu 12 Nov          Approval: Manual (switch) |
+-------------------------------------------------------------------------+
| Waiting for you (2)                                                     |
| Haircut  5:30 pm  Dana R.    approved by customer  [Decline] [Accept]   |
|          answer within 24 min, or it is declined automatically          |
| Beard    6:00 pm  J. Okafor  approved by customer  [Decline] [Accept]   |
+-------------------------------------------------------------------------+
| Book                                                                    |
| 9:00  ▉▉ Haircut      10:00 ▒▒ free       ...                           |
| 17:00 ▉▉ Haircut      17:30 ▓▓ reserved   18:00 closed                  |
+-------------------------------------------------------------------------+
| How did today go? (mark after the appointment)                          |
| 9:00  Haircut  M. Silva     [Completed] [No-show]                       |
| 11:30 Beard    T. Nguyen    Completed ✓                                 |
+-------------------------------------------------------------------------+
```

Legend: ▉▉ booked, ▓▓ reserved (customer approved, waiting for Marcus, P-02), ▒▒ held by an open offer (P-01), ▒▒ free. Holds use pattern, not just colour.

- **Accept** completes the booking Task with `booking_confirmed`; **Decline** ends it with `booking_rejected` reason `shop_declined`. If Marcus does nothing for P-03 (30 minutes), the Task ends with reason `shop_timeout` and the slot is released.
- **Outcomes:** each past booking is marked Completed or No-show by Marcus here, or by the customer's "Did it go as booked?" answer. Completed bookings are what the north star counts (01). If the two sides disagree, the booking is flagged for Sam and counts as neither until resolved.

4.10 Report flow (UC-09, FR-ADMIN-01)

```
+--------------------------------------+
| Report Quick Cuts                    |
| What happened?                       |
| ( ) Pretends to be another business  |
| ( ) Offered something I didn't ask   |
| ( ) Spam or too many messages        |
| ( ) Something else                   |
| Details (optional) [             ]   |
| (✓) Block this contact too           |
| [Cancel]              [Send report]  |
+--------------------------------------+
```

The report attaches the conversation's stored, validated records automatically. Dana doesn't need to screenshot anything.

5. Interaction states

State	Where	What the person sees	What the system does
Loading	Chat after asking	"Asking Main Street Barbers…" with a progress indicator, announced politely	Single deadline per exchange (FR-MSG-05)
Empty	Chats, Bookings	"No chats yet. Find a business to start." with [Find]	Nothing
No availability	Chat	Card: "No haircut slots between Thu 5 pm and 7 pm. Try another time?" [Pick another time]	Shows `no_availability`
Rejected request	Chat	Card: "Main Street Barbers couldn't read that request." [Try again]	Shows `rejected`; reason shown only if it passed validation
Timeout or network error	Chat	"Couldn't get an answer from that agent. Nothing was booked." [Try again]	Own message only, never remote text (NFR-SEC-04)
Expired offer	Offer card, sheet	"This offer expired. The slot was held for 10 minutes." [Ask again]; Approve removed	Hold released at `expiresAt` (P-01); my agent hides Approve 30 s early (P-09)
Declined by you	Offer card	"You declined this offer." [Ask for another time]	`offer_declined` sent; hold released at once (FR-BOOK-08)
Mismatched offer refused	Chat	"Offer not shown: it didn't match what you asked for." [Ask again] [Report]	`offerMatches` failed (FR-MSG-04)
Slot taken at booking	Sheet	"That slot was just taken. Nothing was booked." [See next time]	`booking_rejected` reason `slot_taken`
Waiting on shop	Sheet, chat	"Approved by you. Waiting for Main Street Barbers to accept, up to 30 min."	Booking Task stays WORKING with status "waiting for the shop"; my agent polls `GetTask` (P-04); slot reserved (P-02)
Shop declined	Sheet, chat	"Main Street Barbers declined this booking. Nothing was booked." [Ask for another time]	`booking_rejected` reason `shop_declined`
Shop didn't answer	Sheet, chat	"Main Street Barbers didn't answer in 30 minutes. Nothing was booked." [Ask again]	`booking_rejected` reason `shop_timeout` (P-03)
Offline	Any	Banner "You're offline. Nothing will be sent."	Queues nothing that commits

6. Content and microcopy

Rules: say what happened, then what to do; name the business; give day, time and zone; never blame the person; never print the other agent's free text in our voice.

Exact strings for critical moments:

Moment	String
Approval sheet footer	Nothing is booked until you approve.
Approve button	Approve
Decline button	Decline
After Approve, before confirmation	Booking…
Confirmation title	Booked
Offer expired	This offer expired. The slot was held for 10 minutes.
Mismatched offer	Offer not shown: it didn't match what you asked for.
Network or timeout	Couldn't get an answer from that agent. Nothing was booked.
Slot taken	That slot was just taken. Nothing was booked.
Declined by the person	You declined this offer.
Waiting on the shop	Approved by you. Waiting for Main Street Barbers to accept, up to 30 min.
Shop declined	Main Street Barbers declined this booking. Nothing was booked.
Shop timed out	Main Street Barbers didn't answer in 30 minutes. Nothing was booked.
Outcome question (customer)	Did it go as booked?
Outcome buttons (Marcus)	Completed · No-show
Unverified agent label	Not verified
Cancel confirm	Cancel your haircut on Thu 12 Nov at 5:30 pm?
Cancel done	Cancelled. Main Street Barbers has been told.
Marcus queue item	Approved by customer. Accept to book.
Report sent	Thanks. We'll review this within 2 working days.

Numbers: prices always with currency code; times in the person's zone with the zone abbreviation; durations in minutes.

7. Accessibility (WCAG 2.2 AA, NFR-A11Y-01)

WCAG 2.2 criterion	Rule for Hitchpost
1.3.1 Info and relationships	Offer and booking cards use real headings and description lists, so a screen reader reads "Service, Haircut".
1.4.1 Use of colour	Verified, held and booked states always carry text or pattern, never colour alone.
1.4.3 Contrast (minimum)	Text at least 4.5:1, large text 3:1, checked in light and dark themes.
1.4.11 Non-text contrast	Buttons, toggles and focus rings at least 3:1 against their background.
2.1.1 Keyboard	Every action, including Approve and Decline, works by keyboard and switch access.
2.2.1 Timing adjustable	The offer timer is the business's hold, not a UI time limit. Remaining time is shown as text, and "Ask again" is always offered after expiry.
2.4.3 Focus order	Approval sheet: title, business, each detail row, expiry, footer sentence, Decline, Approve. Focus lands on the title when the sheet opens, never on Approve.
2.4.7 and 2.4.11 Focus visible, not obscured	2 px focus ring; the sticky composer never covers a focused element.
2.5.8 Target size (minimum)	Every target at least 24 by 24 CSS px; Approve and Decline at least 44 by 44 for comfort.
3.3.4 Error prevention (legal, financial, data)	Booking is reviewable (sheet), confirmable (Approve) and reversible (cancel).
4.1.3 Status messages	"Booking…", "Booked", expiry and refusals announced through a polite live region.

Screen reader labels for the approval sheet:

Element	Accessible name
Sheet (dialog)	Approve booking with Main Street Barbers, verified
Detail list	Booking details
Expiry text	Offer expires in 7 minutes 40 seconds (announced at 5, 2 and 1 minute)
Decline	Decline offer from Main Street Barbers
Approve	Approve haircut on Thursday 12 November at 5:30 pm Central, 30 dollars

8. Responsive behaviour

Width	Layout
Under 600 px	Single column, bottom tabs, approval as a bottom sheet covering at least 60% of height
600 to 1024 px	Chats list and thread side by side; approval as a centred dialog
Over 1024 px	Three panes for Marcus: queue, book, detail; Dana's app caps content width at 720 px

Text scales to 200% without loss of content or two-dimensional scrolling (WCAG 1.4.4, 1.4.10). Orientation is never locked.

9. Usability test plan

Method: moderated sessions, think-aloud, 5 customers matching Dana and 5 barbers matching Marcus per round, on a clickable prototype first (before Phase 4 build) and on the real app before v1 release. Rounds repeat until targets are met.

#	Persona	Task	Success metric	Target
UT-1	Dana	Book a haircut for Thursday after 5 pm at a shop you've used	Completed without help; time from opening the app to Booked	5 of 5; median under 60 s
UT-2	Dana	Before approving, tell me the price, time and when the offer expires	All four stated correctly from the sheet	5 of 5
UT-3	Dana	An offer arrives that doesn't match your request. What happened?	Says nothing was booked and why	4 of 5
UT-4	Dana	Cancel Thursday's booking	Completed; no accidental cancel of another booking	5 of 5
UT-5	Dana	Find a verified barber near you and add it	Chooses a verified listing; can explain the check mark	4 of 5
UT-6	Dana	Report an agent pretending to be a shop	Report sent in under 90 s	4 of 5
UT-7	Marcus	Switch your shop to manual approval	Completed without help	5 of 5
UT-8	Marcus	Accept one waiting booking and decline another between customers	Both correct; under 20 s each	5 of 5
UT-9	Marcus	Tell me which slots are held, reserved, and booked	Correctly reads all three patterns	4 of 5
UT-10	Marcus	Mark this morning's appointments: one came, one didn't	Both outcomes correct	5 of 5

Also recorded: System Usability Scale (target 80 or more), every point where a participant thought something was booked when it wasn't (target zero; any instance blocks release), and accessibility passes with one screen reader user and one keyboard-only user per round.

Revision history

Version	Date	Change	Author
1.0	2026-11-09	First baseline	S. Jannisar
1.1	2026-11-09	Remediation after independent review: principles renamed UP-1 to UP-7 and usability tasks UT-1 to UT-10 to avoid ID collisions; barber dashboard placed in Phase 4 with outcome marking (Completed, No-show) and reserved state; Decline sends `offer_declined`; waiting-on-shop uses a WORKING Task with polling, plus shop-declined and shop-timeout states and strings; timings cite P-01, P-03, P-04, P-09	S. Jannisar

HP-SAD-15 · Test strategy and plan

Field	Value
Document ID	HP-SAD-15
Version	1.2
Status	Baselined for Phase 2
Date	2026-11-09
Owner	Sanaullah Jannisar, product and engineering lead
Conforms to	ISO/IEC/IEEE 29119-3:2021 (test documentation: test strategy and test plan information items); ISO/IEC/IEEE 29119-2 risk-based testing

How every requirement gets proven, at which level, against which risk, and what has to pass before anything ships.

1. Purpose and scope

This is the project test plan for Hitchpost from Phase 1 to v1 (end of Phase 6), in the structure of ISO/IEC/IEEE 29119-3. It covers the test items, the features in and out of scope, the risks that drive test priority, the approach per level, a catalogue of test cases with stable IDs (`TC-nn`), entry, exit, suspension and resumption criteria, environments and deliverables. Requirements trace to these test cases in the traceability matrix in 05; every FR and NFR there names its verification method and test cases.

References: 05 Requirements, 11 Quality attributes, 12 Security and privacy, 18 Deployment and operations, 01 v1 release criteria, parameter register in 00.

2. Test policy: test first

Test first for every bug and every trust-boundary rule. Write the failing test, watch it fail, then fix.

The Phase 1 audit is why. Lint, types and 11 tests were all green while five real bugs got through, because the tests only checked the happy path. The fixes all landed test-first, and the auditors' attacks were re-run against the fixed code. The audit also caught one wrong *test* (a 60-minute service expected past closing time), so tests get reviewed like code.

3. Test items

Item	Version under test	Phase
`packages/core` (message types, validators, `offerMatches`)	`main` at the release commit	1 (Built)
`packages/barber-agent` (A2A server, executor, appointment book)	same	1 (Built)
`packages/my-agent` (A2A client `askForSlot` , CLI)	same	1 (Built)
`packages/e2e` (cross-agent and contract suites)	same	2
`packages/directory` (listings API, verification, admin)	same	3
`packages/app` (client app with built-in personal agent, barber dashboard)	same	4
`packages/ratings` (outcomes, metrics, reviews)	same	5
Hosted deployment (staging, production) and CI workflows	tagged release	6 (staging exists from WP-6.1)

4. Features to be tested and not tested

Tested: every FR and NFR in 05, each through the method and test cases its traceability row names.

Not tested, with the reason:

Feature	Why not
The A2A SDK's own transports beyond JSON-RPC (REST, gRPC)	Not advertised in our agent cards until tested; NFR-INT-01 covers what we advertise.
The A2A SDK internals	Third-party, covered by its own suite; we test our use of it end to end.
Payments, deposits, natural-language front end, federation	Out of scope for v1 (01).
Shop-side cancellation over the protocol	Later; in v1 the shop contacts the customer out of band (05).
Load beyond one neighbourhood	v1 targets one area; capacity tests size to the pilot (18).

5. Risk basis

Test priority follows product risk (R- in 03) and security threats (T- in 12). High-risk areas get tests at more than one level.

Risk or threat	What could go wrong	Test response	Priority
R-04, T-01, T-02, T-11	Hostile or malformed input crashes an agent or reaches a person	Validator tables, injection corpus, hostile-agent fixtures (TC-13, TC-15, TC-20, TC-49, TC-50)	High
T-03, R-07	A wrong offer is shown for approval	Offer matching unit and end-to-end (TC-16, TC-21)	High
T-04, T-10	A booking without approval, or approval of A books B	Gate, binding and capability-token tests including a type-level fixture (TC-42, TC-43, TC-48)	High
R-07, NFR-REL-02	Double booking or a lost booking	Concurrency race, idempotent retry, restart survival (TC-35, TC-36, TC-46)	High
T-05, T-06, R-06	One sender exhausts CPU or chairs	Window cap, hold caps, rate limits (TC-13, TC-38, TC-47, TC-93)	Medium
T-08	Error responses leak internals	Error-path probe (TC-30)	Medium
T-12, T-13	Client hangs or is steered to another host	Deadline and origin tests (TC-22, TC-62)	Medium
R-05, T-07, T-15	Fake business agents	Verification from Phase 3 (TC-60); signed cards from Phase 6 (TC-92)	High from Phase 3
T-16	Fake reviews	Rating eligibility (TC-80)	Medium from Phase 5
R-08	Personal data exposure or kept too long	Inspection of message kinds; export and delete (TC-97)	High from Phase 6
R-10	A2A changes break interop	Third-party agent and contract fixtures per version (TC-31, TC-64)	Medium

6. Approach by level

Level	What it proves	Tool	Entry criteria	Exit criteria	Status
Unit	Pure logic: slot finding, validators, offer matching, gate types	`node:test`	Code compiles; `pnpm typecheck` clean	All unit TCs pass; no surviving mutants in validators at release (section 13)	**Built**
Contract	Every `hitchpost/1` message kind is accepted or rejected exactly as 13 specifies; supported old versions still parse	`node:test` table tests over JSON fixtures	Message kind specified in 13 with field limits in 09	Every kind has accept and reject fixtures; all pass	Built (validator tables), Phase 2 (fixtures, TC-31, TC-49)
End to end over A2A	Real server on a free port, real client, card discovery, JSON-RPC, Tasks	`node:test` + `startBarberAgent`; moves to `packages/e2e` in Phase 2	Unit and contract levels green	All end-to-end TCs for the phase pass three runs in a row (no flakes)	**Built**
Security and adversarial	Hostile agents, injection strings, oversized and malformed input, silent servers, error-path leaks	`node:test` hostile fixtures (`SneakyExecutor`, silent server); injection corpus	Threat for the feature listed in 12	Every threat marked "Phase N" in 12 for this phase has a passing TC	Built (first cases), Phase 2 (corpus, TC-30, TC-50)
Performance	Latency against NFR-PERF-01; one request can't block the server	k6 against staging	Staging deployed with production-like data	p95 under 2 s at the pilot load profile in 18	Phase 6
Accessibility	Client app meets NFR-A11Y-01	axe-core in CI plus a manual screen-reader pass	Screen built to the 14 wireframe	Zero serious or critical axe findings; manual pass recorded	Phase 4
User acceptance	Real barbers and customers complete bookings	Pilot in one area, scripted tasks plus observation (17)	Release exit criteria for the pilot build met	Pilot go/no-go in 17 passes	Phase 6

7. Test case catalogue

Built test cases map one to one to a `test(...)` call; the name is exact so it can be searched. Planned test cases name their phase and the package they will live in.

7.1 Built (22, all passing)

TC	File	Test name	Verifies
TC-01	`packages/barber-agent/src/book.test.ts`	skips taken slots	FR-BOOK-04
TC-02	same	a longer service never runs into the next booking	FR-BOOK-04
TC-03	same	a booking off the 30 minute grid still blocks the slots it covers	FR-BOOK-04
TC-04	same	rounds a mid-slot start up to the next slot	FR-BOOK-04
TC-05	same	a window that starts before opening gets the opening slot	FR-BOOK-04
TC-06	same	a service may end exactly at closing, never after	FR-BOOK-04
TC-07	same	latest is inclusive	FR-BOOK-04

TC	File	Test name	Verifies
TC-08	same	never offers a slot in the past	FR-BOOK-04
TC-09	same	closed days and unknown services have no slots	FR-BOOK-04
TC-10	`packages/core/src/booking.test.ts`	accepts a well formed availability request	FR-MSG-03
TC-11	same	normalizes instants with an offset to UTC	FR-MSG-06
TC-12	same	drops fields it does not know	FR-MSG-03, NFR-PRIV-01
TC-13	same	rejects bad availability requests	FR-MSG-03, FR-MSG-06, FR-MSG-07, NFR-SEC-01, NFR-SEC-05, NFR-PERF-02
TC-14	same	parses each kind of barber reply and drops unknown fields	FR-MSG-03, NFR-PRIV-01
TC-15	same	rejects bad barber replies	FR-MSG-03, NFR-SEC-01, NFR-SEC-05
TC-16	same	an offer only matches the request it answers	FR-MSG-04
TC-17	`packages/my-agent/src/ask.test.ts`	my agent asks, the barber agent offers the first free slot	FR-MSG-01, FR-MSG-02, NFR-INT-01
TC-18	same	the barber agent says so when nothing is free	FR-MSG-01, FR-MSG-02
TC-19	same	my agent won't send a request it can't validate itself	FR-MSG-01, FR-MSG-08
TC-20	same	the barber agent rejects a free text message	FR-MSG-01, FR-MSG-02, NFR-SEC-01
TC-21	same	my agent refuses an offer that doesn't answer its request	FR-MSG-01, FR-MSG-04
TC-22	same	my agent gives up on an agent that never answers	FR-MSG-01, FR-MSG-05

7.2 Planned, Phase 2 (`packages/e2e` unless noted)

TC	Test	Verifies
TC-30	Oversized body, malformed JSON and an unknown route return plain JSON errors with no stack trace, file path or `x-powered-by` (`packages/barber-agent`)	NFR-SEC-04
TC-31	The agent card declares the contract extension uri with `required: true`; a message with an unknown `kind` gets `rejected`	FR-MSG-09
TC-32	Availability returns a Message; booking, cancel and reschedule return Tasks	FR-MSG-10
TC-33	An offer carries `issuedAt` and `expiresAt` (P-01); its slot isn't offered to another context before expiry, and is after	FR-BOOK-01
TC-34	`booking_request` with an unknown, expired or other-context `offerId` ends `booking_rejected` with the right reason; the book is unchanged	FR-BOOK-02
TC-35	Two `booking_request`s for the same slot processed concurrently: exactly one `booking_confirmed`	FR-BOOK-02, NFR-REL-02
TC-36	A client that has the `taskId` retries with `GetTask` and gets the same Task, pending or confirmed. A client that lost the response resends `booking_request` without a `taskId`: the new Task completes at once with the same `booking_confirmed` payload plus `duplicateOf` naming the original Task, and the book holds exactly one booking. Same for `cancel_request` (SDK 1.3: a send without `taskId` mints a new Task, `server/index.js:2801`; a send to a finished Task throws, line 2789)	FR-BOOK-07
TC-37	`offer_declined` releases the hold at once	FR-BOOK-08
TC-38	A fourth open hold from one sender is refused (P-07), whatever `contextId`s it uses	FR-BOOK-09
TC-39	Cancel with the right `bookingToken` frees the slot; inside a shop cutoff it ends REJECTED with `cancel_rejected` reason `cutoff`; an unknown booking gives `unknown_booking`	FR-BOOK-03, FR-BOOK-10
TC-40	Reschedule keeps the old booking until the new one is confirmed; a failed new booking leaves the old one standing; inside the shop's cutoff (P-10) the swap ends `booking_rejected` with reason `cutoff`	FR-BOOK-11
TC-41	Manual approval with a fixed clock: Task stays WORKING with a status message; owner yes confirms; owner no gives `shop_declined`; P-03 elapsed gives `shop_timeout`; the reserved slot isn't re-offered meanwhile	FR-GATE-05
TC-42	Booking is impossible without an `Approval`: a fixture that calls the booking path without one fails `tsc`, and no runtime path sends a `booking_request` without one (`packages/my-agent`)	FR-GATE-01, FR-GATE-04

TC	Test	Verifies
TC-43	An approval for offer A can't book offer B; an approval within P-09 of expiry is refused locally	FR-GATE-02
TC-44	Each flow leaves complete, ordered, append-only audit entries on both sides, each with `contextId`, `taskId`, `offerId`, `messageId` and a JCS payload hash	FR-GATE-03, FR-MSG-11, NFR-OBS-01
TC-45	An invalid book configuration (bad hours, duplicate service, bad currency, unparseable booked range) stops the barber agent from starting (`packages/barber-agent`)	FR-BOOK-12
TC-46	Restart the barber agent mid-flow: offers, bookings, audit and Tasks survive; a confirmed booking is never lost	NFR-REL-02
TC-47	Requests above P-08 from one IP get HTTP 429	NFR-SEC-03
TC-48	Capabilities, not `contextId`, authorise: a `booking_request` naming an unknown `offerId` is rejected; `cancel_request` and `reschedule_request` without the matching `bookingToken` are rejected; a client-chosen `contextId` grants nothing (SDK 1.3 keeps the client's `contextId`, `server/index.js:2815`)	FR-MSG-12
TC-49	Contract fixtures: accept and reject cases for every `hitchpost/1` kind, against the limits in 09	FR-MSG-03
TC-50	Injection corpus through every text and time field of every kind is rejected or stored inert	NFR-SEC-01
TC-51	Our clients send the contract extension uri in the `A2A-Extensions` header and are served; a client that omits the header gets `ExtensionSupportRequiredError` (SDK 1.3 checks `context.requestedExtensions`, `server/index.js:2775`)	FR-MSG-09
TC-52	`reschedule_request` is answered as a Message: an `offer` with `replacesBookingId`, `no_availability`, or `rejected` with reason `cutoff` inside P-10	FR-BOOK-11

7.3 Planned, Phases 3 to 6

TC	Phase	Test	Verifies
TC-60	3	Registration publishes only after origin proof; unverified listings stay unpublished	FR-DIR-01
TC-61	3	Search by name, service and area returns matching verified listings, nearest first	FR-DIR-02
TC-62	3	A card whose interface URL has another origin is refused by the client and flagged by the directory	FR-DIR-03
TC-63	3	A business can update and remove its own listing and no other	FR-DIR-04
TC-64	6	An A2A agent built outside this repo completes a booking on staging (RC 6, WP-6.12)	NFR-INT-01
TC-70	4	Contacts are agents, added from the directory or by URL	FR-APP-01
TC-71	4	The approval sheet renders only validated fields as plain text and shows "Nothing is booked until you approve."	FR-APP-02
TC-72	4	The built-in personal agent completes a booking with no external agent	FR-APP-03
TC-73	4	Bookings list shows upcoming bookings; reschedule and cancel work from it	FR-APP-04
TC-74	4	A blocked contact can't reach the person's agent	FR-APP-05
TC-75	4	A matching `booking_confirmed` is written to the calendar; a mismatched one is not and is flagged	FR-APP-06
TC-76	4	axe-core audit of every screen: zero serious or critical findings	NFR-A11Y-01
TC-77	4	Manual screen-reader pass of the approve-and-book flow, recorded (demonstration)	NFR-A11Y-01
TC-80	5	Only verified interactions can be rated, once per side	FR-RATE-01
TC-81	5	Behaviour metrics computed from an audit-log fixture match hand-calculated values	FR-RATE-02
TC-82	5	Human reviews are shown separately from metrics	FR-RATE-03
TC-83	4	The shop marks a past booking Completed or NoShow in the dashboard; the north star counts Completed only	FR-RATE-04
TC-84	5	A listing shows its verification status and rating summary	FR-DIR-05

TC	Phase	Test	Verifies
TC-85	5	A report reaches the moderation queue	FR-ADMIN-01
TC-86	5	The customer's "Did it go as booked?" answer is recorded on the interaction record and never overrides the shop's mark silently (a disagreement is flagged)	FR-RATE-05
TC-87	5	The ratings service accepts an interaction record only when both sides' audit events carry matching JCS SHA-256 hashes of the offer and the decision	FR-RATE-01
TC-90	6	Suspending a listing hides it and notifies the business with the reason	FR-ADMIN-01
TC-91	6	Every moderation action appears in the moderation audit trail	FR-ADMIN-02
TC-92	6	An unsigned card, or one signed by a revoked key, can't book; interaction records carry both sides' signatures (ADR 0017)	NFR-SEC-02
TC-93	6	Per-identity rate limit returns 429 above P-08	NFR-SEC-03
TC-94	6	Load test at the pilot profile: offer round trip p95 under 2 s	NFR-PERF-01
TC-95	6	Monthly availability report from monitoring shows at least 99.5% (analysis)	NFR-REL-01
TC-96	6	One trace id follows a booking across directory, both agents and the app	NFR-OBS-01
TC-97	6	Export and delete of a test person's data within P-13; backups expire per P-15	NFR-PRIV-02
TC-98	6	Time-zone and daylight-saving cases: local grid, skipped local time has no slot, repeated local time offered once	FR-BOOK-05
TC-99	6	Booking through the MCP connector is a conditional write; a conflicting write on the shop's system makes the booking fail cleanly	FR-BOOK-06

8. Coverage summary

Counts are by requirement; the detail is the traceability matrix in 05.

Area	Requirements	Built and tested now	Planned test cases
MSG	12	FR-MSG-01 to FR-MSG-08 (TC-11 to TC-22)	TC-31, TC-32, TC-44, TC-48, TC-49, TC-51
BOOK	12	FR-BOOK-04 (TC-01 to TC-09)	TC-33 to TC-41, TC-45, TC-52, TC-98, TC-99
GATE	5	None (Phase 2)	TC-41 to TC-44
DIR	5	None (Phase 3)	TC-60 to TC-63, TC-84
APP	6	None (Phase 4)	TC-70 to TC-75
RATE	5	None (Phases 4 and 5)	TC-80 to TC-83, TC-86, TC-87
ADMIN	2	None	TC-85, TC-90, TC-91
NFR	16	NFR-SEC-01, NFR-SEC-05, NFR-PERF-02, NFR-INT-01 (ours) by test; NFR-SEC-04 by demonstration; NFR-PRIV-01 by inspection	TC-30, TC-46, TC-47, TC-50, TC-64, TC-76, TC-77, TC-92 to TC-97

9. Test data, environments and time

- **Fixed clocks.** Anything that depends on "now" takes it as a parameter (`findFreeSlot(..., now)`, `new BarberExecutor(book, now)`). Tests pin it to 2026-11-01 so they never rot as dates pass. Hold and approval timeouts (P-01, P-03) are tested by advancing the injected clock, never by sleeping.
- **Known calendar.** 2026-11-12 is a Thursday; the test book is open Thursdays 9 to 18 UTC.
- **Free ports.** Servers bind `127.0.0.1` on port 0, so tests run in parallel and in CI without clashes.
- **Hostile agents are test fixtures.** `SneakyExecutor` in `ask.test.ts` is a subclass of the real executor, so it stays a valid A2A agent with only the lie changed.
- **No real personal data** in any environment before Phase 6; pilot data follows 12 retention.

Environment	Used for	From
Local (Node 24, Windows and Linux)	Unit, contract, end to end, security	Now
CI (`ubuntu-latest`, Node from `.nvmrc`)	Every level that runs in `node:test`; axe-core from Phase 4	Now (workflow), enforced at first push
Staging (18)	Smoke, interop, performance, release candidates	Phase 6 (WP-6.1)
Production pilot	User acceptance only, per 17	Phase 6

10. Suspension and resumption

Suspend when	Resume when
CI is red on `main`	The breaking change is reverted or fixed; CI green on `main`
An end-to-end test fails intermittently	Root cause found and fixed; the test passes three runs in a row
A high or critical security finding is open on the item under test	The fix is merged with a test that failed before it
Staging is down or diverges from the release commit	Staging redeployed from the release tag and smoke test green
A pilot SEV1 per 17	Rollback done, root cause fixed, go/no-go re-run

11. Release exit criteria

A version is tagged only when every applicable row holds. v1 additionally needs every v1 release criterion in 01; the last column says which one each row supports, and criterion 2 (real use) is measured in the pilot, not by tests.

Exit criterion	From	v1 criterion
CI green on the release commit	Now	3
Every requirement claimed for the release passes its verification method and test cases in 05	Now	1
No surviving mutants in the validators (section 13)	Phase 2	3
Injection corpus and hostile-agent tests pass (TC-20, TC-21, TC-50)	Phase 2	3
No booking path reachable without an approval (TC-42, TC-43)	Phase 2	1
Concurrency, idempotency and restart tests pass (TC-35, TC-36, TC-46)	Phase 2	1
Contract fixtures for every supported version still parse (TC-31, TC-49); our clients send the extension header (TC-51)	Phase 2	6
Staging smoke test: register, find, request, approve, book, cancel	Phase 6	1, 4
An agent built outside this repo completes a booking on staging (TC-64)	Phase 6	6
Accessibility checks pass (TC-76, TC-77)	Phase 4	3
Export and delete of a test person's data works (TC-97)	Phase 6	5
Load test within NFR-PERF-01 (TC-94); `pnpm audit` clean	Phase 6	3, 4
Signed cards and per-identity rate limits on (TC-92, TC-93)	Phase 6	3
Restore from backup tested and incident drill run (18)	Phase 6	4
Bug log and journey updated; no open critical or high security issues	Now	3

12. CI gates

Every PR and every push to `main` runs, in order (`.github/workflows/ci.yml`):

1. `pnpm install --frozen-lockfile`
2. `pnpm check` (Biome lint and format)
3. `pnpm typecheck` (tsc, including `erasableSyntaxOnly`)
4. `pnpm test`

All four must pass; the job `lint, typecheck, test` is the required check. The Claude review is advisory.

13. Mutation testing

The QA auditor mutated the code by hand and found 9 changes the old tests didn't notice. To keep that from happening again, I'll run Stryker (or a small mutation script) on `packages/core` and `findFreeSlot`, monthly and before each release. Target: no surviving mutants in the validators. Not in CI on every PR, because it's slow.

14. Deliverables

Deliverable	Where
This test plan	`docs/sad/15-test-strategy.md`
Test cases (code)	`packages/*/src/*.test.ts`, `packages/e2e` from Phase 2
Test results	CI run logs per commit; release notes link the run for the tag
Mutation reports	Attached to the release notes
Defect records	Bug log and GitHub issues
Accessibility and UAT records	Phase 4 accessibility report; pilot report in 17
Test completion report	A section of each phase's journey entry: what ran, what passed, what was deferred and why

Revision history

Version	Date	Change	Author
0.1	2026-11-08	First draft	S. Jannisar
1.0	2026-11-09	Baselined: renumbered into lifecycle order, formal document control, standards conformance	S. Jannisar
1.1	2026-11-09	Remediation after independent review: restructured as a 29119-3 test plan (test items, features not tested, risk basis, entry and exit criteria per level, test case catalogue TC-01 to TC-99, suspension and resumption, environments, deliverables); corrected the coverage table	S. Jannisar
1.2	2026-11-09	Second remediation after regrade: TC-36 rewritten for SDK duplicate handling; TC-38 per sender; TC-48 capability tokens; new TC-51 (extension header), TC-52 (reschedule as a Message with cutoff), TC-86 (customer outcome prompt, FR-RATE-05), TC-87 (hash attestation); TC-83 moved to Phase 4; staging, TC-64 and the smoke test moved to Phase 6	S. Jannisar

HP-SAD-16 · Project plan

Field	Value
Document ID	HP-SAD-16
Version	1.2
Status	Baselined for Phase 2
Date	2026-11-09
Owner	Sanaullah Jannisar, product and engineering lead
Conforms to	ISO/IEC/IEEE 15288:2023, Project planning, Project assessment and control, Decision management, Risk management and Configuration management processes; ISO/IEC/IEEE 16326:2019, project management plan content

1. Purpose and scope

How Hitchpost gets from Phase 1 (built) to the v1 release decision at the end of Phase 6. The plan covers the delivery approach, the work breakdown, estimates, a resource-loaded schedule, milestones and phase gates, resourcing and budget, risk-driven ordering, and governance.

Scope is Phases 2 to 6 as defined in 01 Vision and scope, plus the discovery work that tests the assumptions in 03 Business case. Phases and values come from the phase map and parameter register in 00 Document control. Work after v1 is in 19 Maintenance and evolution.

2. Delivery approach

- **Iterative, with phase gates.** Each phase ships in small pull requests to `main`, each passing CI and review (ADR 0005). A phase closes only when its gate criteria in section 6 are met.
- **One resource.** All work, discovery and build, is done by one person at 15 hours a week. Discovery is not "off the critical path": it takes the same hours as build, and the schedule in section 5 shows them competing.
- **Discovery before the effort it protects.** A failed assumption test must stop work before effort is spent on it. The one exception is stated openly: during the 8-week A-01 test, I build only **protocol-safe work**, meaning work that is worth keeping even if A-01 fails and the project stops at Phase 1 (section 5.1).
- **Test-first.** Every bug fix and every new behaviour lands with a test that failed before it (NFR-MAINT-02). This is the lesson from the Phase 1 audit.
- **Team model.** One lead (me) owns product, architecture, review and every merge. An AI pair (Claude Code) writes most code to my specs. Estimates in this plan are for that team.
- **Audit at each gate.** Before Phases 2, 4 and 6 close, independent reviews run in parallel (QA, security, architecture, DevOps, product). So far these are Claude Code agents run under my direction (00 section 8); an external human review is added before Phase 6.

3. Work breakdown structure

Estimates are three-point, in hours, for the lead plus AI pair: O optimistic, M most likely, P pessimistic. E = (O + 4M + P) / 6. **All figures are estimates.**

3.0 Discovery

WP	Work package	Traces to	O	M	P	E
WP-0.1	Wizard-of-Oz, 8 weeks, about 15 people; time-to-book baseline (pilot stage S0 in 17)	A-01, A-04	24	34	50	35.0
WP-0.2	10 barber interviews incl. the price question; booking-tool API desk audit; verified competitor scan	A-02, A-03, A-07	20	30	50	31.7
WP-0.3	Defensibility and price analysis from WP-0.2 data; A-05 decision record	A-05	6	10	16	10.3
WP-0.4	Trust interviews with listing mockups	A-06	4	6	10	6.3
	Discovery total					**83.3**

3.1 Phase 2: Approval gate

WP	Work package	Traces to	O	M	P	E
WP-2.1	Offer store: `issuedAt`, `expiresAt`, hold (P-01), reserved hold (P-02), `offer_declined`	FR-BOOK-01, FR-BOOK-08	6	10	16	10.3
WP-2.2	`booking_request` as an A2A Task, WORKING while the shop decides, re-check at write; idempotency; ADR 0012	FR-BOOK-02, FR-BOOK-07, FR-MSG-10, FR-MSG-12	10	16	28	17.0
WP-2.3	`Approval` type and the gate in my agent; client polling of `GetTask` (P-04); ADR 0013	FR-GATE-01, FR-GATE-02, FR-GATE-04	6	10	18	10.7
WP-2.4	Append-only audit log on both sides with correlation fields	FR-GATE-03, FR-MSG-11	5	8	14	8.5
WP-2.5	Cancel, `cancel_rejected`, reschedule as an atomic swap	FR-BOOK-03, FR-BOOK-10, FR-BOOK-11	8	14	24	14.7
WP-2.6	Per-shop manual approval switch, shop decision through a command-line stand-in, timeout (P-03)	FR-GATE-05	4	8	14	8.3
WP-2.7	`packages/e2e` with contract tests; contract version as an `AgentCapabilities.extensions` entry	FR-MSG-09, NFR-MAINT-01	4	6	10	6.3

WP	Work package	Traces to	O	M	P	E
WP-2.8	Persistence: SQLite through the SDK's `DatabaseTaskStore` plus offers, bookings and audit tables; JSONL audit on the personal side	NFR-REL-02	6	10	16	10.3
WP-2.9	ADRs, documentation, gate audit	NFR-MAINT-01	4	8	12	8.0
WP-2.10	Validate the shop's book configuration at load (debt D-15)	FR-BOOK-12	2	3	6	3.3
WP-2.11	Open-holds cap (P-07) and basic per-IP rate limit (P-08)	FR-BOOK-09, NFR-SEC-03	3	5	8	5.2
WP-2.12	Clients declare the contract extension in the `A2A-Extensions` header (`ask.ts` now, the app later); contract test	FR-MSG-09	2	3	5	3.2
WP-2.13	Server-minted capabilities (`offerId`, `bookingToken`), duplicate handling with `duplicateOf`, cutoff at reschedule question and swap	FR-MSG-12, FR-BOOK-07, FR-BOOK-11	3	5	8	5.2
	Phase 2 total					**111.0**

3.2 Phase 3: Directory

WP	Work package	Traces to	O	M	P	E
WP-3.2	Directory service and its schema	FR-DIR-01, FR-DIR-04	20	32	50	33.0
WP-3.3	Business verification (well-known token, DNS TXT)	FR-DIR-01	8	12	20	12.7
WP-3.4	Search API `/v1/listings`	FR-DIR-02, FR-DIR-05	8	12	20	12.7
WP-3.5	Card origin check in the client; ADR 0015	FR-DIR-03	6	10	16	10.3
	Phase 3 total					**68.7**

- **WP-3.1** retired: its research moved to WP-0.2. Hosted business agents moved to Phase 6 (WP-6.10), because each needs its own subdomain for origin verification to work.

3.3 Phase 4: Client app and barber dashboard

WP	Work package	Traces to	O	M	P	E
WP-4.1	UI design and prototype test with 5 people	14 UI design, A-08	12	20	32	20.7
WP-4.2	App shell, contacts and chat	FR-APP-01	24	40	64	41.3
WP-4.3	Built-in personal agent	FR-APP-03	12	20	36	21.3
WP-4.4	Approval screen, including decline and waiting-on-shop states	FR-APP-02, FR-BOOK-08	8	12	20	12.7
WP-4.5	Bookings view, reschedule, cancel, block contact, calendar write	FR-APP-04, FR-APP-05, FR-APP-06	10	16	28	17.0
WP-4.6	Accessibility audit and fixes	NFR-A11Y-01	6	10	16	10.3
WP-4.7	Barber dashboard (`packages/dashboard`): manual approval queue, book view, outcome marking	FR-GATE-05, FR-RATE-04	12	20	32	20.7
	Phase 4 total					**144.0**

3.4 Phase 5: Ratings

WP	Work package	Traces to	O	M	P	E
WP-5.1	Interaction records and behaviour metrics	FR-RATE-02	10	16	26	16.7
WP-5.2	Reviews from verified interactions only (hash attestation); customer "Did it go as booked?" prompt	FR-RATE-01, FR-RATE-03, FR-RATE-05	8	14	24	14.7
WP-5.3	Reporting, suspension and moderation trail	FR-ADMIN-01, FR-ADMIN-02, UC-09, UC-10	10	16	28	17.0
	Phase 5 total					**48.4**

- **WP-5.4** retired: the trust interviews moved to WP-0.4.

3.5 Phase 6: Production

WP	Work package	Traces to	O	M	P	E
WP-6.1	Hosting, staging and production environments, infrastructure as code, compile step; ADRs 0014, 0016	NFR-REL-01	16	24	40	25.3
WP-6.2	Agent-to-agent authentication and signed cards; ADR 0017	NFR-SEC-02	16	24	40	25.3
WP-6.3	Per-identity rate limits and abuse controls	NFR-SEC-03	6	10	16	10.3
WP-6.4	Shop time zones; ADR 0018	FR-BOOK-05	8	12	20	12.7
WP-6.5	Connector to one real booking system over MCP, with conditional writes	FR-BOOK-06, A-03	20	36	60	37.3
WP-6.6	Observability, trace ids, SLOs, alerts, backups, tested restore	NFR-OBS-01, NFR-REL-01	12	20	32	20.7
WP-6.7	Privacy notice, retention jobs (P-11 to P-15), export and delete	NFR-PRIV-01, NFR-PRIV-02	10	16	26	16.7

WP	Work package	Traces to	O	M	P	E
WP-6.8	Pre-release security audit, external human review, fixes	NFR-SEC-01 to NFR-SEC-05	12	20	36	21.3
WP-6.9	Pilot run, stage S2 (17 Transition plan), 12 weeks	G-1, G-2	30	45	70	46.7
WP-6.10	Hosted business agents, one subdomain each, per-tenant keys in a KMS; Postgres `slot_claims`	FR-DIR-01, NFR-REL-02	10	16	28	17.0
WP-6.11	Closed alpha, stage S1: 2 barbers, 10 people, 3 weeks on staging	RC 1	10	16	26	16.7
WP-6.12	Third-party interop: an A2A agent not written by me books end to end on staging (TC-64); owner: me; the agent author is recruited through the A2A community	RC 6, NFR-INT-01	6	10	16	10.3
	Phase 6 total					**260.3**

4. Estimate summary

Block	E (hours)	σ (hours)
Discovery	83.3	6.9
2. Approval gate	111.0	6.0
3. Directory	68.7	6.0
4. Client app	144.0	9.9
5. Ratings	48.4	4.8
6. Production	260.3	13.4
Total	**715.7**	**20.5**

σ per work package is (P − O) / 6. The total σ is the square root of the sum of the variances.

- **P80** ≈ E + 0.84σ ≈ **733 hours**. **P95** ≈ E + 1.65σ ≈ **750 hours**.
- PERT assumes work packages are independent, which understates real risk: a slow WP-6.5 also delays WP-6.11 and WP-6.9. A **20% management reserve (143 hours, which the round-up rule in section 5 makes 10 weeks) gives about 859 hours**.
- **Capacity:** 15 hours a week (**estimate** of sustainable solo time), with 2 holiday weeks at each year end. Re-planned if actual capacity runs below 12 hours a week for 4 weeks in a row.
- **What changed from version 1.0:** the 1.0 plan scheduled 624 hours of build at 15 hours a week while also running discovery in parallel, as if discovery took no hours. It also put 170 hours of Phase 6 work into the 7 weeks before the pilot. Loading everything onto one person moved the v1 decision from 2027-10-19 to 2028-01-18 in version 1.1. Version 1.2 adds WP-2.12, WP-2.13 and WP-6.12, applies the round-up rule to every block, and stops counting the two holiday weeks as pilot time; the v1 decision is now **2028-02-08**.

5. Schedule

Start 2026-11-10. Durations are hours divided by 15 hours a week, rounded up to whole weeks, plus holidays. Every block draws on the same 15 hours.

5.1 Window 1: discovery and protocol-safe work (2026-11-10 to 2027-01-12)

Seven working weeks (105 hours; 2026-12-21 to 2027-01-03 is holiday) hold:

Work	Hours	Why it's here
WP-0.1 Wizard-of-Oz (8 weeks elapsed)	35.0	Runs 2026-11-16 to 2027-01-10; about 4 to 5 hours a week of my time
WP-0.2 Interviews, audit, scan	31.7	Barbers interviewed in November and early December, before the holidays
WP-0.3 A-05 analysis	10.3	Uses the WP-0.2 data
WP-2.10 Book configuration validation	3.3	**Protocol-safe:** fixes a real gap in Built code; worth keeping if the project stops
WP-2.7 e2e package and contract tests	6.3	**Protocol-safe:** hardens the Phase 1 reference implementation
WP-2.12 Contract extension header in `ask.ts`	3.2	**Protocol-safe:** without it no client can talk to a Phase 2 agent at all; it fixes the reference client whatever A-01 says
WP-2.9 part: ADR 0012 implementation notes and ADR 0013 draft	4.0	**Protocol-safe:** ADR 0012 (accepted 2026-11-09) fixes the booking protocol; turning it into contract-test fixtures and drafting ADR 0013 is useful to anyone building on A2A, whatever A-01 says
Total	**93.8**	11.2 hours of slack absorb interview scheduling

Nothing else in Phase 2 starts until M-01 records a pass on A-01 and A-04.

5.2 Build windows

Block	Hours	Weeks	Start	End (milestone)
Phase 2 rest (111.0 − 16.8)	94.2	7	2027-01-12	2027-03-02 (M-03)
Phase 3	68.7	5	2027-03-02	2027-04-06 (M-04)
Phase 4	144.0	10	2027-04-06	2027-06-15 (M-05)

Block	Hours	Weeks	Start	End (milestone)
Phase 5 plus WP-0.4	54.7	4	2027-06-15	2027-07-13 (M-06)
Phase 6 before the pilot (incl. S1; staging from WP-6.1)	203.3	14	2027-07-13	2027-10-19 (M-07)
Pilot S2 (WP-6.9 and WP-6.12, about 5 h a week), 12 active weeks	57.0	14	2027-10-19	2028-01-25
Holiday pause inside the pilot (listings paused, 17)		(2 of the 14)	2027-12-20	2028-01-02
Pilot review and v1 decision		2	2028-01-25	2028-02-08 (M-08)

Reserve. The pilot has 12 working weeks (180 hours) and needs 57, so about **123 hours** are free; that absorbs most of the 143-hour reserve if overruns happen there. If the reserve is consumed **before** the pilot, M-07 slides by 10 weeks (the round-up rule) plus the 2-week holiday it then crosses, to 2028-01-11, and M-08 to **2028-04-18** at the latest. So the honest target for the v1 decision is **2028-02-08, no later than 2028-04-18**.

RC measurement window. RC 1 and RC 2 are measured over the 4 active pilot weeks 2027-11-22 to 2027-12-19, so the window never straddles the holiday pause. The 3 active weeks after the pause are for fixes and the pilot review.

Critical path: discovery window → Phase 2 → Phase 3 → Phase 4 → Phase 5 → Phase 6 (WP-6.1 staging → WP-6.11 S1 → go/no-go) → S2 → M-08. Discovery is on it: if A-01 fails at M-01, everything after stops. WP-6.5 (connector) is the least certain item before the pilot.

6. Milestones and phase-gate exit criteria

A gate passes only when every criterion holds. The v1 release criteria (RC) are the six numbered criteria in 01 Vision and scope.

Milestone	Date	Exit criteria	Traces to
M-01	2027-01-12	A-01 (8 weeks) and A-04 measured against their kill criteria; decision recorded; protocol-safe work merged	A-01, A-04
M-02	2027-01-12	A-02, A-03, A-05 and A-07 measured; booking-tool shortlist chosen	A-02, A-03, A-05, A-07
M-03 Phase 2 gate	2027-03-02	No booking without a logged approval, proven by tests; our clients send the contract extension header (TC-51); duplicate retries and capability tokens behave per TC-36 and TC-48; no double booking under concurrent requests; offers, bookings and audit survive a restart; audit logs complete for UC-02 to UC-04; gate audit has no open high findings; ADRs 0012 and 0013 accepted	RC 1, RC 3
M-04 Phase 3 gate	2027-04-06	Verified registration works and unverified is refused; card origin check enforced; search works against the seeded directory	RC 3, RC 6
M-05 Phase 4 gate	2027-06-15	A person completes UC-02 end to end in the app; Marcus accepts and declines in the dashboard and marks outcomes (FR-RATE-04); approval screen shows only validated data; WCAG 2.2 AA audit has no open blockers; gate audit clean	RC 1, RC 2
M-06 Phase 5 gate	2027-07-13	Only verified interactions (matching hashes, TC-87) can be rated; the customer outcome prompt works (FR-RATE-05); report and takedown works end to end with a moderation trail	RC 2, RC 3
M-07 Pilot go-live	2027-10-19	S1 exit criteria met; go/no-go checklist in 17 Transition plan section 7 fully met	RC 3, RC 4, RC 5
M-08 v1 decision	2028-02-08	All six RC hold (RC 6 through WP-6.12); otherwise extend the pilot, or apply the kill criteria in 03	RC 1 to RC 6

7. Resourcing and budget

7.1 People

Role	Who	Allocation
Product and engineering lead, reviewer, merger	Sanaullah Jannisar	15 h/week (**estimate**), the only planned capacity
AI engineering pair	Claude Code	Implementation to spec, under review
Independent reviewers at gates	Claude Code review agents and the review bot, run by me	At M-03, M-05 and before M-07
External human reviewer	Paid or volunteer, to be found	Before M-07 (WP-6.8)
Legal review	External, paid per task	Before M-07
Contributors	Open-source community	Welcome; not planned capacity

7.2 Cash budget to the v1 decision (estimates)

November 2026 to February 2028, 16 months. This is the one budget figure for the package; 02 Feasibility study section 4.2 reconciles to it.

Item	Basis	Amount
AI pair and tools	About $100 a month × 16	$1,600
Domain and DNS	2 years	$40
Staging hosting	About $10 a month, July 2027 to February 2028 (8 months; staging exists from WP-6.1 in Phase 6)	$80
Production hosting	About $50 a month, July 2027 to February 2028 (8 months)	$400
Research incentives	15 × $25 (8-week Wizard-of-Oz) + 10 × $25 (barbers) + 5 × $15 (trust interviews)	$700
Legal review of privacy notice and terms	One-off	$1,500
Subtotal		**$4,320**
Contingency	20%	$864
Total to v1		**$5,184**

GitHub Actions and hosting the public repository cost nothing. The external human review (WP-6.8) is assumed unpaid; if it's paid, it comes out of contingency.

8. Risk-driven ordering

The plan is ordered so the work that retires the biggest risks comes before the work those risks would waste. Risk IDs are from 03 Business case.

Risk	Retired or reduced by	When
R-01 people don't adopt	WP-0.1 Wizard-of-Oz	M-01, before Phase 2 build beyond protocol-safe work
R-03 booking tools block API access	WP-0.2 desk audit	M-02, before Phase 3
R-02 platforms build their own	WP-0.2 scan, WP-0.3 A-05 decision	M-02
R-12 cold start	WP-0.2 recruitment, WP-4.3 built-in agent	Window 1 and Phase 4
R-04 prompt injection and hostile agents	WP-2.3 gate, WP-6.2 auth, WP-6.8 audit	Phases 2 and 6
R-05 fake business agents	WP-3.3 verification, WP-5.3 reporting, WP-6.10 per-tenant origin	Phases 3, 5 and 6
R-06 spam and hold exhaustion	WP-2.11 holds cap and per-IP limit; WP-6.3 per-identity limits	Phases 2 and 6
R-08 privacy breach	WP-6.7 privacy	Before M-07
R-10 A2A breaking changes	WP-2.7 contract tests	Window 1 onward
R-11 solo bandwidth	Capacity monitoring (section 4), cutting scope per section 9.1	Continuous

9. Governance

9.1 Change control

Changes to scope, schedule or a baselined document use the one change process in 00 Document control section 6.2, labelled `docs-change`.

1. The change is proposed as a GitHub issue labelled `docs-change`.
2. I assess its impact on the goals, the release criteria, the estimates, the parameters in 00 section 10 and the risks.
3. Small changes (under 8 hours and no change to a gate criterion or a P-value) are decided in the issue.
4. Larger changes need a decision record, and the affected baselined documents get a new version with a revision history row.
5. **Scope cut order when behind:** Phase 5 moves after v1 first, then FR-APP-05, then FR-RATE-03. The gate criteria themselves are never cut.

9.2 Decision process

Architecturally significant or hard-to-reverse choices get an ADR in docs/decisions before the code that depends on them merges (ADR 0001). ADRs 0012 (booking protocol) and 0018 (time zones, implemented in Phase 6) are accepted. 0013 to 0017 are written as proposals, each with a decide-by milestone: 0013 (M-03), 0015 (M-04), 0014, 0016 and 0017 (before M-07).

9.3 Configuration management

- `main` is the only long-lived branch. It is protected, with squash merges only and the required check `lint, typecheck, test` (18 Deployment and operations).
- Releases are tagged with semantic versions. Baselined documents carry a version and a revision history.
- Dependencies are locked with the pnpm lockfile, and actions are pinned to commit SHAs.

9.4 Status reporting

Report	Cadence	Content	Where
Progress	Weekly	Hours spent vs plan by block (discovery and build), work packages done, blockers, top 3 risks	Journey entry or pinned issue
Metrics (from pilot)	Weekly	North star and counter-metrics from 01	Metrics review
Phase gate	Per gate	Exit criteria evidence, audit report, decision	`docs/audits/` and the journey

Earned value check: at each gate I compare the hours actually spent with the sum of E for completed work packages. If the ratio passes 1.3, I re-estimate the remaining phases before continuing.

9.5 Definition of done (per pull request)

- [ ] The behaviour matches its requirement and the acceptance criteria in 05 Requirements.
- [ ] Every new behaviour and every fix has a test that failed first.
- [ ] `pnpm check`, `pnpm typecheck` and `pnpm test` pass in CI.
- [ ] Inbound data from other agents is validated at the boundary (NFR-SEC-01).
- [ ] The review bot's comments are resolved or answered.
- [ ] An ADR, bug log entry or journey entry is added where needed.
- [ ] Any affected baselined document is updated, with its version bumped; any value used in more than one document cites its P-ID.

Revision history

Version	Date	Change	Author
1.0	2026-11-09	First baseline	S. Jannisar
1.1	2026-11-09	Remediation after independent review: plan resource-loaded on one person at 15 h a week; discovery work packages WP-0.1 to WP-0.4 (A-01 now 8 weeks); protocol-safe work defined for the A-01 window; new WP-2.8 persistence, WP-2.10 book validation, WP-2.11 holds cap and rate limit, WP-4.7 barber dashboard (`packages/dashboard`), WP-6.10 hosted agents per subdomain, WP-6.11 S1 closed alpha on staging; estimate 697 h (P95 731, 836 with reserve); milestones re-baselined, M-07 2027-10-12, M-08 2028-01-18 (latest 2028-03-21); one budget figure, $4,140 ($4,968 with contingency), reconciled with 02; change process `docs-change`	S. Jannisar
1.2	2026-11-09	Second remediation after regrade: added WP-2.12 (extension header), WP-2.13 (capability tokens, duplicates, reschedule cutoff) and WP-6.12 (RC 6 third-party interop); totals 715.7 h (P95 750, 859 with reserve); round-up rule applied (reserve 10 weeks) and the pilot holiday pause no longer counted as pilot time; M-03 2027-03-02, M-07 2027-10-19, M-08 2028-02-08 (latest 2028-04-18); RC 1 and RC 2 window before the pause; staging hosting only from Phase 6; budget $4,320 ($5,184 with contingency); ADRs 0013 to 0017 written as proposals	S. Jannisar

HP-SAD-17 · Transition plan

Field	Value
Document ID	HP-SAD-17
Version	1.2
Status	Baselined for Phase 2
Date	2026-11-09
Owner	Sanaullah Jannisar, product and engineering lead
Conforms to	ISO/IEC/IEEE 15288:2023, Transition process (prepare, perform, manage results) and Validation process; ITIL 4 release management and change enablement practices (informative)

1. Purpose and scope

How Hitchpost moves from a tested build into real use by real barbers and customers in one neighbourhood, without anyone losing a booking. It covers:

- the staged pilot
- onboarding runbooks for barbers and customers
- data conversion
- training and support
- the go/no-go checklist
- rollback
- hypercare
- communications
- the post-implementation review

Operation after hypercare is covered in 18 Deployment and operations. Dates come from 16 Project plan.

2. Transition principles

1. **No booking is ever lost or doubled.** The barber's own booking tool stays the system of record throughout the pilot. Hitchpost writes into it or into a reconciled hosted book. It never runs alongside it unreconciled.
2. **Smallest blast radius first.** Each stage adds users only after the previous stage met its exit criteria.
3. **Every shop can be switched off on its own** in under 5 minutes, with its customers told.
4. **Every number gets measured, not assumed.** The pilot produces the metrics in 01 Vision and scope.

3. Staged pilot design

Stage	When	Who	What runs	Exit criteria	Proves
S0. Wizard-of-Oz (WP-0.1)	2026-11-16 to 2027-01-10 (8 weeks)	About 15 people, any barbers they use	No software. I act as each person's agent and as the barber's agent over WhatsApp, following the UC-02 flow by hand	At least 60% complete one booking through the agent, at least 30% complete two, and first-offer approval at least 50% (A-01 rule); time-to-book at least 50% faster than baseline (A-04)	A-01, A-04
S1. Closed alpha (WP-6.11)	2027-09-21 to 2027-10-12 (3 weeks)	2 friendly barbers, 10 people from S0	Phase 2 to 6 pre-pilot build on **staging**, which exists from WP-6.1 (Phase 6); hosted book reconciled with the shop's tool daily, by hand	Zero double bookings; zero bookings without approval; every booking reconciled; barbers would continue	RC 1 under real use
S2. Pilot (WP-6.9)	2027-10-19 to 2028-01-25 (12 active weeks plus the 2-week holiday pause)	5 to 10 barbers in one neighbourhood, target 50+ people	Production build, connector or calendar sync per shop (section 4.3)	The v1 release criteria in 01, measured over the last 4 weeks	RC 1 to RC 6
S3. v1 decision (M-08)	2028-02-08	Me	Review of S2 results	Go: v1 release. Extend: up to 4 more pilot weeks. Stop: apply the kill criteria in 03	G-1 to G-5

S0 runs 8 weeks because people book every 3 to 4 weeks (04); a shorter test couldn't observe a second booking. S1 depends on staging, so it sits inside Phase 6 after WP-6.1, not before it. Dates come from 16 Project plan section 5.

Holiday pause. From 2027-12-20 to 2028-01-02 every pilot listing is set to `paused`, with two weeks' notice to shops and their customers. Paused agents answer new requests with `rejected` ("temporarily unavailable"); confirmed bookings in the pause stay in the shop's own tool. Because nothing new is booked through Hitchpost while paused, no SEV1 response is promised in those two weeks (P-17). RC 1 and RC 2 are measured over the 4 active weeks 2027-11-22 to 2027-12-19, so the measurement window never straddles the pause (16 Project plan).

Pilot neighbourhood selection: at least 15 barbershops within walking distance, at least 3 of them from the A-02 interviews willing to list, and close enough for me to visit any shop the same day.

4. Barber onboarding runbook

Target: the barber's own time at the visit is **15 minutes or less**, done in person by me during S1 and S2. End to end, from signup to the first offer sent, G-2 in 01 targets a median of at most 30 minutes and a 90th percentile of at most 2 hours; section 4.5 records it per shop.

4.1 Before the visit (operator, about 20 minutes)

- [ ] Shop's booking tool identified. Connection path chosen per section 4.3.
- [ ] Services, prices, durations and opening hours collected from the public listing or booking page.
- [ ] Listing drafted in the directory, not published.
- [ ] Verification method chosen (section 4.2).

4.2 Verification (FR-DIR-01)

Shop has	Method	Evidence kept
Its own website	Well-known token at `/.well-known/` on the shop's domain, or a DNS TXT record	Token check result, timestamp
No website (common for barbers)	Agent hosted by Hitchpost on its own subdomain, `<slug>.agents.hitchpost.dev` (WP-6.10), so origin verification can tell hosted shops apart; identity confirmed by an in-person visit plus a phone call to the number on the shop's public listing	Operator verification record: who, when, method, photo of the shop front with consent

The in-person method is a **pilot procedure**. It doesn't scale beyond one neighbourhood. A scalable method for shops without a domain gets an ADR before any expansion (debt D-14 in 19 Maintenance and evolution).

4.3 Booking-tool connection

Chosen per shop from the A-03 audit result:

Option	When	How	Reconciliation
C1. MCP connector to the shop's tool (FR-BOOK-06)	The tool allows programmatic reads and writes under its terms	Shop owner authorizes the connection; the agent reads availability and writes bookings	Automatic. A daily check compares Hitchpost bookings with the tool.
C2. Calendar sync	The tool exports and imports a calendar but has no booking API	Busy blocks are read from the calendar; Hitchpost bookings are written as calendar events	Daily check; the barber confirms new bookings appear in the tool
C3. Hosted book	No usable integration	Hitchpost holds the book; the barber sees Hitchpost bookings in the app	Barber blocks Hitchpost slots in their own tool. A daily reminder lists bookings to mirror.

C3 carries the highest risk of double booking. Shops on C3 are capped at 3 of the pilot, and each gets a daily reconciliation in hypercare.

4.4 At the visit (barber's time, 15 minutes or less)

1. Explain what Hitchpost does and the standing-approval default: bookings in open hours are accepted. Offer the manual-approval switch (FR-GATE-05). (3 min)
2. Confirm services, prices, durations and hours from the draft listing; correct them on the spot. (4 min)
3. Complete the connection authorization (C1), confirm the calendar (C2), or show the hosted book (C3). (4 min)
4. Run one live test booking from my phone; the barber sees it arrive and confirms it in their tool. (3 min)
5. Publish the listing and place the QR code at the counter. (1 min)

4.5 After the visit

- [ ] Listing published and searchable (FR-DIR-02).
- [ ] Test booking cancelled and the cancellation seen in the shop's tool.
- [ ] Shop added to the hypercare reconciliation list.
- [ ] Onboarding time recorded for G-2.

5. Customer onboarding

1. **Entry points:** the QR code at the counter, a personal invite from the S0 group, or a link shared by the barber.
2. **Install and consent:** the person installs the client app and reads the privacy notice in plain language (12 Security and privacy). Account creation asks for a name and a contact method only (NFR-PRIV-01).
3. **First contact:** the QR code adds the shop's agent as a contact directly (FR-APP-01). The built-in personal agent is enabled by default (FR-APP-03).
4. **Guided first booking:** a short in-app walkthrough of the approval screen (FR-APP-02). It covers what will be booked, until when the offer holds, and that nothing happens without a yes.
5. **Follow-up:** a reminder before the appointment, and a single question after it ("Did it go as booked?"). The answer feeds the honored-booking metric.

6. Data conversion and migration

There is no legacy Hitchpost data to migrate. Conversion means bringing each shop's existing setup into Hitchpost correctly.

Data	Source	Target	Rule	Check
Services, durations, prices	Public listing or booking page; confirmed at the visit	`Service` in 08 Data design	Prices in integer cents; durations in whole minutes	Barber confirms every line at the visit

Data	Source	Target	Rule	Check
Opening hours	Same	`OpeningHours`, with the shop's IANA time zone (ADR 0018)	Local times stored with the zone; UTC on the wire	Test offer at opening and at closing time is correct
Existing bookings	Shop's tool (C1, C2) or the barber's word (C3)	Busy blocks: start and duration only	**No customer names or contact details are imported** (NFR-PRIV-01)	Count of busy blocks for the next 14 days matches the tool; 10 spot checks
Shop identity	Verification (section 4.2)	`DirectoryListing` and verification record	Per FR-DIR-01	Listing shows the verified status (FR-DIR-05)

Reconciliation sign-off: a shop goes live only after the busy-block count matches and the test booking round-trips. The operator records both in the shop's onboarding record.

7. Cutover: go/no-go checklist for S2 (milestone M-07)

Every item must be **Go**. Any **No-go** item moves the go-live date.

#	Item	Evidence	Traces to
1	Phase 2 to 5 gates passed	Gate records in `docs/audits/`	M-03 to M-06
2	S1 exit criteria met	S1 report	RC 1
3	Pre-release security audit: no open high or critical findings	Audit report	RC 3, WP-6.8
4	Agent-to-agent authentication and rate limits on in production	Config and test evidence	NFR-SEC-02, NFR-SEC-03
5	Monitoring and alerts on the booking path; on-call is me, with phone alerts	Dashboard and a test alert received	RC 4, NFR-OBS-01
6	Backups running; a restore tested within the last 14 days	Restore log	RC 4
7	Incident runbook drilled once	Drill notes	RC 4
8	Privacy notice published; retention jobs running; export and delete tested	Links and test evidence	RC 5, NFR-PRIV-02
9	Terms reviewed by a lawyer	Review note	R-07
10	Per-shop kill switch tested on staging	Test evidence	Section 8
11	Every launch shop reconciled and signed off (section 6)	Onboarding records	Principle 1
12	Support line staffed, with response targets (P-17) published	Support page	Section 9, P-17
13	Rollback rehearsed on staging within the last 7 days	Rehearsal notes	Section 8

8. Rollback plan

8.1 Triggers

Severities and their triggers are defined once, in the SEV table in 19. This plan only says what each one means for the pilot.

Severity	Pilot action
SEV1	Full rollback (8.3) within 1 hour; incident process per 18
SEV2	Per-shop rollback (8.2) for the affected shops
SEV3	Normal fix through a pull request

8.2 Per-shop rollback (under 5 minutes)

1. Set the shop's listing to `paused` (a `ListingStatus` value in 09 Data dictionary). Its agent answers new requests with `rejected` and the reason "temporarily unavailable"; open holds and reserved offers are released.
2. Confirm that bookings already made remain in the shop's own tool (C1, C2). For C3, send the barber the list of upcoming Hitchpost bookings.
3. Message affected customers with the shop's phone number and their booking details.
4. Log the rollback in the incident record.

8.3 Full rollback (within 1 hour)

1. Pause every listing (one operator action).
2. Redeploy the previous release tag, or keep the service read-only if the defect is in the new release.
3. If data is suspect, restore the last known-good backup (P-15, RPO 5 minutes for infrastructure loss). Confirmed bookings are never lost, because each is committed before `booking_confirmed` is sent (00); replay the audit logs on both sides to find bookings made since the restore point and confirm each one with its shop.
4. Send each barber the upcoming-bookings list, and send customers the contact message.
5. Resume only after root cause is found, a test that reproduces it is added, and the go/no-go items affected are re-checked.

9. Training and support

Audience	Material	Format
Barbers	One-page guide: what arrives, how to switch manual approval, how to pause	Printed and PDF

Audience	Material	Format
Barbers	2-minute video of a booking arriving in their tool	Video link
Customers	In-app walkthrough of the first booking; FAQ	In app
Developers (Priya)	Contract and conformance tests, listing guide	Repo docs (13 Interfaces)
Operator (Sam)	Onboarding runbook (section 4), rollback (section 8), moderation steps	Repo docs

Support during the pilot: one WhatsApp business number and email, staffed by me. The response targets are P-17, kept in one table in 19 Maintenance and evolution; this plan doesn't restate them. During hypercare I also send the daily check-in in section 10, but the committed targets don't change.

A SEV1 report goes straight to the incident process at any time while listings are live; during the holiday pause nothing is live, so no cover is promised.

10. Hypercare

- **Duration:** the first 14 days after each shop goes live. It's per shop, so the pilot runs rolling hypercare.
- **Daily during hypercare:**
  - reconcile Hitchpost bookings with the shop's tool
  - review the audit log for any booking without an approval
  - review errors on the booking path
  - send a 1-line check-in to the barber
- **Exit criteria per shop:**
  - 10 consecutive days with zero reconciliation differences
  - at least 5 honored bookings
  - zero SEV1 or SEV2 incidents in the last 7 days
  - the barber confirms they want to continue
- **On exit:** the shop moves to normal operations and weekly reconciliation.

11. Communications plan

Audience	Message	Channel	When	Owner
S0 participants	Invitation, what to expect, consent	WhatsApp	2026-11-16	Me
Interviewed barbers	Thanks, results summary, alpha or pilot invite	In person, message	After M-02	Me
Pilot barbers	Onboarding date, what changes, support contacts	In person, printed guide	1 week before their go-live	Me
Pilot customers	How to book by message, privacy notice	QR code, in app	At go-live	Me
All pilot users	Planned maintenance, incident notices	In app, WhatsApp	24 hours before; or as it happens	Me
Open-source community	Pilot start, findings, v1 decision	Repo journey, release notes	M-07, M-08	Me

12. Post-implementation review template

Held 2 weeks after S2 ends and filed in `docs/audits/`.

```
# Post-implementation review: <stage>

- Date, attendees, stage dates
- Goals and release criteria: target vs actual (G-1 to G-5, RC 1 to RC 6)
- North star and counter-metrics: weekly trend, baseline comparison (A-04)
- Assumption results: A-01 to A-08, each confirmed, refuted or open, with evidence
- Incidents: count by severity, root causes, fixes, tests added
- Onboarding: median barber time (G-2), verification issues, connection option mix (C1, C2, C3)
- Support: volume, response times vs targets, top 5 questions
- Cost: cash spent vs budget in HP-SAD-16, hours spent vs estimate
- What worked, what didn't, what I'd change
- Decision: go, extend or stop, with reasons
- Actions: owner, due date, tracking issue
```

Revision history

Version	Date	Change	Author
1.0	2026-11-09	First baseline	S. Jannisar
1.1	2026-11-09	Remediation after independent review: S0 is 8 weeks with the new A-01 rule; S1 moved inside Phase 6 after staging exists (WP-6.11); S2 12 weeks; dates from the re-baselined plan (M-07 2027-10-12, M-08 2028-01-18); hosted agents on their own subdomain; `paused` matches `ListingStatus`; support targets link to P-17 in 19; restore wording uses P-15 and the zero-loss rule; G-2 target restated	S. Jannisar
1.2	2026-11-09	Second remediation after regrade: S1 2027-09-21 to 2027-10-12, S2 2027-10-19 to 2028-01-25 with a 2-week holiday pause (listings paused, no SEV1 cover promised), M-08 2028-02-08; RC 1 and RC 2 window before the pause; rollback triggers now cite the single SEV table in 19	S. Jannisar

HP-SAD-18 · Deployment and operations

Field	Value
Document ID	HP-SAD-18
Version	1.2
Status	Baselined for Phase 2
Date	2026-11-09
Owner	Sanaullah Jannisar, product and engineering lead
Conforms to	ISO/IEC/IEEE 12207 (transition and operation processes); ITIL 4 practices (informative)

How code gets from a branch to production, where it runs, and how it's watched and recovered. Values (P-) and phases come from 00 Document control.

1. Environments

Environment	Purpose	Data	Status
Local	Development; both agents on `127.0.0.1`	Demo book in `packages/barber-agent/src/main.ts`	**Built**
CI	Lint, type check and tests on every PR and push	Test fixtures only	**Built** in `.github/workflows/ci.yml`, not yet run on GitHub
Preview	One deploy per PR for the directory and app	Seeded fake data	Phase 3
Staging	Mirrors production; release candidates; closed alpha S1; pilot rehearsal	Fake businesses, my own test bookings, then the S1 shops	Phase 6 (created by WP-6.1, before S1)
Production	Real barbers in one area	Real	Phase 6

2. CI/CD today

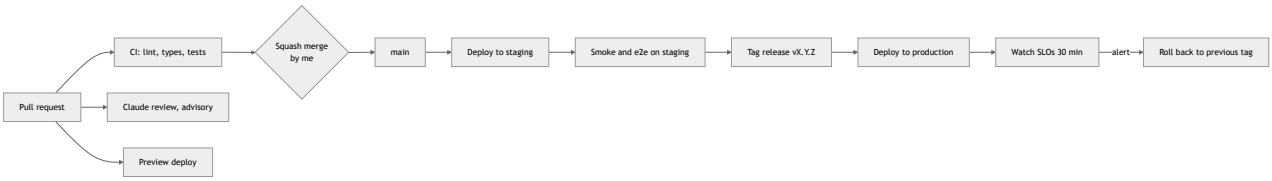
- **CI:** `ci.yml` runs install with the frozen lockfile, Biome, tsc and tests on Node from `.nvmrc` (24). The actions are pinned to commit SHAs. Superseded PR runs are cancelled; runs on `main` always finish.
- **Review:** `claude-review.yml` runs an advisory review on same-repo PRs. It needs the Claude GitHub App and the `ANTHROPIC_API_KEY` secret.
- **Dependencies:** Dependabot weekly for npm and GitHub Actions (`.github/dependabot.yml`).
- **Not yet:** no remote, so nothing is enforced and nothing deploys.

First push checklist

From the DevOps audit:

1. Create `Jannisar01/hitchpost`, push `main`, confirm CI green.
2. Merge settings: squash only, PR title and body as the commit, delete branches on merge.
3. Default workflow token: read-only; workflows can't approve PRs.
4. Ruleset on `main`: no deletion, no force push, PR required (0 approvals, since I'm the sole maintainer), squash only, required check `lint, typecheck, test`.
5. Turn on private vulnerability reporting and vulnerability alerts.
6. Install the Claude GitHub App; add `ANTHROPIC_API_KEY`.
7. Open the Phase 1 branch as the first real PR.

3. CI/CD target



- **Preview deploys** (Phase 3): each PR gets its own directory and app URL, torn down on merge.
- **Staging** (from Phase 6, WP-6.1) deploys automatically from `main`.
- **Production** deploys only from a release tag, after the release exit criteria.
- **Rollback** means redeploying the previous tag. Database migrations must be backward compatible for one release so rollback is always safe.
- **Build step:** before hosting, packages need a compile step (ADR 0016). Today `exports` point at `.ts` source, which only works locally (19, debt D-02).

4. Versioning and releases

- **Packages:** semantic versioning. Releases are tagged `vX.Y.Z` with release notes drawn from the PR titles.
- **Message contract:** versioned separately from the code, from Phase 2 (13).
  - Declared on the agent card as an `AgentCapabilities.extensions` entry with uri `https://hitchpost.dev/ext/contract/v1` and `required: true`; each message lists that uri in its `extensions`. The A2A `AgentCard` has no metadata field, so the version can't live there.
  - **Major versions only.** Additive changes (a new optional field, a new message kind) keep the version. A breaking change gets a new major uri, and both majors are accepted for P-18 (6 months) after the new one ships (19).
- **A2A protocol:** pinned to the SDK's spec version (v1.0 today). SDK upgrades go through their own PR with the e2e tests.

5. Hosting

Proposed as ADR 0014 (one container platform plus managed Postgres). The options:

Option	Fits	Costs	Concerns
Fly.io or Render (containers, managed Postgres)	Long-running Node servers, WebSockets/SSE for A2A streaming, simple ops	Low at pilot scale	Smaller vendors; check region and backup options
Cloudflare Workers + D1	Cheap, global, the A2A SDK supports D1 stores	Very low	Express-based server needs porting; Workers runtime limits
AWS (ECS Fargate + RDS)	Scales anywhere, every compliance box	Higher, more ops work	Overkill for one-area pilot
Serverless functions (Vercel)	Fine for the app front end	Low	Poor fit for long agent tasks and streaming

Proposed (ADR 0014): option A. One container platform (Fly.io or Render) with managed Postgres. The directory (which also hosts the admin pages), the ratings service, the barber dashboard (from Phase 4) and the hosted business agents run there. The app front end goes on a static or edge host. The vendor choice between Fly.io and Render is confirmed with a pilot cost estimate before Phase 6.

- **Hosted business agents get one subdomain each**, `<slug>.agents.hitchpost.dev`, served by the same container. One origin per shop is what lets origin verification tell hosted shops apart, and it keeps each agent card at its own origin root as `.well-known` requires (RFC 8615).
- **Bookings stay correct with more than one instance:** holds and bookings live in one Postgres `slot_claims` table with a time-range exclusion constraint per business, so two instances can't claim the same slot. With a real booking system over MCP, the write must be conditional or atomic on that system (FR-BOOK-06).
- **Before Phase 6** there is no hosting: Phase 2 to 5 run locally, with SQLite on the business side (phase map in 00).

6. Configuration and secrets

- **Config through environment variables**, validated at startup. The server refuses to start on a missing or bad value. Today only `PORT` exists (`packages/barber-agent/src/main.ts`).
- **The public agent URL comes from config** (`PUBLIC_URL`), not from the bind address as it does today (`server.ts`).
- **Secrets** (database URLs, signing keys, API keys) live in the host's secret store and GitHub Actions secrets. Never in the repo: `.env*` is git-ignored, except `.env.example`.
- **Card signing keys** (Phase 6, NFR-SEC-02): cards are signed as a JWS over the JCS-canonical card (RFC 8785); public keys are published as a JWKS at a URL registered in the directory listing. Hosted shops' keys are held by the platform in a KMS, one key per tenant.
  - **Scheduled rotation**, yearly: the old public key stays in the JWKS for 30 days so recently signed cards still verify.
  - **Suspected compromise:** the key is revoked immediately, removed from the JWKS, and the listing is flagged until a new key is in place. There is no grace period in that case.

7. Observability

- **Logs:** structured JSON, one line per request.
  - **Fields:** request id, agent, method, outcome, latency, and from Phase 2 the correlation fields `contextId`, `taskId`, `offerId`, `messageId` (FR-MSG-11). `contextId` is client-chosen and used for correlation only. The capabilities (`offerId`, `bookingToken`) are logged only as hashes, never in clear.
  - **No message bodies, no personal data** (see 12).
  - **Retention:** 30 days.
- **Metrics:** requests by outcome (`offer`, `no_availability`, `rejected`, error), latency histograms, approvals and declines, bookings, rate-limit hits, card-fetch failures.
- **Traces** (Phase 6): OpenTelemetry across directory lookup, agent-to-agent call and booking write. One trace id flows through the A2A message `metadata` field (the message has one; the card doesn't).
- **Product metrics,** from the audit logs:
  - the north star: weekly human-approved bookings that were honored
  - counter-metrics: first-offer rejection rate, median time to approve, booking errors, reports per 100 interactions, repeat use within 60 days

SLOs (pilot)

SLI	SLO	Requirement
Offer round trip (request to validated offer), p95	under 2 s	NFR-PERF-01
Directory availability, monthly	99.5%	NFR-REL-01

SLI	SLO	Requirement
Confirmed bookings lost or duplicated	0	NFR-REL-02
Booking path traceable end to end	100% of bookings	NFR-OBS-01
Directory search, p95	under 500 ms	Operational target only; no requirement sets it
Successful business-agent replies (non-5xx), 30 days	99.5%	Operational target only; NFR-REL-01 covers the directory only

Dashboards and alerts

One dashboard per service: traffic, errors, latency, saturation, plus a product panel.

Alert	When	Severity
Error budget burn	2% of the monthly budget in 1 hour	Page
Booking write failures	Any	Page
p95 latency over SLO	15 minutes	Ticket
Card-fetch failure spike or rate-limit hits	Over baseline	Ticket
Certificate expiry, backup failure	Any	Ticket

8. Incident response (runbook outline)

1. **Detect:** an alert or a user report (issue, email, in-app).
2. **Triage:** assign a severity from the single SEV table in 19.
3. **Mitigate first:** roll back to the previous tag, turn on rate limits, or delist an abusive agent.
4. **Communicate:** a status note on the repo and to affected businesses. For SEV1, update every hour. Response targets per severity are P-17, kept in 19.
5. **Resolve and verify** against the SLO dashboard.
6. **Post-incident review** within 5 days, blameless. Add it to the bug log with root cause and prevention, and add a test.
7. **Security incidents** also follow SECURITY.md and the breach-notification duties in 12.

9. Backups and disaster recovery

Backups follow P-15: a daily full backup plus continuous WAL, expiring after 30 days, with no separate cold-storage export. Expiry is what lets an erasure request (P-13) also reach backups: erased from live systems within 30 days, gone from backups within 60 days at most.

Data	Backup	RPO	RTO
Directory and bookings (Postgres)	Managed point-in-time recovery (continuous WAL) plus a daily full backup to another region	5 minutes for infrastructure loss; 0 for confirmed bookings (below)	4 hours
Audit logs	Append-only, in the same database, so covered by the same backups	5 minutes	4 hours
Config and code	Git and the host's config history	0	1 hour

Zero loss and RPO are not in conflict. A booking is committed synchronously before `booking_confirmed` is sent, so a crash leaves either no booking and no confirmation, or both. The 5-minute RPO applies to everything else (offers, the audit tail, directory edits) and to loss of a whole region. The NFR-REL-02 target of zero lost confirmed bookings holds on that basis.

- **Restore drills:** quarterly, into staging, timed against the RTO. One tested restore and one incident drill are part of v1 release criterion 4 (01).

10. Capacity and cost notes

- **Pilot load:** about 20 barbers, a few hundred people, under 1 request per second at peak. One small container per service and a small Postgres cover it.
- **Hosting estimate:** roughly $20 to $60 a month plus the domain. To be confirmed in the hosting ADR.
- **The Claude review's API spend is the main variable cost.** If it grows, limit the review to code paths with `paths-ignore` for docs.
- **Scale-up triggers:** p95 latency near the SLO, CPU above 70% sustained, or more than one area live.

Revision history

Version	Date	Change	Author
0.1	2026-11-08	First draft	S. Jannisar
1.0	2026-11-09	Baselined: renumbered into lifecycle order, formal document control, standards conformance	S. Jannisar
1.1	2026-11-09	Remediation after independent review: contract version as an `AgentCapabilities.extensions` entry, major versions only (P-18); hosted agents one subdomain each and `slot_claims` exclusion constraint; card signing and revocation specified; correlation fields from Phase 2; SLOs mapped to the right NFRs and operational targets marked; backups per P-15 with no cold-storage export; zero-loss vs RPO stated; staging created before S1	S. Jannisar
1.2	2026-11-09	Second remediation after regrade: triage cites the single SEV table in 19; backups expire after 30 days (P-15); logs record capabilities only as hashes, contextId is correlation only	S. Jannisar

HP-SAD-19 · Maintenance and evolution

Field	Value
Document ID	HP-SAD-19
Version	1.2
Status	Baselined for Phase 2
Date	2026-11-09
Owner	Sanaullah Jannisar, product and engineering lead
Conforms to	ISO/IEC/IEEE 14764 (software maintenance); ISO/IEC/IEEE 12207 maintenance process

What happens after production: support, versioning, patching, the debt I'm carrying, how the docs stay true, and where the system goes after v1. Also how it ends, if it does. Values (P-) and phases come from 00 Document control.

1. Support model

This is the one support table for the package (P-17). 17 Transition plan and 18 Deployment and operations link here instead of restating it.

Severity and response targets (P-17). This is the single severity table for the package; incident response in 18 and the pilot rollback in 17 cite it and don't restate the definitions.

Severity	Meaning	First response	Resolution target
SEV1	Any double booking or lost confirmed booking caused by Hitchpost; any booking without a logged approval; any security or personal-data breach	1 hour, any time while any listing is live (none promised while pilot listings are paused, 17)	Mitigate (rollback or pause) within 1 hour; fix with a test before resuming
SEV2	Service down or degraded, including an error rate on the booking path above the SLO for 1 hour; one shop's sync failing for more than 2 hours	4 business hours	Next patch release
SEV3	Minor, cosmetic or non-booking defect	Acknowledged at triage	Next release
Community issue (not a SEV)	Feature request, question, docs	Triaged within 5 days	Backlog; `good first issue` where possible
Security report	Private vulnerability reporting (SECURITY.md)	Acknowledged within 72 hours	Patched per P-16

Channels by audience:

Who	Channel
Pilot barbers (Marcus)	Direct line (phone or WhatsApp) during the pilot
People using the app (Dana)	In-app help, then email
Developers (Priya)	GitHub issues and discussions
Security reporters	Private vulnerability reporting

2. Issue triage

Weekly triage. Every new issue gets a type label (`bug`, `enhancement`, `docs`, `security`) and, for defects, a severity from section 1. I use SEV labels rather than P0 to P3, so issue priorities don't collide with the P- parameter IDs.

3. Release cadence

- **Patch releases** as needed for fixes. Security fixes ship the same day they're ready.
- **Minor releases** every 4 to 6 weeks during active phases.
- **Major releases** only for breaking changes to the message contract or public APIs, announced at least one minor release ahead.

4. Message contract versioning and deprecation

The booking messages (13) are a public contract other people's agents depend on (NFR-INT-01).

- **Versioning:** major versions only, declared on the agent card as an `AgentCapabilities.extensions` entry (`https://hitchpost.dev/ext/contract/v1`, `required: true`) from Phase 2, and listed in each message's `extensions`. There are no minor versions.
- **Additive changes** (new optional fields, new message kinds) keep the current version and need no deprecation.
- **Breaking changes** need a new major uri. **An old version stays supported for 6 months after the next one ships (P-18).**
- **Deprecation notice:** in release notes, in the directory listing of affected agents, and as a warning field in replies to old-version messages.
- **Contract fixtures** for every supported version stay in the test suite until that version is removed (15).
- **A2A spec upgrades** follow the SDK. The A2A v0.3 compatibility layer gets turned on only if real partners still speak v0.3.

5. Dependency and security patching

What	How	Cadence
npm dependencies	Dependabot PRs, dev tools grouped, through CI	Weekly; merge within 1 week
GitHub Actions	Dependabot updates the SHA pins	Weekly
CVE in a runtime dependency	Patch release	P-16: critical within 48 hours; high within 7 days; others in the next release
Node runtime	Stay on the active LTS; move to the next LTS within 3 months of its LTS date	Twice a year check
A2A SDK	Read release notes; upgrade in its own PR with the e2e tests	Each minor release

6. Tech-debt register

Packages named below follow 10: `packages/e2e`, `packages/directory` (also hosts admin), `packages/app`, `packages/dashboard`, `packages/ratings`. Seeded from the Phase 1 audit and the ADR correction notes. Reviewed at the start of each phase.

ID	Debt	Why it matters	Priority	Pay down by
D-01	Times are UTC only; shop hours are whole UTC hours, not minutes of the local day	Wrong slots for any real shop; no real booking happens before this is paid	High	Phase 6, before the first real booking (ADR 0018: IANA zone per business, local slot grid, DST rules, UTC on the wire)
D-02	Package `exports` point at `.ts` source	Breaks under copy installs, Docker, publishing	High	Phase 6 (ADR 0016: compile step)
D-03	Offers aren't stored; no slot hold	No approval binding (T-04)	High	Phase 2 (ADR 0012, ADR 0013)
D-04	No auth or rate limits on agents	Anyone who can reach the port can call it or lock slots	High	Phase 2 for the holds cap and per-IP limit (P-07, P-08); Phase 6 for authentication (ADR 0017)
D-05	Client trusts the card's advertised URL; no SSRF block list or size cap	SSRF once a hosted service reads directory URLs (T-13)	High	Phase 3 (ADR 0015)
D-06	Every invalid request gets the same rejection reason; unknown service looks like "no availability"	Poor developer experience for other agent builders	Medium	Phase 2
D-07	End-to-end tests live in `my-agent`, which devDepends on `barber-agent`	Becomes a cycle once the barber side needs my agent	Medium	Phase 2 (move to `packages/e2e`)
D-08	Public agent URL comes from the bind address	Wrong URL when hosted	Medium	Phase 6
D-09	`cancelTask` is a no-op	Breaks the SDK contract once Tasks are used	Medium	Phase 2
D-10	In-memory task store and book	All state lost on restart	High	Phase 2: SQLite on the business side (SDK `DatabaseTaskStore` plus offers, bookings, audit), JSONL on the personal side (NFR-REL-02); Phase 6: Postgres `slot_claims`
D-11	`@a2a-js/sdk` version declared in three packages	Drift between packages	Low	Phase 2 (pnpm catalog)
D-12	No `pnpm audit` or release-age delay in CI	Slower to spot bad dependencies	Low	Phase 6
D-13	Claude review runs on docs-only pushes	API cost	Low	When cost shows up
D-14	Businesses without a website are verified in person (pilot only, see 17)	Doesn't scale past one neighbourhood	Medium	Before expanding beyond the pilot area
D-15	The shop's book configuration isn't validated at load: an unparseable booked `start` silently stops blocking its slot; hours, service uniqueness and currency are unchecked	Silent double-booking risk from a bad config	High	Phase 2 (FR-BOOK-12, WP-2.10): validate at load and refuse to start on an invalid book

New debt gets a row when it's created, with the reason it was accepted. That's the same rule as the `shortcut:` comments in code.

7. Documentation upkeep

- **Decision records:** a new ADR for every choice that's expensive to reverse. Old ones are never rewritten; dated status or correction notes are added instead, as done after the audit.
- **Build journey:** one entry per phase or major event, written when it happens.
- **Bug log:** every real bug, with root cause and prevention. PR template checkbox.
- **This SA&D set:** each phase's PR updates the status labels (Phase N to Built) in the docs it touches. Before each release I check that nothing says Built that isn't. Any value or phase used in more than one document changes in 00 first and is cited by its P-ID; the scripted consistency check covers IDs and links, not values, so that rule is what keeps values consistent.
- **Audits:** before Phase 2 ships, before production, then yearly.

8. Metrics review

Cadence	Review
Weekly (pilot)	North star: weekly human-approved bookings that were honored. Counter-metrics: first-offer rejection rate, median time to approve, booking errors, reports per 100 interactions, repeat use within 60 days.
Monthly	SLOs and error budget, API and hosting cost, open SEV1 and SEV2 count, Dependabot backlog, mutation test results.
Per phase	Assumption tests and risks R-01 to R-12 from the business case: continue, change or stop. Progress against the six v1 release criteria.
Yearly	Security re-audit, hosting cost review, roadmap reset.

9. Roadmap beyond v1

Theme	What	Depends on
More verticals	Salons, trades, restaurants, then clinics last (privacy rules). Generalise the appointment model only when the second vertical arrives (ADR 0008).	Pilot results
Language-model front end	Turn "Thursday after work" into a request; summarise offers. Under the injection rules in 12.	Phase 2 gate
Real booking systems	MCP connectors to the booking tools barbers actually use, replacing the in-memory book (ADR 0011)	Barber interviews, API access
Payments and deposits (not in v1)	Deposits for no-show protection, through a payment provider, never stored by Hitchpost. Brings PCI and consumer-protection scope.	Legal review
Third-party assistants	Any A2A-speaking personal assistant can use the directory and the gate	Directory API stability
Federation	Other directories can mirror or peer with Hitchpost listings, so no single operator owns the commons (ADR 0004)	Signed cards, stable contract

10. Sunset and end of life

If the pilot's kill criteria are met (03), or I stop maintaining the project:

1. **Announce at least 90 days ahead** to listed businesses, app users and in the README.
2. **Freeze new listings**, keep existing bookings working until the date.
3. **Export:** every business gets its listing and booking data as JSON; every person gets theirs.
4. **Delete** personal data after the export window, and say so publicly.
5. **Archive the repository** with a final journey entry on what was learned. The code stays MIT-licensed, so anyone can fork and run it.
6. **Hand over** the directory domain and data to a willing community maintainer if one exists, with business consent.

Revision history

Version	Date	Change	Author
0.1	2026-11-08	First draft	S. Jannisar
1.0	2026-11-09	Baselined: renumbered into lifecycle order, formal document control, standards conformance	S. Jannisar
1.1	2026-11-09	Remediation after independent review: one support table by severity (P-17) that 17 and 18 link to; SEV labels replace P0 to P3; contract versioning via `AgentCapabilities.extensions`, major only (P-18); patching per P-16; D-01 time zones moved to Phase 6; D-04 and D-10 brought into Phase 2 where the plan now pays them; new D-15 (book configuration validation, FR-BOOK-12)	S. Jannisar
1.2	2026-11-09	Second remediation after regrade: this is now the single SEV table (precise SEV1 and SEV2 triggers, no SEV1 cover during the pilot holiday pause); 17 and 18 cite it	S. Jannisar

HP-SAD-20 · Glossary

Field	Value
Document ID	HP-SAD-20
Version	1.1
Status	Baselined for Phase 2
Date	2026-11-09
Owner	Sanaullah Jannisar, product and engineering lead
Conforms to	ISO/IEC/IEEE 29148 (definitions), ISO/IEC/IEEE 24765 (vocabulary, where terms overlap)

1. Purpose and scope

One meaning per term across the whole package. Where a term has a general industry meaning and a narrower Hitchpost meaning, the Hitchpost meaning is given and the difference noted. Other documents link here instead of redefining terms.

2. Terms

Term	Definition
A2A (Agent2Agent)	Open protocol, now a Linux Foundation project, for agents to discover each other and exchange messages and tasks. Hitchpost uses specification v1.0 through `@a2a-js/sdk` 1.3 (ADR 0003).
ADR (architecture decision record)	Short numbered record of one significant decision: context, decision, alternatives, consequences. Kept in `docs/decisions/`.
Agent	Software that acts for one party. A *business agent* acts for a shop; a *personal agent* acts for a person.
Agent Card	JSON document an A2A agent publishes at `/.well-known/agent-card.json` describing its name, endpoint, skills and accepted contract versions.
Agent record	The structured behaviour metrics shown for a business agent (response time, offers honored, reports), as distinct from human star ratings (FR-RATE-02).
Appointment book	The business's schedule: services, opening hours and booked time ranges. In-memory in Phase 1 (`book.ts`); a real booking system over MCP later.
Approval	A recorded human yes to one specific offer. In code, a value only the approval gate can create, bound to one `offerId` and expiring with it (FR-GATE-02, FR-GATE-04).
Approval gate	The component and rule that nothing committing a person (time, money, personal data) happens without that person's approval (ADR 0007). The trust floor of the product, not its moat.
Approval sheet	The client app screen that shows a validated offer and the Approve and Decline buttons.
Audit log	Append-only record of offers, decisions and booking results kept on both sides of an exchange (FR-GATE-03).
Availability request	Message kind asking a business agent for the first free slot for a service within a time window.
Baseline	An approved version of a document or document set that changes only through change control (HP-SAD-00).
Booking	A confirmed time range in the business's appointment book for one person and one service.
Booking request	Message kind by which a personal agent, after approval, asks the business agent to book a specific stored offer, in that offer's `contextId`. Repeating it returns the existing Task (FR-BOOK-07).
Booking outcome	What happened to a booking once its time has passed: **Completed** (the customer came) or **NoShow** (they didn't), marked by the shop or answered by the customer through "Did it go as booked?" (FR-RATE-04).
Built	Status label meaning the item exists in the code today, with a path or test cited.
Business rule	A constraint the system enforces regardless of interface, numbered BR-nn in HP-SAD-07.
C4 model	Notation for architecture diagrams at context, container, component and code levels.
Cold start	The two-sided problem that a directory without businesses has no users, and without users attracts no businesses.
Contract version	The major version of the Hitchpost message contract an agent accepts, declared on its Agent Card as an `AgentCapabilities.extensions` entry (`https://hitchpost.dev/ext/contract/v1` from Phase 2) and listed in each message's `extensions`. Major versions only (P-18).
contextId	A2A identifier, minted by the server, that ties the messages and tasks of one conversation together. An offer can only be booked, declined, cancelled or rescheduled within its own `contextId` (FR-MSG-12). Until agent authentication it acts as a bearer capability: logged, never shown in a UI or URL.
Correlation fields	`contextId`, `taskId`, `offerId` and `messageId`, recorded on every audit event from Phase 2 so one booking can be followed across both sides (FR-MSG-11).
Counter-metric	A metric that must not get worse while the north star grows (for example first-offer rejection rate).
Data part	A2A message part carrying structured JSON, as opposed to a text part. All Hitchpost booking messages travel as data parts (ADR 0010).
Directory	Public, searchable register of verified business agents (Phase 3).
Expiry (`expiresAt`)	The instant an offer stops being bookable and its hold is released: `issuedAt` plus P-01 (10 minutes), on the business clock. The personal agent treats it as expired 30 seconds early (P-09).
Honored booking	A booking whose outcome is Completed. The north star counts these.
Hold	Temporary reservation of a slot while an offer is open (P-01), so it can't be offered to someone else. Capped per `contextId` and per sender (P-07).
`issuedAt`	The business agent's clock time when it created an offer. The business clock is authoritative for expiry.

Term	Definition
Kill criterion	A pre-set result of an assumption test that stops or changes the plan.
Listing	A directory entry for one business agent, pointing to its Agent Card.
Listing origin	The scheme, host and port a listing was verified for. A card's interface URL must match it (FR-DIR-03).
Manual approval	Per-shop setting under which the owner accepts each booking. The booking Task stays WORKING with a "waiting for the shop" status, the slot is reserved, and the personal agent polls `GetTask`; after P-03 (30 minutes) it ends with `shop_timeout` (FR-GATE-05). It doesn't use input-required, which in A2A means the client must reply.
MCP (Model Context Protocol)	Open protocol connecting an agent to its own tools and data. Planned for reaching real booking systems; not used in Phase 1.
Message (A2A)	A single A2A exchange unit. Hitchpost uses Messages for stateless questions (availability).
Normative parameter (P-nn)	A value or phase used in more than one document, kept once in 00 and cited by its ID everywhere else.
North star	The one metric the product is steered by: weekly human-approved bookings that were honored, meaning their outcome is Completed.
Offer	Message kind from a business agent proposing one slot: service, start, duration, price, currency, and from Phase 2 a stored `offerId`, `issuedAt` and `expiresAt`.
Offer declined (`offer_declined`)	Message kind a personal agent sends when the person declines; it releases the hold at once (FR-BOOK-08).
Offer match	The check that an offer answers the request it replies to: same service and a start inside the requested window (`offerMatches`, FR-MSG-04).
Personal agent	The agent acting for a person. The built-in agent in the client app is the consumer agent at Phase 4 launch.
Phase	One stage of the delivery plan, 0 to 6 then Later, each with an exit gate (HP-SAD-16).
Phase gate	The review at the end of a phase that checks its exit criteria before the next phase starts.
Prompt injection	Text crafted to make a language model follow instructions it shouldn't. Inbound agent data is treated as data, never instructions.
Protocol-safe work	Work done during the A-01 test that is worth keeping even if A-01 fails and the project stops at Phase 1: book validation, the e2e contract tests and the ADR notes (HP-SAD-16).
Quality attribute scenario	A testable statement of a quality requirement: source, stimulus, environment, artifact, response, response measure (HP-SAD-11).
Rejected	Message kind a business agent returns when it can't validate a request.
Reserved hold	The hold on an offer after its `booking_request` is accepted while the shop decides; it lasts until the shop answers or P-03 passes (P-02).
Slot	A start time on the 30-minute grid in which a service fits inside opening hours and overlaps no booking or hold.
SLI and SLO	Service level indicator (what is measured) and objective (the target), for example offer round trip p95 under 2 s.
Standing approval	Default business-side rule that a shop's published hours and services count as its approval to book any free slot.
STRIDE	Threat classification: spoofing, tampering, repudiation, information disclosure, denial of service, elevation of privilege.
Task (A2A)	Stateful A2A unit of work with a lifecycle (submitted, working, input-required, completed, rejected, failed). Hitchpost uses Tasks for commitments: book, cancel, reschedule (ADR 0012). A booking waiting for the shop stays working; Hitchpost never uses input-required for that.
Time zone rule	Phase 6 (ADR 0018): UTC on the wire; each business has an IANA time zone; hours are minutes of the local day; the slot grid starts at local opening time; a skipped local time gives no slot and a repeated one is offered once. Before Phase 6 everything is UTC and demo-only.
Trust boundary	A line across which data changes trust level, labelled B1 to B6 in HP-SAD-12.
Untrusted data	Anything received from another agent or the network. Validated and rebuilt before use (FR-MSG-03).
Verified business	A listing whose control of its domain has been proven by a well-known token or DNS TXT record (FR-DIR-01).
Verified interaction	An interaction with a logged offer and a matching logged decision on both sides, ending in a booking that reached Completed or NoShow. Only these can be rated (FR-RATE-01). Same wording as 05.
Walking skeleton	The smallest end-to-end slice that runs through the whole pipeline (ADR 0009).
Wizard of Oz test	A test where a person plays the system by hand to learn whether users want it before it is built (A-01).

3. Acronyms

Acronym	Expansion
A2A	Agent2Agent protocol
ADR	Architecture decision record
API	Application programming interface
ATAM	Architecture Tradeoff Analysis Method
CCPA	California Consumer Privacy Act
CI/CD	Continuous integration and continuous delivery
CRUD	Create, read, update, delete
DFD	Data flow diagram
DNS	Domain Name System
DR	Disaster recovery

Acronym	Expansion
ERD	Entity relationship diagram
GDPR	General Data Protection Regulation (EU)
IANA	Internet Assigned Numbers Authority (time zone database)
JCS	JSON Canonicalization Scheme (RFC 8785), used for card signing and audit hashes
JWKS	JSON Web Key Set, where an agent's public signing keys are published
JWS	JSON Web Signature
KMS	Key management service
ISO 8601	International standard for date and time strings
JSON-RPC	JSON remote procedure call protocol, the A2A binding Hitchpost uses
MCP	Model Context Protocol
NFR	Non-functional requirement
NPV	Net present value
p95	95th percentile
PR	Pull request
RACI	Responsible, accountable, consulted, informed
RPO and RTO	Recovery point objective and recovery time objective
SDK	Software development kit
SHA	Secure hash algorithm; here, a git commit hash used to pin an action
SLA	Service level agreement
SLI and SLO	Service level indicator and objective
SSRF	Server-side request forgery
SUS	System Usability Scale
UAT	User acceptance testing
UTC	Coordinated Universal Time
WBS	Work breakdown structure
WCAG	Web Content Accessibility Guidelines

4. ID prefix legend

Every ID family in the package, with where it's defined. Prefixes are chosen so no two families can be confused: in particular P-01 to P-20 are parameters, P1 to P7 (no dash) are DFD processes, and UI principles use UP-.

Prefix	Meaning	Defined in
P-	Normative parameter: a value or phase used in more than one document (P-01 to P-20)	HP-SAD-00
G-	Goal	HP-SAD-01
ALT-	Alternative in the feasibility analysis (ALT-A to ALT-D)	HP-SAD-02
A-	Assumption to test, with kill criterion	HP-SAD-03
R-	Risk	HP-SAD-03
FR-	Functional requirement, by area (MSG, BOOK, GATE, DIR, APP, RATE, ADMIN)	HP-SAD-05
NFR-	Non-functional requirement, by area (SEC, PRIV, PERF, REL, OBS, A11Y, MAINT, INT)	HP-SAD-05
UC-	Use case	HP-SAD-06
P1 to P7	Process in the data flow diagrams (no dash; sub-processes P4.1 and so on)	HP-SAD-07
DS	Data store in the data flow diagrams (DS1 to DS7, no dash)	HP-SAD-07
E-	Event (external or temporal) in the event list	HP-SAD-07
BR-	Business rule	HP-SAD-07
DQ-	Data quality rule	HP-SAD-09
CR-	Correspondence rule between architecture views	HP-SAD-10
QAS-	Quality attribute scenario	HP-SAD-11
SP-	Sensitivity point (ATAM)	HP-SAD-11
TO-	Trade-off point (ATAM)	HP-SAD-11
AR-	Architecture risk (ATAM)	HP-SAD-11
NR-	Non-risk (ATAM)	HP-SAD-11
T-	Threat	HP-SAD-12

Prefix	Meaning	Defined in
UP-	User interface design principle	HP-SAD-14
UT-	Usability test task	HP-SAD-14
TC-	Test case	HP-SAD-15
WP-	Work package in the work breakdown structure	HP-SAD-16
M-	Milestone	HP-SAD-16
S0 to S3	Pilot stage (no dash)	HP-SAD-17
C1 to C3	Booking-tool connection option (no dash)	HP-SAD-17
D-	Tech-debt item	HP-SAD-19
SEV1 to SEV3	Incident and support severity	HP-SAD-19

Revision history

Version	Date	Change	Author
1.0	2026-11-09	First baseline	S. Jannisar
1.1	2026-11-09	Remediation after independent review: one verified-interaction definition, word for word with 05; manual approval described as a WORKING Task, not input-required; contract version via `AgentCapabilities.extensions`; new terms (booking outcome, honored booking, correlation fields, `issuedAt`, normative parameter, `offer_declined`, protocol-safe work, reserved hold); time zones placed in Phase 6; unused OIDC removed, JCS, JWKS, JWS and KMS added; ID prefix legend completed with no collisions (P- vs P1, UP-, UT-)	S. Jannisar